

1000

MITRE ATT&CK

Detection Mapping Compendium

Practical scenario-to-technique mappings for SOC monitoring, detection engineering, threat hunting, investigation and safe validation

BY IZZMIER IZZUDDIN

Coverage Distribution

Chapter	Tactic	ATT&CK ID	Techniques	Mappings
1	Reconnaissance	TA0043	6	58
2	Resource Development	TA0042	6	58
3	Initial Access	TA0001	7	67
4	Execution	TA0002	7	67
5	Persistence	TA0003	7	67
6	Privilege Escalation	TA0004	6	58
7	Defense Evasion	TA0005	9	85
8	Credential Access	TA0006	8	76
9	Discovery	TA0007	9	85
10	Lateral Movement	TA0008	7	67
11	Collection	TA0009	8	76
12	Command and Control	TA0011	8	76
13	Exfiltration	TA0010	7	67
14	Impact	TA0040	10	93

Contents

Chapter	Tactic and scope	Mapping range
1	TA0043 Reconnaissance - 6 techniques	MAP-0001 to MAP-0058
2	TA0042 Resource Development - 6 techniques	MAP-0059 to MAP-0116
3	TA0001 Initial Access - 7 techniques	MAP-0117 to MAP-0183
4	TA0002 Execution - 7 techniques	MAP-0184 to MAP-0250
5	TA0003 Persistence - 7 techniques	MAP-0251 to MAP-0317
6	TA0004 Privilege Escalation - 6 techniques	MAP-0318 to MAP-0375
7	TA0005 Defense Evasion - 9 techniques	MAP-0376 to MAP-0460
8	TA0006 Credential Access - 8 techniques	MAP-0461 to MAP-0536
9	TA0007 Discovery - 9 techniques	MAP-0537 to MAP-0621
10	TA0008 Lateral Movement - 7 techniques	MAP-0622 to MAP-0688
11	TA0009 Collection - 8 techniques	MAP-0689 to MAP-0764
12	TA0011 Command and Control - 8 techniques	MAP-0765 to MAP-0840
13	TA0010 Exfiltration - 7 techniques	MAP-0841 to MAP-0907
14	TA0040 Impact - 10 techniques	MAP-0908 to MAP-1000

1. TA0043 - Reconnaissance

This chapter contains 58 practical mappings across 6 priority techniques. A realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

1.1 T1595 - Active Scanning (10 mappings: MAP-0001-MAP-0010)

Behavior focus: Repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence.

MAP-0001 T1595 Active Scanning - Burst scanning of the public portal	
ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing banking portal shows the following pattern: a previously unseen cloud-hosted source sends a burst of requests across uncommon ports, paths and service banners. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an approved vulnerability scanner in discovery-only mode against a designated test endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0002 T1595 Active Scanning - Slow probing of the VPN gateway	
ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, the remote-access perimeter shows the following pattern: low-rate requests enumerate gateway paths, authentication methods and exposed services over several days. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, replay a small synthetic sequence of harmless HTTP and connection attempts against a lab VPN interface. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0003 T1595 Active Scanning - Public cloud address enumeration	
ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud workload shows the following pattern: queries and connection attempts focus on newly published cloud addresses shortly after deployment. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled scanner from an approved test address to touch only documented non-production ports. Use synthetic identities and data, reserved test infrastructure, a documented change

	ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

MAP-0004 | T1595 Active Scanning - Certificate and DNS footprint collection

ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, the organisation public namespace shows the following pattern: certificate transparency, passive DNS and web observations reveal newly created hostnames that are then queried externally. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, publish a temporary test hostname and confirm that external observation data is ingested and correlated. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0005 | T1595 Active Scanning - Employee and identity research

ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, public professional and collaboration channels shows the following pattern: external activity collects employee names, roles, email formats and help-desk details before contact attempts. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed synthetic employee identities in a controlled awareness exercise and monitor only approved test interactions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0006 | T1595 Active Scanning - API endpoint discovery

ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing API gateway shows the following pattern: requests enumerate versions, schemas, error messages and undocumented paths without completing normal business transactions. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a finite set of benign malformed and documentation-path requests to a test API. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0007 | T1595 Active Scanning - Third-party portal mapping

ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, a supplier-facing portal shows the following pattern: a new source profiles login pages, software versions and trust relationships associated with a partner connection. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a scoped discovery assessment against a supplier test tenant under an agreed change ticket. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0008 | T1595 Active Scanning - Branch public address probing

ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a branch internet edge shows the following pattern: sequential connection attempts target branch public addresses and network services that are not normally accessed from the internet. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate limited connection attempts from the security test range to a branch lab firewall. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0009 | T1595 Active Scanning - Crawler masquerading as normal traffic

ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a customer web application shows the following pattern: an automated client imitates a browser while systematically enumerating files, parameters and hidden routes. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved crawler with an identifying test header against a cloned web application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0010 | T1595 Active Scanning - Reconnaissance followed by login attempts

ATT&CK mapping	TA0043 Reconnaissance -> T1595 Active Scanning Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, the digital identity perimeter shows the following pattern: service discovery and username-oriented requests are followed by authentication failures from related infrastructure. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1595 because the core observable is repeated or specialized

	probes identify services, versions, paths and weaknesses on internet-facing assets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across WAF; firewall; IDS/IPS; load balancer; web server; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vulnerability scanners, uptime monitors, search-engine crawlers and approved penetration tests.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create synthetic reconnaissance and failed-login events with test identities and reserved source addresses. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Active Scanning without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

1.2 T1592 - Gather Victim Host Information (10 mappings: MAP-0011-MAP-0020)

Behavior focus: External research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. Primary analytic: External observation enriched with internal activity. Core telemetry: Attack surface management; passive DNS; certificate transparency; WAF; asset inventory.

MAP-0011 T1592 Gather Victim Host Information - Burst scanning of the public portal	
ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing banking portal shows the following pattern: a previously unseen cloud-hosted source sends a burst of requests across uncommon ports, paths and service banners. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an approved vulnerability scanner in discovery-only mode against a designated test endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0012 T1592 Gather Victim Host Information - Slow probing of the VPN gateway	
ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, the remote-access perimeter shows the following pattern: low-rate requests enumerate gateway paths, authentication methods and exposed services over several days. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, replay a small synthetic sequence of harmless HTTP and connection attempts against a lab VPN interface. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0013 T1592 Gather Victim Host Information - Public cloud address enumeration	
ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud workload shows the following pattern: queries and connection attempts focus on newly published cloud addresses shortly after deployment. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Build a correlation that external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled scanner from an approved test address to touch only documented non-production ports. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0014 | T1592 Gather Victim Host Information - Certificate and DNS footprint collection

ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, the organisation public namespace shows the following pattern: certificate transparency, passive DNS and web observations reveal newly created hostnames that are then queried externally. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, publish a temporary test hostname and confirm that external observation data is ingested and correlated. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0015 | T1592 Gather Victim Host Information - Employee and identity research

ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, public professional and collaboration channels shows the following pattern: external activity collects employee names, roles, email formats and help-desk details before contact attempts. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed synthetic employee identities in a controlled awareness exercise and monitor only approved test interactions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0016 | T1592 Gather Victim Host Information - API endpoint discovery

ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing API gateway shows the following pattern: requests enumerate versions, schemas, error messages and undocumented paths without completing normal business transactions. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source,

	confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a finite set of benign malformed and documentation-path requests to a test API. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0017 T1592 Gather Victim Host Information - Third-party portal mapping	
ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, a supplier-facing portal shows the following pattern: a new source profiles login pages, software versions and trust relationships associated with a partner connection. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a scoped discovery assessment against a supplier test tenant under an agreed change ticket. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0018 T1592 Gather Victim Host Information - Branch public address probing	
ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a branch internet edge shows the following pattern: sequential connection attempts target branch public addresses and network services that are not normally accessed from the internet. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate limited connection attempts from the security test range to a branch lab firewall. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0019 T1592 Gather Victim Host Information - Crawler masquerading as normal traffic	
ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a customer web application shows the following pattern: an automated client imitates a browser while systematically enumerating files, parameters and hidden routes. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing.. Confirm the source ownership, first-seen time, targeted assets, requested paths or

	services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved crawler with an identifying test header against a cloned web application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0020 T1592 Gather Victim Host Information - Reconnaissance followed by login attempts	
ATT&CK mapping	TA0043 Reconnaissance -> T1592 Gather Victim Host Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, the digital identity perimeter shows the following pattern: service discovery and username-oriented requests are followed by authentication failures from related infrastructure. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1592 because the core observable is external research identifies operating systems, software versions, exposed hostnames or device characteristics associated with the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Attack surface management; passive DNS; certificate transparency; WAF; asset inventory. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security research, vendor support activity and ordinary internet indexing. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create synthetic reconnaissance and failed-login events with test identities and reserved source addresses. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Host Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

1.3 T1590 - Gather Victim Network Information (10 mappings: MAP-0021-MAP-0030)

Behavior focus: The adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. Primary analytic: External observation enriched with internal activity. Core telemetry: Passive DNS; DNS; firewall; certificate transparency; threat intelligence.

MAP-0021 T1590 Gather Victim Network Information - Burst scanning of the public portal	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing banking portal shows the following pattern: a previously unseen cloud-hosted source sends a burst of requests across uncommon ports, paths and service banners. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an approved vulnerability scanner in discovery-only mode against a designated test endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0022 T1590 Gather Victim Network Information - Slow probing of the VPN gateway	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, the remote-access perimeter shows the following pattern: low-rate requests enumerate gateway paths, authentication methods and exposed services over several days. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, replay a small synthetic sequence of harmless HTTP and connection attempts against a lab VPN interface. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0023 T1590 Gather Victim Network Information - Public cloud address enumeration	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud workload shows the following pattern: queries and connection attempts focus on newly published cloud addresses shortly after deployment. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled scanner from an approved test address to touch only documented non-production ports. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0024 T1590 Gather Victim Network Information - Certificate and DNS footprint collection	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, the organisation public namespace shows the following pattern: certificate transparency, passive DNS and web observations reveal newly created hostnames that are then queried externally. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, publish a temporary test hostname and confirm that external observation data is ingested and correlated. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0025 T1590 Gather Victim Network Information - Employee and identity research	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, public professional and collaboration channels shows the following pattern: external activity collects employee names, roles, email formats and help-desk details before contact attempts. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed synthetic employee identities in a controlled awareness exercise and monitor only approved test interactions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0026 T1590 Gather Victim Network Information - API endpoint discovery	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing API gateway shows the following pattern: requests enumerate versions, schemas, error messages and undocumented paths without completing normal business transactions. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a finite set of benign malformed and documentation-path requests to a test API. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0027 T1590 Gather Victim Network Information - Third-party portal mapping	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, a supplier-facing portal shows the following pattern: a new source profiles login pages, software versions and trust relationships associated with a partner connection. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a scoped discovery assessment against a supplier test tenant under an agreed change ticket. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0028 T1590 Gather Victim Network Information - Branch public address probing	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a branch internet edge shows the following pattern: sequential connection attempts target branch public addresses and network services that are not normally accessed from the internet. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate limited connection attempts from the security test range to a branch lab firewall. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0029 T1590 Gather Victim Network Information - Crawler masquerading as normal traffic	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a customer web application shows the following pattern: an automated client imitates a browser while systematically enumerating files, parameters and hidden routes. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved crawler with an identifying test header against a cloned web application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0030 T1590 Gather Victim Network Information - Reconnaissance followed by login attempts	
ATT&CK mapping	TA0043 Reconnaissance -> T1590 Gather Victim Network Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, the digital identity perimeter shows the following pattern: service discovery and username-oriented requests are followed by authentication failures from related infrastructure. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1590 because the core observable is the adversary collects netblocks, DNS records, VPN gateways, cloud ranges and network trust information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Passive DNS; DNS; firewall; certificate transparency; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting, domain administration and third-party assessment.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create synthetic reconnaissance and failed-login events with test identities and reserved source addresses. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Network Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

1.4 T1589 - Gather Victim Identity Information (10 mappings: MAP-0031-MAP-0040)

Behavior focus: Public or breached sources are used to enumerate employee names, email addresses, roles and credential material. Primary analytic: High-impact change with actor and authentication context. Core telemetry: Threat intelligence; brand monitoring; identity protection; email security.

MAP-0031 T1589 Gather Victim Identity Information - Burst scanning of the public portal	
ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing banking portal shows the following pattern: a previously unseen cloud-hosted source sends a burst of requests across uncommon ports, paths and service banners. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an approved vulnerability scanner in discovery-only mode against a designated test endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0032 T1589 Gather Victim Identity Information - Slow probing of the VPN gateway	
ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, the remote-access perimeter shows the following pattern: low-rate requests enumerate gateway paths, authentication methods and exposed services over several days. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved

	workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, replay a small synthetic sequence of harmless HTTP and connection attempts against a lab VPN interface. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0033 | T1589 Gather Victim Identity Information - Public cloud address enumeration

ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud workload shows the following pattern: queries and connection attempts focus on newly published cloud addresses shortly after deployment. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled scanner from an approved test address to touch only documented non-production ports. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0034 | T1589 Gather Victim Identity Information - Certificate and DNS footprint collection

ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, the organisation public namespace shows the following pattern: certificate transparency, passive DNS and web observations reveal newly created hostnames that are then queried externally. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, publish a temporary test hostname and confirm that external observation data is ingested and correlated. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0035 | T1589 Gather Victim Identity Information - Employee and identity research

ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, public professional and collaboration channels shows the following pattern: external activity collects employee names, roles, email formats and help-desk details before contact attempts. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets,

	requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed synthetic employee identities in a controlled awareness exercise and monitor only approved test interactions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0036 T1589 Gather Victim Identity Information - API endpoint discovery	
ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing API gateway shows the following pattern: requests enumerate versions, schemas, error messages and undocumented paths without completing normal business transactions. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a finite set of benign malformed and documentation-path requests to a test API. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0037 T1589 Gather Victim Identity Information - Third-party portal mapping	
ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, a supplier-facing portal shows the following pattern: a new source profiles login pages, software versions and trust relationships associated with a partner connection. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a scoped discovery assessment against a supplier test tenant under an agreed change ticket. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0038 T1589 Gather Victim Identity Information - Branch public address probing	
ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a branch internet edge shows the following pattern: sequential connection attempts target branch public addresses and network services that are not normally accessed from the internet. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate limited connection attempts from the security test range to a branch lab firewall. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized

	timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0039 T1589 Gather Victim Identity Information - Crawler masquerading as normal traffic	
ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a customer web application shows the following pattern: an automated client imitates a browser while systematically enumerating files, parameters and hidden routes. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved crawler with an identifying test header against a cloned web application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0040 T1589 Gather Victim Identity Information - Reconnaissance followed by login attempts	
ATT&CK mapping	TA0043 Reconnaissance -> T1589 Gather Victim Identity Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, the digital identity perimeter shows the following pattern: service discovery and username-oriented requests are followed by authentication failures from related infrastructure. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1589 because the core observable is public or breached sources are used to enumerate employee names, email addresses, roles and credential material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across Threat intelligence; brand monitoring; identity protection; email security. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include recruitment research, sales prospecting and legitimate directory queries.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create synthetic reconnaissance and failed-login events with test identities and reserved source addresses. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Gather Victim Identity Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

1.5 T1598 - Phishing for Information (9 mappings: MAP-0041-MAP-0049)

Behavior focus: Messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. Primary analytic: Delivery-to-interaction sequence correlation. Core telemetry: Email gateway; mailbox audit; identity provider; user reporting.

MAP-0041 T1598 Phishing for Information - Burst scanning of the public portal	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing banking portal shows the following pattern: a previously unseen cloud-hosted source sends a burst of requests across uncommon ports, paths and service banners. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an approved vulnerability scanner in discovery-only mode against a designated test endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0042 T1598 Phishing for Information - Slow probing of the VPN gateway	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, the remote-access perimeter shows the following pattern: low-rate requests enumerate gateway paths, authentication methods and exposed services over several days. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, replay a small synthetic sequence of harmless HTTP and connection attempts against a lab VPN interface. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0043 T1598 Phishing for Information - Public cloud address enumeration	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud workload shows the following pattern: queries and connection attempts focus on newly published cloud addresses shortly after deployment. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled scanner from an approved test address to touch only documented non-production ports. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0044 T1598 Phishing for Information - Certificate and DNS footprint collection	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, the organisation public namespace shows the following pattern: certificate transparency, passive DNS and web observations reveal newly created hostnames that are then queried externally. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, publish a temporary test hostname and confirm that external observation data is ingested and correlated. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0045 T1598 Phishing for Information - Employee and identity research	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, public professional and collaboration channels shows the following pattern: external activity collects employee names, roles, email formats and help-desk details before contact attempts. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or

	calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed synthetic employee identities in a controlled awareness exercise and monitor only approved test interactions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0046 T1598 Phishing for Information - API endpoint discovery	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internet-facing API gateway shows the following pattern: requests enumerate versions, schemas, error messages and undocumented paths without completing normal business transactions. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a finite set of benign malformed and documentation-path requests to a test API. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0047 T1598 Phishing for Information - Third-party portal mapping	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, a supplier-facing portal shows the following pattern: a new source profiles login pages, software versions and trust relationships associated with a partner connection. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a scoped discovery assessment against a supplier test tenant under an agreed change ticket. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0048 T1598 Phishing for Information - Branch public address probing	
ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a branch internet edge shows the following pattern: sequential connection attempts target branch public addresses and network services that are not normally accessed from the internet. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate limited connection attempts from the security test range to a branch lab firewall. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0049 | T1598 Phishing for Information - Crawler masquerading as normal traffic

ATT&CK mapping	TA0043 Reconnaissance -> T1598 Phishing for Information Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a customer web application shows the following pattern: an automated client imitates a browser while systematically enumerating files, parameters and hidden routes. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1598 because the core observable is messages or calls seek passwords, codes, organizational details or other information without necessarily delivering malware. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where delivery-to-interaction sequence correlation across Email gateway; mailbox audit; identity provider; user reporting. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate surveys, help-desk verification and vendor communications.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved crawler with an identifying test header against a cloned web application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing for Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

1.6 T1593 - Search Open Websites and Domains (9 mappings: MAP-0050-MAP-0058)

Behavior focus: The adversary mines public websites, code repositories, social platforms and documents for operationally useful information. Primary analytic: External observation enriched with internal activity. Core telemetry: Threat intelligence; DLP; code-repository audit; web publishing review.

MAP-0050 | T1593 Search Open Websites and Domains - Burst scanning of the public portal

ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, an internet-facing banking portal shows the following pattern: a previously unseen cloud-hosted source sends a burst of requests across uncommon ports, paths and service banners. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an approved vulnerability scanner in discovery-only mode against a designated test endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0051 | T1593 Search Open Websites and Domains - Slow probing of the VPN gateway

ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During an analyst-led hunt, the remote-access perimeter shows the following pattern: low-rate requests enumerate gateway paths, authentication methods and exposed services over several days. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, replay a small synthetic sequence of harmless HTTP and connection attempts against a lab VPN interface. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0052 T1593 Search Open Websites and Domains - Public cloud address enumeration	
ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While reviewing a high-value system, a public cloud workload shows the following pattern: queries and connection attempts focus on newly published cloud addresses shortly after deployment. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled scanner from an approved test address to touch only documented non-production ports. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0053 T1593 Search Open Websites and Domains - Certificate and DNS footprint collection	
ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a user or application anomaly, the organisation public namespace shows the following pattern: certificate transparency, passive DNS and web observations reveal newly created hostnames that are then queried externally. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, publish a temporary test hostname and confirm that external observation data is ingested and correlated. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0054 T1593 Search Open Websites and Domains - Employee and identity research	
ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After threat-intelligence enrichment, public professional and collaboration channels shows the following pattern: external activity collects employee names, roles, email formats and help-desk details before contact attempts. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed synthetic employee identities in a controlled awareness exercise and monitor only approved test interactions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0055 T1593 Search Open Websites and Domains - API endpoint discovery	
ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, an internet-facing API gateway shows the following pattern: requests enumerate versions, schemas, error messages and undocumented paths without completing normal business transactions. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a finite set of benign malformed and documentation-path requests to a test API. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0056 T1593 Search Open Websites and Domains - Third-party portal mapping	
ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During an analyst-led hunt, a supplier-facing portal shows the following pattern: a new source profiles login pages, software versions and trust relationships associated with a partner connection. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a scoped discovery assessment against a supplier test tenant under an agreed change ticket. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0057 T1593 Search Open Websites and Domains - Branch public address probing	
ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While reviewing a high-value system, a branch internet edge shows the following pattern: sequential connection attempts target branch public addresses and network services that are not normally accessed from the internet. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate limited connection attempts from the security test range to a branch lab firewall. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0058 T1593 Search Open Websites and Domains - Crawler masquerading as normal traffic	
ATT&CK mapping	TA0043 Reconnaissance -> T1593 Search Open Websites and Domains Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a user or application anomaly, a customer web application shows the following pattern: an automated client imitates a browser while systematically enumerating files, parameters and hidden routes. A realistic enterprise example is that a realistic intrusion may begin with several days of low-volume profiling before the same infrastructure attempts authentication or delivers a lure. This maps to T1593 because the core observable is the adversary mines public websites, code repositories, social platforms and documents for operationally useful information. The mapping describes behavior and

	evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining external observation enriched with internal activity across Threat intelligence; DLP; code-repository audit; web publishing review. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary public research and search-engine activity.. Confirm the source ownership, first-seen time, targeted assets, requested paths or services, rate pattern, relationship to known scanners, and whether authentication or delivery activity followed. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved crawler with an identifying test header against a cloned web application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Search Open Websites and Domains without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

2. TA0042 - Resource Development

This chapter contains 58 practical mappings across 6 priority techniques. In practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

2.1 T1583 - Acquire Infrastructure (10 mappings: MAP-0059-MAP-0068)

Behavior focus: Domains, servers, cloud tenants, email services or certificates are acquired to support future operations. Primary analytic: External observation enriched with internal activity. Core telemetry: Passive DNS; certificate transparency; threat intelligence; brand monitoring.

MAP-0059 T1583 Acquire Infrastructure - Lookalike domain preparation	
ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, external brand-monitoring telemetry shows the following pattern: a newly registered domain resembles the organisation and begins hosting login-themed content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, register no domain; instead inject a synthetic domain observation into the threat-intelligence test feed. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0060 T1583 Acquire Infrastructure - Cloud VPS staging infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, threat-intelligence and network telemetry shows the following pattern: a newly observed virtual private server is associated with short-lived domains and later contacts internal assets. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a reserved test IP and synthetic enrichment record to validate correlation without deploying attacker infrastructure. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0061 T1583 Acquire Infrastructure - Impersonation account establishment	
ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, public social and collaboration services shows the following pattern: a new account

	adopts employee or brand identity elements and begins contacting staff. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a clearly labelled internal awareness-test account approved by communications and security. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0062 T1583 Acquire Infrastructure - Compromised supplier mailbox preparation	
ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, supplier email communications shows the following pattern: a normally trusted mailbox changes sending patterns, infrastructure or conversation style before delivering unusual content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a benign test message from a dedicated supplier simulation mailbox with agreed headers. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0063 T1583 Acquire Infrastructure - Malicious capability preparation pattern	
ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, code repository and file-intelligence monitoring shows the following pattern: a tool or document with suspicious capabilities is staged before any direct interaction with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, submit an inert sample containing only safe marker strings to the internal analysis pipeline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0064 T1583 Acquire Infrastructure - Redirect and tracking infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, email and web telemetry shows the following pattern: new redirectors, URL shorteners and tracking pages are chained to obscure the final destination. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved

	workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, build a harmless internal redirect chain that terminates on a training page and uses no external collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0065 | T1583 Acquire Infrastructure - Certificate acquisition for deceptive services

ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, certificate and domain monitoring shows the following pattern: a new certificate is issued for a confusingly similar hostname shortly before campaign activity. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a synthetic certificate event in the test data stream rather than requesting a real public certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0066 | T1583 Acquire Infrastructure - Credential dataset acquisition indicator

ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, credential-exposure intelligence shows the following pattern: a dataset containing corporate identity strings appears in an approved intelligence source. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load synthetic usernames and fake hashes into an isolated test feed; never use real credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0067 | T1583 Acquire Infrastructure - Compromised web server used for staging

ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, external web and threat-intelligence monitoring shows the following pattern: a legitimate but unrelated server begins hosting lure files or redirect content associated with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, host a harmless text file on an internal test server and simulate the external reputation event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0068 T1583 Acquire Infrastructure - Remote administration account preparation	
ATT&CK mapping	TA0042 Resource Development -> T1583 Acquire Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a third-party service platform shows the following pattern: an account is created or repurposed before unusual remote access activity begins. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1583 because the core observable is domains, servers, cloud tenants, email services or certificates are acquired to support future operations. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Passive DNS; certificate transparency; threat intelligence; brand monitoring. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new legitimate suppliers, marketing domains and unrelated infrastructure. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited test account in a lab tenant with no production access and verify account-lifecycle telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Acquire Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

2.2 T1584 - Compromise Infrastructure (10 mappings: MAP-0069-MAP-0078)

Behavior focus: Existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. Primary analytic: External observation enriched with internal activity. Core telemetry: Threat intelligence; passive DNS; web reputation; abuse feeds.

MAP-0069 T1584 Compromise Infrastructure - Lookalike domain preparation	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, external brand-monitoring telemetry shows the following pattern: a newly registered domain resembles the organisation and begins hosting login-themed content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, register no domain; instead inject a synthetic domain observation into the threat-intelligence test feed. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0070 T1584 Compromise Infrastructure - Cloud VPS staging infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, threat-intelligence and network telemetry shows the following pattern: a newly observed virtual private server is associated with short-lived domains and later contacts internal assets. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a reserved test IP and synthetic enrichment record to validate correlation without deploying attacker infrastructure. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot

	be reversed.
--	--------------

MAP-0071 T1584 Compromise Infrastructure - Impersonation account establishment	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, public social and collaboration services shows the following pattern: a new account adopts employee or brand identity elements and begins contacting staff. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a clearly labelled internal awareness-test account approved by communications and security. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0072 T1584 Compromise Infrastructure - Compromised supplier mailbox preparation	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, supplier email communications shows the following pattern: a normally trusted mailbox changes sending patterns, infrastructure or conversation style before delivering unusual content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a benign test message from a dedicated supplier simulation mailbox with agreed headers. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0073 T1584 Compromise Infrastructure - Malicious capability preparation pattern	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, code repository and file-intelligence monitoring shows the following pattern: a tool or document with suspicious capabilities is staged before any direct interaction with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, submit an inert sample containing only safe marker strings to the internal analysis pipeline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0074 T1584 Compromise Infrastructure - Redirect and tracking infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, email and web telemetry shows the following pattern: new redirectors, URL shorteners and tracking pages are chained to obscure the final destination. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier

	channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, build a harmless internal redirect chain that terminates on a training page and uses no external collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0075 T1584 Compromise Infrastructure - Certificate acquisition for deceptive services	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, certificate and domain monitoring shows the following pattern: a new certificate is issued for a confusingly similar hostname shortly before campaign activity. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a synthetic certificate event in the test data stream rather than requesting a real public certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0076 T1584 Compromise Infrastructure - Credential dataset acquisition indicator	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, credential-exposure intelligence shows the following pattern: a dataset containing corporate identity strings appears in an approved intelligence source. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load synthetic usernames and fake hashes into an isolated test feed; never use real credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0077 T1584 Compromise Infrastructure - Compromised web server used for staging	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, external web and threat-intelligence monitoring shows the following pattern: a legitimate but unrelated server begins hosting lure files or redirect content associated with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless text file on an internal test server and simulate the external reputation event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0078 T1584 Compromise Infrastructure - Remote administration account preparation	
ATT&CK mapping	TA0042 Resource Development -> T1584 Compromise Infrastructure Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a third-party service platform shows the following pattern: an account is created or repurposed before unusual remote access activity begins. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1584 because the core observable is existing websites, servers, routers or accounts are taken over and reused to hide attacker ownership. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Threat intelligence; passive DNS; web reputation; abuse feeds. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include shared hosting compromises and transient reputation errors. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited test account in a lab tenant with no production access and verify account-lifecycle telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Infrastructure without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

2.3 T1585 - Establish Accounts (10 mappings: MAP-0079-MAP-0088)

Behavior focus: The adversary creates email, social, cloud or application accounts that can support impersonation and delivery. Primary analytic: High-impact change with actor and authentication context. Core telemetry: Identity protection; email security; brand monitoring; cloud audit.

MAP-0079 T1585 Establish Accounts - Lookalike domain preparation	
ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, external brand-monitoring telemetry shows the following pattern: a newly registered domain resembles the organisation and begins hosting login-themed content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, register no domain; instead inject a synthetic domain observation into the threat-intelligence test feed. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0080 T1585 Establish Accounts - Cloud VPS staging infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, threat-intelligence and network telemetry shows the following pattern: a newly observed virtual private server is associated with short-lived domains and later contacts internal assets. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use a reserved test IP and synthetic enrichment record to validate correlation without deploying attacker infrastructure. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0081 | T1585 Establish Accounts - Impersonation account establishment

ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, public social and collaboration services shows the following pattern: a new account adopts employee or brand identity elements and begins contacting staff. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a clearly labelled internal awareness-test account approved by communications and security. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0082 | T1585 Establish Accounts - Compromised supplier mailbox preparation

ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, supplier email communications shows the following pattern: a normally trusted mailbox changes sending patterns, infrastructure or conversation style before delivering unusual content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a benign test message from a dedicated supplier simulation mailbox with agreed headers. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0083 | T1585 Establish Accounts - Malicious capability preparation pattern

ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, code repository and file-intelligence monitoring shows the following pattern: a tool or document with suspicious capabilities is staged before any direct interaction with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, submit an inert sample containing only safe marker strings to the internal analysis pipeline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0084 | T1585 Establish Accounts - Redirect and tracking infrastructure

ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, email and web telemetry shows the following pattern: new redirectors, URL shorteners and tracking pages are chained to obscure the final destination. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, build a harmless internal redirect chain that terminates on a training page and uses no external collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0085 T1585 Establish Accounts - Certificate acquisition for deceptive services	
ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, certificate and domain monitoring shows the following pattern: a new certificate is issued for a confusingly similar hostname shortly before campaign activity. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a synthetic certificate event in the test data stream rather than requesting a real public certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0086 T1585 Establish Accounts - Credential dataset acquisition indicator	
ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, credential-exposure intelligence shows the following pattern: a dataset containing corporate identity strings appears in an approved intelligence source. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load synthetic usernames and fake hashes into an isolated test feed; never use real credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0087 T1585 Establish Accounts - Compromised web server used for staging	
ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, external web and threat-intelligence monitoring shows the following pattern: a legitimate but unrelated server begins hosting lure files or redirect content associated with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless text file on an internal test server and simulate the external reputation event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0088 T1585 Establish Accounts - Remote administration account preparation	
ATT&CK mapping	TA0042 Resource Development -> T1585 Establish Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a third-party service platform shows the following pattern: an account is created or repurposed before unusual remote access activity begins. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1585 because the core observable is the adversary creates email, social, cloud or application accounts that can support impersonation and delivery. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across Identity protection; email security; brand monitoring; cloud audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new business accounts and vendor onboarding.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited test account in a lab tenant with no production access and verify account-lifecycle telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Establish Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

2.4 T1586 - Compromise Accounts (10 mappings: MAP-0089-MAP-0098)

Behavior focus: Legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. Primary analytic: High-impact change with actor and authentication context. Core telemetry: Identity provider; email security; threat intelligence; SaaS audit.

MAP-0089 T1586 Compromise Accounts - Lookalike domain preparation	
ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, external brand-monitoring telemetry shows the following pattern: a newly registered domain resembles the organisation and begins hosting login-themed content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, register no domain; instead inject a synthetic domain observation into the threat-intelligence test feed. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0090 T1586 Compromise Accounts - Cloud VPS staging infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, threat-intelligence and network telemetry shows the following pattern: a newly observed virtual private server is associated with short-lived domains and later contacts internal assets. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a reserved test IP and synthetic enrichment record to validate correlation without deploying attacker infrastructure. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0091 | T1586 Compromise Accounts - Impersonation account establishment

ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, public social and collaboration services shows the following pattern: a new account adopts employee or brand identity elements and begins contacting staff. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a clearly labelled internal awareness-test account approved by communications and security. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0092 | T1586 Compromise Accounts - Compromised supplier mailbox preparation

ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, supplier email communications shows the following pattern: a normally trusted mailbox changes sending patterns, infrastructure or conversation style before delivering unusual content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a benign test message from a dedicated supplier simulation mailbox with agreed headers. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0093 | T1586 Compromise Accounts - Malicious capability preparation pattern

ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, code repository and file-intelligence monitoring shows the following pattern: a tool or document with suspicious capabilities is staged before any direct interaction with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, submit an inert sample containing only safe marker strings to the internal analysis pipeline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts

	without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0094 T1586 Compromise Accounts - Redirect and tracking infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, email and web telemetry shows the following pattern: new redirectors, URL shorteners and tracking pages are chained to obscure the final destination. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, build a harmless internal redirect chain that terminates on a training page and uses no external collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0095 T1586 Compromise Accounts - Certificate acquisition for deceptive services	
ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, certificate and domain monitoring shows the following pattern: a new certificate is issued for a confusingly similar hostname shortly before campaign activity. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a synthetic certificate event in the test data stream rather than requesting a real public certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0096 T1586 Compromise Accounts - Credential dataset acquisition indicator	
ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, credential-exposure intelligence shows the following pattern: a dataset containing corporate identity strings appears in an approved intelligence source. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load synthetic usernames and fake hashes into an isolated test feed; never use real credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0097 T1586 Compromise Accounts - Compromised web server used for staging	
ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, external web and threat-intelligence monitoring shows the following pattern: a legitimate but unrelated server begins hosting lure files or redirect content associated with the

	organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless text file on an internal test server and simulate the external reputation event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0098 | T1586 Compromise Accounts - Remote administration account preparation

ATT&CK mapping	TA0042 Resource Development -> T1586 Compromise Accounts Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a third-party service platform shows the following pattern: an account is created or repurposed before unusual remote access activity begins. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1586 because the core observable is legitimate external accounts are hijacked and later used for phishing, access or infrastructure control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across Identity provider; email security; threat intelligence; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include travel, shared administration and legitimate account recovery.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited test account in a lab tenant with no production access and verify account-lifecycle telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Compromise Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

2.5 T1587 - Develop Capabilities (9 mappings: MAP-0099-MAP-0107)

Behavior focus: Malware, exploits, certificates or delivery tooling are created or customized for a campaign. Primary analytic: External observation enriched with internal activity. Core telemetry: Malware intelligence; sandbox; code-signing telemetry; threat intelligence.

MAP-0099 | T1587 Develop Capabilities - Lookalike domain preparation

ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, external brand-monitoring telemetry shows the following pattern: a newly registered domain resembles the organisation and begins hosting login-themed content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, register no domain; instead inject a synthetic domain observation into the threat-intelligence test feed. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0100 | T1587 Develop Capabilities - Cloud VPS staging infrastructure

ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, threat-intelligence and network telemetry shows the following pattern: a newly observed virtual private server is associated with short-lived domains and later contacts internal assets. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Build a correlation that external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a reserved test IP and synthetic enrichment record to validate correlation without deploying attacker infrastructure. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0101 T1587 Develop Capabilities - Impersonation account establishment	
ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, public social and collaboration services shows the following pattern: a new account adopts employee or brand identity elements and begins contacting staff. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a clearly labelled internal awareness-test account approved by communications and security. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0102 T1587 Develop Capabilities - Compromised supplier mailbox preparation	
ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, supplier email communications shows the following pattern: a normally trusted mailbox changes sending patterns, infrastructure or conversation style before delivering unusual content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a benign test message from a dedicated supplier simulation mailbox with agreed headers. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0103 T1587 Develop Capabilities - Malicious capability preparation pattern	
ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, code repository and file-intelligence monitoring shows the following pattern: a tool or document with suspicious capabilities is staged before any direct interaction with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history,

	relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, submit an inert sample containing only safe marker strings to the internal analysis pipeline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0104 | T1587 Develop Capabilities - Redirect and tracking infrastructure

ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, email and web telemetry shows the following pattern: new redirectors, URL shorteners and tracking pages are chained to obscure the final destination. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, build a harmless internal redirect chain that terminates on a training page and uses no external collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0105 | T1587 Develop Capabilities - Certificate acquisition for deceptive services

ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, certificate and domain monitoring shows the following pattern: a new certificate is issued for a confusingly similar hostname shortly before campaign activity. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a synthetic certificate event in the test data stream rather than requesting a real public certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0106 | T1587 Develop Capabilities - Credential dataset acquisition indicator

ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, credential-exposure intelligence shows the following pattern: a dataset containing corporate identity strings appears in an approved intelligence source. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load synthetic usernames and fake hashes into an isolated test feed; never use real credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0107 T1587 Develop Capabilities - Compromised web server used for staging	
ATT&CK mapping	TA0042 Resource Development -> T1587 Develop Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, external web and threat-intelligence monitoring shows the following pattern: a legitimate but unrelated server begins hosting lure files or redirect content associated with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1587 because the core observable is malware, exploits, certificates or delivery tooling are created or customized for a campaign. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to external observation enriched with internal activity across Malware intelligence; sandbox; code-signing telemetry; threat intelligence. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include internal software development and security testing.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless text file on an internal test server and simulate the external reputation event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Develop Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

2.6 T1588 - Obtain Capabilities (9 mappings: MAP-0108-MAP-0116)

Behavior focus: The adversary buys, downloads or steals malware, exploits, certificates, credentials or information. Primary analytic: External observation enriched with internal activity. Core telemetry: Threat intelligence; dark-web monitoring; malware repositories; identity protection.

MAP-0108 T1588 Obtain Capabilities - Lookalike domain preparation	
ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After threat-intelligence enrichment, external brand-monitoring telemetry shows the following pattern: a newly registered domain resembles the organisation and begins hosting login-themed content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, register no domain; instead inject a synthetic domain observation into the threat-intelligence test feed. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0109 T1588 Obtain Capabilities - Cloud VPS staging infrastructure	
ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, threat-intelligence and network telemetry shows the following pattern: a newly observed virtual private server is associated with short-lived domains and later contacts internal assets. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a reserved test IP and synthetic enrichment record to validate correlation without deploying attacker infrastructure. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0110 T1588 Obtain Capabilities - Impersonation account establishment	
ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During an analyst-led hunt, public social and collaboration services shows the following pattern: a new account adopts

	employee or brand identity elements and begins contacting staff. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a clearly labelled internal awareness-test account approved by communications and security. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0111 | T1588 Obtain Capabilities - Compromised supplier mailbox preparation

ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While reviewing a high-value system, supplier email communications shows the following pattern: a normally trusted mailbox changes sending patterns, infrastructure or conversation style before delivering unusual content. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send a benign test message from a dedicated supplier simulation mailbox with agreed headers. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0112 | T1588 Obtain Capabilities - Malicious capability preparation pattern

ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a user or application anomaly, code repository and file-intelligence monitoring shows the following pattern: a tool or document with suspicious capabilities is staged before any direct interaction with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, submit an inert sample containing only safe marker strings to the internal analysis pipeline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0113 | T1588 Obtain Capabilities - Redirect and tracking infrastructure

ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After threat-intelligence enrichment, email and web telemetry shows the following pattern: new redirectors, URL shorteners and tracking pages are chained to obscure the final destination. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The

	alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, build a harmless internal redirect chain that terminates on a training page and uses no external collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0114 T1588 Obtain Capabilities - Certificate acquisition for deceptive services	
ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, certificate and domain monitoring shows the following pattern: a new certificate is issued for a confusingly similar hostname shortly before campaign activity. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a synthetic certificate event in the test data stream rather than requesting a real public certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0115 T1588 Obtain Capabilities - Credential dataset acquisition indicator	
ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During an analyst-led hunt, credential-exposure intelligence shows the following pattern: a dataset containing corporate identity strings appears in an approved intelligence source. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load synthetic usernames and fake hashes into an isolated test feed; never use real credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0116 T1588 Obtain Capabilities - Compromised web server used for staging	
ATT&CK mapping	TA0042 Resource Development -> T1588 Obtain Capabilities Severity: Medium Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While reviewing a high-value system, external web and threat-intelligence monitoring shows the following pattern: a legitimate but unrelated server begins hosting lure files or redirect content associated with the organisation. A realistic enterprise example is that in practice, defenders often first see a lookalike domain, new cloud host, impersonation account or compromised supplier channel before direct contact with internal systems. This maps to T1588 because the core observable is the adversary buys, downloads or steals malware, exploits, certificates, credentials or information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to external observation enriched with internal activity across Threat intelligence; dark-web monitoring; malware repositories; identity protection. Preserve and enrich indicator or observation, source, confidence, first and last seen, expiry, ownership and internal matches. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate research and commercial security tooling.. Validate the infrastructure or account age, ownership, reputation, certificate and DNS history, relationship to the organisation, and any later delivery, authentication or network contact. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless text file on an internal test server and simulate the external reputation event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and

synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obtain Capabilities without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

3. TA0001 - Initial Access

This chapter contains 67 practical mappings across 7 priority techniques. A common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

3.1 T1566 - Phishing (10 mappings: MAP-0117-MAP-0126)

Behavior focus: A malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. Primary analytic: Delivery-to-interaction sequence correlation. Core telemetry: Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider.

MAP-0117 T1566 Phishing - Suspicious attachment delivered to Finance	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the corporate email environment shows the following pattern: a message from an unusual sender delivers an attachment or link that does not match the business conversation. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send an inert awareness-test attachment to designated test mailboxes with no executable content. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0118 T1566 Phishing - Exploit-like requests against a public application	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application shows the following pattern: requests contain abnormal parameters, traversal patterns or repeated server errors before a new session is established. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a web testing tool in non-destructive mode against a cloned test application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0119 T1566 Phishing - Unusual successful VPN authentication	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the remote-access service shows the following pattern: a valid account signs in from a new geography, device or network after preceding failures. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use a test identity from an approved alternate network and immediately revoke the test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0120 T1566 Phishing - Legacy remote service access	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a server remote-management interface shows the following pattern: a valid account accesses a rarely used external service outside the normal support workflow. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect to a lab service with a test account during a documented validation window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0121 T1566 Phishing - Watering-hole style redirection	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, employee web browsing shows the following pattern: a user visits a normally trusted site and is redirected through an unusual chain before a download or authentication prompt. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal training page that redirects only to another internal page and records no personal data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0122 T1566 Phishing - Trusted supplier channel abuse	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a third-party integration shows the following pattern: access originates through a trusted relationship but differs from the supplier baseline in time, account or resource target. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, coordinate a supplier test session using a segregated account and non-production resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0123 T1566 Phishing - Removable media introduction	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources

Scenario and rationale	While comparing activity with the 30-day baseline, a controlled endpoint segment shows the following pattern: new removable media is mounted and followed by file execution or propagation-related activity. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attach approved blank test media containing only inert marker files to a lab workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0124 T1566 Phishing - Cloud application consent entry	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the enterprise identity tenant shows the following pattern: a user grants unusual permissions to a newly observed application shortly before mailbox or file access. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, grant minimal, non-sensitive permissions to an approved test application and remove them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0125 T1566 Phishing - Password spraying followed by success	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity provider shows the following pattern: many accounts receive low-volume failures and one later authenticates from the same infrastructure. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic authentication events or use locked test accounts within platform rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0126 T1566 Phishing - Shortcut or document lure delivery	
ATT&CK mapping	TA0001 Initial Access -> T1566 Phishing Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, email and collaboration messaging shows the following pattern: a user receives a file that appears to be a business document but invokes an unexpected execution path. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1566 because the core observable is a malicious link, attachment, service message or social-engineering lure is delivered to induce interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when delivery-to-interaction sequence correlation across Email gateway; sandbox; URL defense; mailbox audit; EDR; identity provider. Preserve and enrich message identifier, sender, authentication, recipients, URL or attachment, delivery and interaction. Raise confidence when the activity is new for the entity, occurs outside an approved

	workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include bulk mail, newsletters, file-sharing notifications and security simulations.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deliver an inert shortcut or document that opens a training page and performs no command execution. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Phishing without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

3.2 T1190 - Exploit Public-Facing Application (10 mappings: MAP-0127-MAP-0136)

Behavior focus: A weakness in an internet-facing application, appliance or API is exploited to gain execution or access. Primary analytic: Suspicious request followed by server-side consequence. Core telemetry: WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy.

MAP-0127 T1190 Exploit Public-Facing Application - Suspicious attachment delivered to Finance	
ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the corporate email environment shows the following pattern: a message from an unusual sender delivers an attachment or link that does not match the business conversation. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send an inert awareness-test attachment to designated test mailboxes with no executable content. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0128 T1190 Exploit Public-Facing Application - Exploit-like requests against a public application	
ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application shows the following pattern: requests contain abnormal parameters, traversal patterns or repeated server errors before a new session is established. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a web testing tool in non-destructive mode against a cloned test application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0129 T1190 Exploit Public-Facing Application - Unusual successful VPN authentication	
ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the remote-access service shows the following pattern: a valid account signs in from a new geography, device or network after preceding failures. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned

	behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test identity from an approved alternate network and immediately revoke the test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0130 | T1190 Exploit Public-Facing Application - Legacy remote service access

ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a server remote-management interface shows the following pattern: a valid account accesses a rarely used external service outside the normal support workflow. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect to a lab service with a test account during a documented validation window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0131 | T1190 Exploit Public-Facing Application - Watering-hole style redirection

ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, employee web browsing shows the following pattern: a user visits a normally trusted site and is redirected through an unusual chain before a download or authentication prompt. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal training page that redirects only to another internal page and records no personal data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0132 | T1190 Exploit Public-Facing Application - Trusted supplier channel abuse

ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a third-party integration shows the following pattern: access originates through a trusted relationship but differs from the supplier baseline in time, account or resource target. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

	future changes.
Safe validation	In an isolated or non-production environment, coordinate a supplier test session using a segregated account and non-production resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0133 | T1190 Exploit Public-Facing Application - Removable media introduction

ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a controlled endpoint segment shows the following pattern: new removable media is mounted and followed by file execution or propagation-related activity. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attach approved blank test media containing only inert marker files to a lab workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0134 | T1190 Exploit Public-Facing Application - Cloud application consent entry

ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the enterprise identity tenant shows the following pattern: a user grants unusual permissions to a newly observed application shortly before mailbox or file access. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, grant minimal, non-sensitive permissions to an approved test application and remove them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0135 | T1190 Exploit Public-Facing Application - Password spraying followed by success

ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity provider shows the following pattern: many accounts receive low-volume failures and one later authenticates from the same infrastructure. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic authentication events or use locked test accounts within platform rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing

	Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0136 T1190 Exploit Public-Facing Application - Shortcut or document lure delivery	
ATT&CK mapping	TA0001 Initial Access -> T1190 Exploit Public-Facing Application Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, email and collaboration messaging shows the following pattern: a user receives a file that appears to be a business document but invokes an unexpected execution path. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1190 because the core observable is a weakness in an internet-facing application, appliance or API is exploited to gain execution or access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when suspicious request followed by server-side consequence across WAF; application logs; EDR; IDS/IPS; vulnerability management; reverse proxy. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated scanning, error conditions and approved testing. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deliver an inert shortcut or document that opens a training page and performs no command execution. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploit Public-Facing Application without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

3.3 T1133 - External Remote Services (10 mappings: MAP-0137-MAP-0146)

Behavior focus: VPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. Primary analytic: Breadth or sequence correlation across authentication events. Core telemetry: VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment.

MAP-0137 T1133 External Remote Services - Suspicious attachment delivered to Finance	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the corporate email environment shows the following pattern: a message from an unusual sender delivers an attachment or link that does not match the business conversation. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send an inert awareness-test attachment to designated test mailboxes with no executable content. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0138 T1133 External Remote Services - Exploit-like requests against a public application	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application shows the following pattern: requests contain abnormal parameters, traversal patterns or repeated server errors before a new session is established. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a web testing tool in non-destructive mode against a cloned test application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0139 T1133 External Remote Services - Unusual successful VPN authentication	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the remote-access service shows the following pattern: a valid account signs in from a new geography, device or network after preceding failures. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test identity from an approved alternate network and immediately revoke the test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0140 T1133 External Remote Services - Legacy remote service access	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a server remote-management interface shows the following pattern: a valid account accesses a rarely used external service outside the normal support workflow. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect to a lab service with a test account during a documented validation window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0141 T1133 External Remote Services - Watering-hole style redirection	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, employee web browsing shows the following pattern: a user visits a normally trusted site and is redirected through an unusual chain before a download or authentication prompt. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal training page that redirects only to another internal page and records no personal data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0142 T1133 External Remote Services - Trusted supplier channel abuse	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a third-party integration shows the following pattern: access originates through a

	trusted relationship but differs from the supplier baseline in time, account or resource target. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, coordinate a supplier test session using a segregated account and non-production resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0143 T1133 External Remote Services - Removable media introduction	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a controlled endpoint segment shows the following pattern: new removable media is mounted and followed by file execution or propagation-related activity. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attach approved blank test media containing only inert marker files to a lab workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0144 T1133 External Remote Services - Cloud application consent entry	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the enterprise identity tenant shows the following pattern: a user grants unusual permissions to a newly observed application shortly before mailbox or file access. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, grant minimal, non-sensitive permissions to an approved test application and remove them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0145 T1133 External Remote Services - Password spraying followed by success	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity provider shows the following pattern: many accounts receive low-volume failures and one later authenticates from the same infrastructure. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Use a sequence-based rule that breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic authentication events or use locked test accounts within platform rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0146 T1133 External Remote Services - Shortcut or document lure delivery	
ATT&CK mapping	TA0001 Initial Access -> T1133 External Remote Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, email and collaboration messaging shows the following pattern: a user receives a file that appears to be a business document but invokes an unexpected execution path. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1133 because the core observable is vPN, RDP gateway, VDI, SSH or other exposed remote access is used to enter the environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across VPN; identity provider; firewall; PAM; endpoint; geolocation enrichment. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include remote work, vendor support and disaster-recovery exercises.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deliver an inert shortcut or document that opens a training page and performs no command execution. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify External Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

3.4 T1078 - Valid Accounts (10 mappings: MAP-0147-MAP-0156)

Behavior focus: A legitimate local, domain, cloud or application account is used to bypass initial security barriers. Primary analytic: Breadth or sequence correlation across authentication events. Core telemetry: Identity provider; AD; VPN; SaaS audit; EDR; UEBA.

MAP-0147 T1078 Valid Accounts - Suspicious attachment delivered to Finance	
ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the corporate email environment shows the following pattern: a message from an unusual sender delivers an attachment or link that does not match the business conversation. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send an inert awareness-test attachment to designated test mailboxes with no executable content. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0148 T1078 Valid Accounts - Exploit-like requests against a public application	
ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application shows the following pattern: requests contain abnormal parameters, traversal patterns or repeated server errors before a new session is established. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application,

	session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a web testing tool in non-destructive mode against a cloned test application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0149 T1078 Valid Accounts - Unusual successful VPN authentication	
ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the remote-access service shows the following pattern: a valid account signs in from a new geography, device or network after preceding failures. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test identity from an approved alternate network and immediately revoke the test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0150 T1078 Valid Accounts - Legacy remote service access	
ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a server remote-management interface shows the following pattern: a valid account accesses a rarely used external service outside the normal support workflow. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect to a lab service with a test account during a documented validation window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0151 T1078 Valid Accounts - Watering-hole style redirection	
ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, employee web browsing shows the following pattern: a user visits a normally trusted site and is redirected through an unusual chain before a download or authentication prompt. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts.. Establish whether access actually succeeded, identify the affected identity and

	asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal training page that redirects only to another internal page and records no personal data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0152 | T1078 Valid Accounts - Trusted supplier channel abuse

ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a third-party integration shows the following pattern: access originates through a trusted relationship but differs from the supplier baseline in time, account or resource target. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, coordinate a supplier test session using a segregated account and non-production resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0153 | T1078 Valid Accounts - Removable media introduction

ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a controlled endpoint segment shows the following pattern: new removable media is mounted and followed by file execution or propagation-related activity. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attach approved blank test media containing only inert marker files to a lab workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0154 | T1078 Valid Accounts - Cloud application consent entry

ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the enterprise identity tenant shows the following pattern: a user grants unusual permissions to a newly observed application shortly before mailbox or file access. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, grant minimal, non-sensitive permissions to an approved test application and remove them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts

	without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0155 T1078 Valid Accounts - Password spraying followed by success	
ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity provider shows the following pattern: many accounts receive low-volume failures and one later authenticates from the same infrastructure. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic authentication events or use locked test accounts within platform rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0156 T1078 Valid Accounts - Shortcut or document lure delivery	
ATT&CK mapping	TA0001 Initial Access -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, email and collaboration messaging shows the following pattern: a user receives a file that appears to be a business document but invokes an unexpected execution path. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1078 because the core observable is a legitimate local, domain, cloud or application account is used to bypass initial security barriers. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; EDR; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user activity, service accounts and shared operations accounts. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deliver an inert shortcut or document that opens a training page and performs no command execution. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

3.5 T1189 - Drive-by Compromise (9 mappings: MAP-0157-MAP-0165)

Behavior focus: A user visits a compromised or malicious website that triggers redirection, exploitation or download. Primary analytic: Suspicious request followed by server-side consequence. Core telemetry: Secure web gateway; browser telemetry; DNS; EDR; sandbox.

MAP-0157 T1189 Drive-by Compromise - Suspicious attachment delivered to Finance	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the corporate email environment shows the following pattern: a message from an unusual sender delivers an attachment or link that does not match the business conversation. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send an inert awareness-test attachment to designated test mailboxes with no executable content. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0158 T1189 Drive-by Compromise - Exploit-like requests against a public application	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application shows the following pattern: requests contain abnormal parameters, traversal patterns or repeated server errors before a new session is established. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a web testing tool in non-destructive mode against a cloned test application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0159 T1189 Drive-by Compromise - Unusual successful VPN authentication	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the remote-access service shows the following pattern: a valid account signs in from a new geography, device or network after preceding failures. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test identity from an approved alternate network and immediately revoke the test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0160 T1189 Drive-by Compromise - Legacy remote service access	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a server remote-management interface shows the following pattern: a valid account accesses a rarely used external service outside the normal support workflow. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect to a lab service with a test account during a documented validation window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0161 T1189 Drive-by Compromise - Watering-hole style redirection	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, employee web browsing shows the following pattern: a user

	visits a normally trusted site and is redirected through an unusual chain before a download or authentication prompt. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal training page that redirects only to another internal page and records no personal data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0162 T1189 Drive-by Compromise - Trusted supplier channel abuse	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a third-party integration shows the following pattern: access originates through a trusted relationship but differs from the supplier baseline in time, account or resource target. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, coordinate a supplier test session using a segregated account and non-production resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0163 T1189 Drive-by Compromise - Removable media introduction	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a controlled endpoint segment shows the following pattern: new removable media is mounted and followed by file execution or propagation-related activity. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attach approved blank test media containing only inert marker files to a lab workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0164 T1189 Drive-by Compromise - Cloud application consent entry	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the enterprise identity tenant shows the following pattern: a user grants unusual permissions to a newly observed application shortly before mailbox or file access. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to suspicious request followed by server-side consequence across Secure web

	gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, grant minimal, non-sensitive permissions to an approved test application and remove them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0165 T1189 Drive-by Compromise - Password spraying followed by success	
ATT&CK mapping	TA0001 Initial Access -> T1189 Drive-by Compromise Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity provider shows the following pattern: many accounts receive low-volume failures and one later authenticates from the same infrastructure. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1189 because the core observable is a user visits a compromised or malicious website that triggers redirection, exploitation or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that suspicious request followed by server-side consequence across Secure web gateway; browser telemetry; DNS; EDR; sandbox. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include advertising networks, benign redirects and browser extensions.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic authentication events or use locked test accounts within platform rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Drive-by Compromise without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

3.6 T1199 - Trusted Relationship (9 mappings: MAP-0166-MAP-0174)

Behavior focus: A supplier, partner, service provider or connected environment is abused to reach the target. Primary analytic: High-impact change with actor and authentication context. Core telemetry: Third-party access logs; VPN; identity provider; PAM; network segmentation.

MAP-0166 T1199 Trusted Relationship - Suspicious attachment delivered to Finance	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, the corporate email environment shows the following pattern: a message from an unusual sender delivers an attachment or link that does not match the business conversation. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send an inert awareness-test attachment to designated test mailboxes with no executable content. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0167 T1199 Trusted Relationship - Exploit-like requests against a public application	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an internet-facing application shows the following pattern: requests contain abnormal parameters, traversal patterns or repeated server errors before a new session is established. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an

	approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a web testing tool in non-destructive mode against a cloned test application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0168 T1199 Trusted Relationship - Unusual successful VPN authentication	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, the remote-access service shows the following pattern: a valid account signs in from a new geography, device or network after preceding failures. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test identity from an approved alternate network and immediately revoke the test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0169 T1199 Trusted Relationship - Legacy remote service access	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server remote-management interface shows the following pattern: a valid account accesses a rarely used external service outside the normal support workflow. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect to a lab service with a test account during a documented validation window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0170 T1199 Trusted Relationship - Watering-hole style redirection	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, employee web browsing shows the following pattern: a user visits a normally trusted site and is redirected through an unusual chain before a download or authentication prompt. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated

	entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal training page that redirects only to another internal page and records no personal data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0171 T1199 Trusted Relationship - Trusted supplier channel abuse	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a third-party integration shows the following pattern: access originates through a trusted relationship but differs from the supplier baseline in time, account or resource target. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, coordinate a supplier test session using a segregated account and non-production resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0172 T1199 Trusted Relationship - Removable media introduction	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a controlled endpoint segment shows the following pattern: new removable media is mounted and followed by file execution or propagation-related activity. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attach approved blank test media containing only inert marker files to a lab workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0173 T1199 Trusted Relationship - Cloud application consent entry	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, the enterprise identity tenant shows the following pattern: a user grants unusual permissions to a newly observed application shortly before mailbox or file access. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, grant minimal, non-sensitive permissions to an approved test application and remove them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0174 T1199 Trusted Relationship - Password spraying followed by success	
ATT&CK mapping	TA0001 Initial Access -> T1199 Trusted Relationship Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, the identity provider shows the following pattern: many accounts receive low-volume failures and one later authenticates from the same infrastructure. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1199 because the core observable is a supplier, partner, service provider or connected environment is abused to reach the target. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that high-impact change with actor and authentication context across Third-party access logs; VPN; identity provider; PAM; network segmentation. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved managed services and inter-company integration.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic authentication events or use locked test accounts within platform rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Trusted Relationship without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

3.7 T1091 - Replication Through Removable Media (9 mappings: MAP-0175-MAP-0183)

Behavior focus: Malicious content reaches systems through USB or other removable media and may automatically or socially execute. Primary analytic: Device insertion followed by copy or execution. Core telemetry: Device control; EDR; file telemetry; Windows events.

MAP-0175 T1091 Replication Through Removable Media - Suspicious attachment delivered to Finance	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the corporate email environment shows the following pattern: a message from an unusual sender delivers an attachment or link that does not match the business conversation. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send an inert awareness-test attachment to designated test mailboxes with no executable content. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0176 T1091 Replication Through Removable Media - Exploit-like requests against a public application	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an internet-facing application shows the following pattern: requests contain abnormal parameters, traversal patterns or repeated server errors before a new session is established. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a web testing tool in non-destructive mode against a cloned test application. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0177 T1091 Replication Through Removable Media - Unusual successful VPN authentication	
--	--

ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, the remote-access service shows the following pattern: a valid account signs in from a new geography, device or network after preceding failures. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test identity from an approved alternate network and immediately revoke the test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0178 T1091 Replication Through Removable Media - Legacy remote service access	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a server remote-management interface shows the following pattern: a valid account accesses a rarely used external service outside the normal support workflow. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect to a lab service with a test account during a documented validation window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0179 T1091 Replication Through Removable Media - Watering-hole style redirection	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, employee web browsing shows the following pattern: a user visits a normally trusted site and is redirected through an unusual chain before a download or authentication prompt. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal training page that redirects only to another internal page and records no personal data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0180 T1091 Replication Through Removable Media - Trusted supplier channel abuse	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a third-party integration shows the following pattern: access originates through a trusted relationship but differs from the supplier baseline in time, account or resource target. A realistic

	enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, coordinate a supplier test session using a segregated account and non-production resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0181 T1091 Replication Through Removable Media - Removable media introduction	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a controlled endpoint segment shows the following pattern: new removable media is mounted and followed by file execution or propagation-related activity. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attach approved blank test media containing only inert marker files to a lab workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0182 T1091 Replication Through Removable Media - Cloud application consent entry	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, the enterprise identity tenant shows the following pattern: a user grants unusual permissions to a newly observed application shortly before mailbox or file access. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, grant minimal, non-sensitive permissions to an approved test application and remove them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0183 T1091 Replication Through Removable Media - Password spraying followed by success	
ATT&CK mapping	TA0001 Initial Access -> T1091 Replication Through Removable Media Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the identity provider shows the following pattern: many accounts receive low-volume failures and one later authenticates from the same infrastructure. A realistic enterprise example is that a common enterprise case is a user, application or remote service receiving a deceptive message, exploit-like request or valid-account login that creates the first foothold. This maps to T1091 because the core observable is malicious content reaches systems through USB or other removable media and may automatically or socially execute. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Generate a detection when device insertion followed by copy or execution across Device control; EDR; file telemetry; Windows events. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media transfers and offline maintenance.. Establish whether access actually succeeded, identify the affected identity and asset, preserve the original message or request, review authentication and endpoint follow-on activity, and scope other recipients or targets. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic authentication events or use locked test accounts within platform rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

4. TA0002 - Execution

This chapter contains 67 practical mappings across 7 priority techniques. A typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

4.1 T1059 - Command and Scripting Interpreter (10 mappings: MAP-0184-MAP-0193)

Behavior focus: PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry.

MAP-0184 T1059 Command and Scripting Interpreter - Office application spawns an interpreter	
ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a corporate workstation shows the following pattern: a productivity application launches a script or command interpreter inconsistent with the document workflow. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is powerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign signed test document that triggers only a harmless local message in an isolated lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0185 T1059 Command and Scripting Interpreter - Encoded script activity on an endpoint	
ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an analyst test workstation shows the following pattern: a script engine processes obfuscated or encoded content and creates unusual child processes or network activity. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is powerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, execute a harmless encoded string that writes a test marker file, with no download or persistence. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0186 T1059 Command and Scripting Interpreter - Remote process creation through management tooling	
ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources

Scenario and rationale	After threat-intelligence enrichment, a Windows server segment shows the following pattern: management instrumentation creates a process remotely from a host that does not normally administer the target. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use approved administration tooling to start a benign test process on a lab server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0187 | T1059 Command and Scripting Interpreter - Scheduled execution outside change window

ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a critical application server shows the following pattern: a new or modified task launches code at an unusual time or from a user-writable path. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a short-lived lab task that writes an audit marker and then delete it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0188 | T1059 Command and Scripting Interpreter - Service-based execution

ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a service starts a new binary or command with an unusual image path, account or parent relationship. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign temporary test service on an isolated virtual machine and remove it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0189 | T1059 Command and Scripting Interpreter - Native API execution pattern

ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an endpoint protected by EDR shows the following pattern: a process performs execution-related API activity that is uncommon for its signer, role or parent process. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer,

	hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided benign simulation or synthetic EDR event rather than custom injection code. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0190 T1059 Command and Scripting Interpreter - Unexpected shared module loading	
ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a business application host shows the following pattern: a trusted process loads a module from a user-controlled or uncommon directory. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load an approved harmless library in a lab copy of the application from a designated test path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0191 T1059 Command and Scripting Interpreter - Temporary-folder script launch	
ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a user endpoint shows the following pattern: a script or executable starts from a download, temporary or cache location and is followed by system discovery. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an inert script from a temporary lab folder that only records hostname and exits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0192 T1059 Command and Scripting Interpreter - Command chain after interactive login	
ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an administrator workstation shows the following pattern: a sequence of interpreters and utilities appears immediately after an unusual login. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script

	content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test admin account to run a documented series of harmless information commands in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0193 T1059 Command and Scripting Interpreter - Signed utility launches unexpected content	
ATT&CK mapping	TA0002 Execution -> T1059 Command and Scripting Interpreter Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a managed Windows endpoint shows the following pattern: a trusted signed binary becomes the parent of script, network or file activity outside its ordinary use. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1059 because the core observable is PowerShell, cmd, shell, Python, JavaScript or another interpreter executes commands that perform attacker objectives. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; PowerShell; AMSI; auditd; command-line telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, deployment, development and troubleshooting.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-supported benign test case that produces the process relationship without executing a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Command and Scripting Interpreter without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

4.2 T1204 - User Execution (10 mappings: MAP-0194-MAP-0203)

Behavior focus: A user opens, launches or approves malicious content, often after phishing or download. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; email; browser; office audit; file telemetry.

MAP-0194 T1204 User Execution - Office application spawns an interpreter	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a corporate workstation shows the following pattern: a productivity application launches a script or command interpreter inconsistent with the document workflow. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign signed test document that triggers only a harmless local message in an isolated lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0195 T1204 User Execution - Encoded script activity on an endpoint	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an analyst test workstation shows the following pattern: a script engine processes obfuscated or encoded content and creates unusual child processes or network activity. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, execute a harmless encoded string that writes a test marker file, with no

	download or persistence. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0196 T1204 User Execution - Remote process creation through management tooling	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows server segment shows the following pattern: management instrumentation creates a process remotely from a host that does not normally administer the target. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use approved administration tooling to start a benign test process on a lab server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0197 T1204 User Execution - Scheduled execution outside change window	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a critical application server shows the following pattern: a new or modified task launches code at an unusual time or from a user-writable path. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a short-lived lab task that writes an audit marker and then delete it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0198 T1204 User Execution - Service-based execution	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a service starts a new binary or command with an unusual image path, account or parent relationship. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign temporary test service on an isolated virtual machine and remove it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0199 T1204 User Execution - Native API execution pattern	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an endpoint protected by EDR shows the following pattern: a process performs execution-related API activity that is uncommon for its signer, role or parent process. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process

	and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided benign simulation or synthetic EDR event rather than custom injection code. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0200 T1204 User Execution - Unexpected shared module loading	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a business application host shows the following pattern: a trusted process loads a module from a user-controlled or uncommon directory. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load an approved harmless library in a lab copy of the application from a designated test path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0201 T1204 User Execution - Temporary-folder script launch	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a user endpoint shows the following pattern: a script or executable starts from a download, temporary or cache location and is followed by system discovery. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an inert script from a temporary lab folder that only records hostname and exits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0202 T1204 User Execution - Command chain after interactive login	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an administrator workstation shows the following pattern: a sequence of interpreters and utilities appears immediately after an unusual login. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test admin account to run a documented series of harmless information commands in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0203 T1204 User Execution - Signed utility launches unexpected content	
ATT&CK mapping	TA0002 Execution -> T1204 User Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a managed Windows endpoint shows the following pattern: a trusted signed binary becomes the parent of script, network or file activity outside its ordinary use. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1204 because the core observable is a user opens, launches or approves malicious content, often after phishing or download. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; email; browser; office audit; file telemetry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include opening legitimate documents, installers and downloaded tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-supported benign test case that produces the process relationship without executing a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify User Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

4.3 T1047 - Windows Management Instrumentation (10 mappings: MAP-0204-MAP-0213)

Behavior focus: WMI performs local or remote process execution, discovery, persistence or administration. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; Sysmon; WMI activity logs; Windows Security.

MAP-0204 T1047 Windows Management Instrumentation - Office application spawns an interpreter	
ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a corporate workstation shows the following pattern: a productivity application launches a script or command interpreter inconsistent with the document workflow. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is wmi performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign signed test document that triggers only a harmless local message in an isolated lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0205 T1047 Windows Management Instrumentation - Encoded script activity on an endpoint	
ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an analyst test workstation shows the following pattern: a script engine processes obfuscated or encoded content and creates unusual child processes or network activity. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is wmi performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was

	authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, execute a harmless encoded string that writes a test marker file, with no download or persistence. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0206 | T1047 Windows Management Instrumentation - Remote process creation through management tooling

ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows server segment shows the following pattern: management instrumentation creates a process remotely from a host that does not normally administer the target. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is WMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use approved administration tooling to start a benign test process on a lab server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0207 | T1047 Windows Management Instrumentation - Scheduled execution outside change window

ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a critical application server shows the following pattern: a new or modified task launches code at an unusual time or from a user-writable path. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is WMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a short-lived lab task that writes an audit marker and then delete it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0208 | T1047 Windows Management Instrumentation - Service-based execution

ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a service starts a new binary or command with an unusual image path, account or parent relationship. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is WMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign temporary test service on an isolated virtual machine and remove it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or

	restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

MAP-0209 T1047 Windows Management Instrumentation - Native API execution pattern	
ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an endpoint protected by EDR shows the following pattern: a process performs execution-related API activity that is uncommon for its signer, role or parent process. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is WMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided benign simulation or synthetic EDR event rather than custom injection code. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0210 T1047 Windows Management Instrumentation - Unexpected shared module loading	
ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a business application host shows the following pattern: a trusted process loads a module from a user-controlled or uncommon directory. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is WMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load an approved harmless library in a lab copy of the application from a designated test path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0211 T1047 Windows Management Instrumentation - Temporary-folder script launch	
ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a user endpoint shows the following pattern: a script or executable starts from a download, temporary or cache location and is followed by system discovery. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is WMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an inert script from a temporary lab folder that only records hostname and exits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0212 T1047 Windows Management Instrumentation - Command chain after interactive login	
---	--

ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an administrator workstation shows the following pattern: a sequence of interpreters and utilities appears immediately after an unusual login. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is wMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test admin account to run a documented series of harmless information commands in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0213 T1047 Windows Management Instrumentation - Signed utility launches unexpected content	
ATT&CK mapping	TA0002 Execution -> T1047 Windows Management Instrumentation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a managed Windows endpoint shows the following pattern: a trusted signed binary becomes the parent of script, network or file activity outside its ordinary use. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1047 because the core observable is wMI performs local or remote process execution, discovery, persistence or administration. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; WMI activity logs; Windows Security. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management, inventory and endpoint administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-supported benign test case that produces the process relationship without executing a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Windows Management Instrumentation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

4.4 T1053 - Scheduled Task or Job (10 mappings: MAP-0214-MAP-0223)

Behavior focus: A scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. Primary analytic: Configuration change with creator and target-path context. Core telemetry: Task Scheduler; Sysmon; auditd; EDR; cloud audit.

MAP-0214 T1053 Scheduled Task or Job - Office application spawns an interpreter	
ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a corporate workstation shows the following pattern: a productivity application launches a script or command interpreter inconsistent with the document workflow. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign signed test document that triggers only a harmless local message in an isolated lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0215 T1053 Scheduled Task or Job - Encoded script activity on an endpoint	
ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more

	sources
Scenario and rationale	Following a user or application anomaly, an analyst test workstation shows the following pattern: a script engine processes obfuscated or encoded content and creates unusual child processes or network activity. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, execute a harmless encoded string that writes a test marker file, with no download or persistence. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0216 T1053 Scheduled Task or Job - Remote process creation through management tooling	
ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows server segment shows the following pattern: management instrumentation creates a process remotely from a host that does not normally administer the target. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use approved administration tooling to start a benign test process on a lab server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0217 T1053 Scheduled Task or Job - Scheduled execution outside change window	
ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a critical application server shows the following pattern: a new or modified task launches code at an unusual time or from a user-writable path. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a short-lived lab task that writes an audit marker and then delete it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0218 T1053 Scheduled Task or Job - Service-based execution	
ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a service starts a new binary or command with an unusual image path, account or parent relationship. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Apply rarity and temporal logic to configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign temporary test service on an isolated virtual machine and remove it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0219 | T1053 Scheduled Task or Job - Native API execution pattern

ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an endpoint protected by EDR shows the following pattern: a process performs execution-related API activity that is uncommon for its signer, role or parent process. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided benign simulation or synthetic EDR event rather than custom injection code. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0220 | T1053 Scheduled Task or Job - Unexpected shared module loading

ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a business application host shows the following pattern: a trusted process loads a module from a user-controlled or uncommon directory. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load an approved harmless library in a lab copy of the application from a designated test path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0221 | T1053 Scheduled Task or Job - Temporary-folder script launch

ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a user endpoint shows the following pattern: a script or executable starts from a download, temporary or cache location and is followed by system discovery. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup

	jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an inert script from a temporary lab folder that only records hostname and exits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0222 | T1053 Scheduled Task or Job - Command chain after interactive login

ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an administrator workstation shows the following pattern: a sequence of interpreters and utilities appears immediately after an unusual login. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test admin account to run a documented series of harmless information commands in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0223 | T1053 Scheduled Task or Job - Signed utility launches unexpected content

ATT&CK mapping	TA0002 Execution -> T1053 Scheduled Task or Job Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a managed Windows endpoint shows the following pattern: a trusted signed binary becomes the parent of script, network or file activity outside its ordinary use. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1053 because the core observable is a scheduled task, cron job or cloud scheduler executes code at a chosen time or interval. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to configuration change with creator and target-path context across Task Scheduler; Sysmon; auditd; EDR; cloud audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, backup jobs and enterprise automation.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-supported benign test case that produces the process relationship without executing a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Task or Job without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

4.5 T1569 - System Services (9 mappings: MAP-0224-MAP-0232)

Behavior focus: A service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. Primary analytic: Service change with path, account and remote-origin context. Core telemetry: Windows System; Sysmon; EDR; auditd; service manager logs.

MAP-0224 | T1569 System Services - Office application spawns an interpreter

ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a corporate workstation shows the following pattern: a productivity application launches a script or command interpreter inconsistent with the document workflow. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use a benign signed test document that triggers only a harmless local message in an isolated lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0225 T1569 System Services - Encoded script activity on an endpoint	
ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an analyst test workstation shows the following pattern: a script engine processes obfuscated or encoded content and creates unusual child processes or network activity. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, execute a harmless encoded string that writes a test marker file, with no download or persistence. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0226 T1569 System Services - Remote process creation through management tooling	
ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows server segment shows the following pattern: management instrumentation creates a process remotely from a host that does not normally administer the target. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use approved administration tooling to start a benign test process on a lab server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0227 T1569 System Services - Scheduled execution outside change window	
ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a critical application server shows the following pattern: a new or modified task launches code at an unusual time or from a user-writable path. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a short-lived lab task that writes an audit marker and then delete it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0228 T1569 System Services - Service-based execution	
ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a service starts a new binary or command

	with an unusual image path, account or parent relationship. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign temporary test service on an isolated virtual machine and remove it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0229 | T1569 System Services - Native API execution pattern

ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an endpoint protected by EDR shows the following pattern: a process performs execution-related API activity that is uncommon for its signer, role or parent process. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided benign simulation or synthetic EDR event rather than custom injection code. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0230 | T1569 System Services - Unexpected shared module loading

ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a business application host shows the following pattern: a trusted process loads a module from a user-controlled or uncommon directory. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load an approved harmless library in a lab copy of the application from a designated test path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0231 | T1569 System Services - Temporary-folder script launch

ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a user endpoint shows the following pattern: a script or executable starts from a download, temporary or cache location and is followed by system discovery. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an inert script from a temporary lab folder that only records hostname and exits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0232 T1569 System Services - Command chain after interactive login	
ATT&CK mapping	TA0002 Execution -> T1569 System Services Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an administrator workstation shows the following pattern: a sequence of interpreters and utilities appears immediately after an unusual login. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1569 because the core observable is a service manager is used to start code locally or remotely through Windows services, systemd or equivalent mechanisms. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; service manager logs. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, patching and approved administration.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test admin account to run a documented series of harmless information commands in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

4.6 T1106 - Native API (9 mappings: MAP-0233-MAP-0241)

Behavior focus: Low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; API telemetry; Sysmon; memory protection.

MAP-0233 T1106 Native API - Office application spawns an interpreter	
ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a corporate workstation shows the following pattern: a productivity application launches a script or command interpreter inconsistent with the document workflow. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign signed test document that triggers only a harmless local message in an isolated lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0234 T1106 Native API - Encoded script activity on an endpoint	
ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, an analyst test workstation shows the following pattern: a script engine processes obfuscated or encoded content and creates unusual child processes or network activity. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, execute a harmless encoded string that writes a test marker file, with no download or persistence. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0235 T1106 Native API - Remote process creation through management tooling	
ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a Windows server segment shows the following pattern: management instrumentation creates a process remotely from a host that does not normally administer the target. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use approved administration tooling to start a benign test process on a lab server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0236 T1106 Native API - Scheduled execution outside change window	
ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a critical application server shows the following pattern: a new or modified task launches code at an unusual time or from a user-writable path. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a short-lived lab task that writes an audit marker and then delete it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0237 T1106 Native API - Service-based execution	
ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a server operating system shows the following pattern: a service starts a new binary or command with an unusual image path, account or parent relationship. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign temporary test service on an isolated virtual machine and remove it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0238 T1106 Native API - Native API execution pattern	
ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, an endpoint protected by EDR shows the following pattern: a process performs execution-related API activity that is uncommon for its signer, role or parent process. A realistic enterprise example is that a

	typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided benign simulation or synthetic EDR event rather than custom injection code. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0239 | T1106 Native API - Unexpected shared module loading

ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a business application host shows the following pattern: a trusted process loads a module from a user-controlled or uncommon directory. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load an approved harmless library in a lab copy of the application from a designated test path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0240 | T1106 Native API - Temporary-folder script launch

ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a user endpoint shows the following pattern: a script or executable starts from a download, temporary or cache location and is followed by system discovery. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an inert script from a temporary lab folder that only records hostname and exits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0241 | T1106 Native API - Command chain after interactive login

ATT&CK mapping	TA0002 Execution -> T1106 Native API Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an administrator workstation shows the following pattern: a sequence of interpreters and utilities appears immediately after an unusual login. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1106 because the core observable is low-level operating-system APIs are invoked to execute, inject or manipulate processes while reducing reliance on obvious utilities. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that lineage, command intent and subsequent behavior across EDR; API telemetry; Sysmon; memory protection. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service

	account, expected destination and normal time window. Likely benign explanations include legitimate software, security products and accessibility tools.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test admin account to run a documented series of harmless information commands in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Native API without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

4.7 T1129 - Shared Modules (9 mappings: MAP-0242-MAP-0250)

Behavior focus: A DLL or shared object is loaded to execute attacker-controlled code within an existing process. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; image-load telemetry; Sysmon Event 7; code integrity.

MAP-0242 T1129 Shared Modules - Office application spawns an interpreter	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a corporate workstation shows the following pattern: a productivity application launches a script or command interpreter inconsistent with the document workflow. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign signed test document that triggers only a harmless local message in an isolated lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0243 T1129 Shared Modules - Encoded script activity on an endpoint	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an analyst test workstation shows the following pattern: a script engine processes obfuscated or encoded content and creates unusual child processes or network activity. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, execute a harmless encoded string that writes a test marker file, with no download or persistence. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0244 T1129 Shared Modules - Remote process creation through management tooling	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a Windows server segment shows the following pattern: management instrumentation creates a process remotely from a host that does not normally administer the target. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use approved administration tooling to start a benign test process on a lab server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized

	timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0245 T1129 Shared Modules - Scheduled execution outside change window	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a critical application server shows the following pattern: a new or modified task launches code at an unusual time or from a user-writable path. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a short-lived lab task that writes an audit marker and then delete it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0246 T1129 Shared Modules - Service-based execution	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a server operating system shows the following pattern: a service starts a new binary or command with an unusual image path, account or parent relationship. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign temporary test service on an isolated virtual machine and remove it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0247 T1129 Shared Modules - Native API execution pattern	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, an endpoint protected by EDR shows the following pattern: a process performs execution-related API activity that is uncommon for its signer, role or parent process. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided benign simulation or synthetic EDR event rather than custom injection code. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0248 T1129 Shared Modules - Unexpected shared module loading	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a business application host shows the following pattern: a trusted process loads a module from a user-controlled or uncommon directory. A realistic enterprise example is that a typical investigation begins

	when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, load an approved harmless library in a lab copy of the application from a designated test path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0249 T1129 Shared Modules - Temporary-folder script launch	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a user endpoint shows the following pattern: a script or executable starts from a download, temporary or cache location and is followed by system discovery. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run an inert script from a temporary lab folder that only records hostname and exits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0250 T1129 Shared Modules - Command chain after interactive login	
ATT&CK mapping	TA0002 Execution -> T1129 Shared Modules Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an administrator workstation shows the following pattern: a sequence of interpreters and utilities appears immediately after an unusual login. A realistic enterprise example is that a typical investigation begins when a document, remote-management action or signed utility creates an unexpected process and subsequent endpoint or network evidence. This maps to T1129 because the core observable is a DLL or shared object is loaded to execute attacker-controlled code within an existing process. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; image-load telemetry; Sysmon Event 7; code integrity. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal application module loading and software updates.. Build the process and user timeline, verify parent-child relationships, command or script content, signer and path, network connections, created files, and whether the action was authorised administration. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test admin account to run a documented series of harmless information commands in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Shared Modules without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

5. TA0003 - Persistence

This chapter contains 67 practical mappings across 7 priority techniques. Real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

5.1 T1547 - Boot or Logon Autostart Execution (10 mappings: MAP-0251-MAP-0260)

Behavior focus: Registry run keys, startup folders, login items or boot mechanisms launch code automatically. Primary analytic: Configuration change with creator and target-path context. Core telemetry: Registry; Sysmon; EDR; startup inventory; macOS/Linux audit.

MAP-0251 T1547 Boot or Logon Autostart Execution - Autostart entry on a user workstation	
ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources

Scenario and rationale	Following a change window, a managed endpoint shows the following pattern: a new startup location, logon item or registry value references a user-writable file. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a temporary autostart entry that launches only an inert test marker and remove it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0252 T1547 Boot or Logon Autostart Execution - New local account on a server	
ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a critical Windows server shows the following pattern: an account is created outside provisioning workflow and later receives an interactive or remote logon. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a disabled test account in the lab, verify telemetry, and delete it before ending the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0253 T1547 Boot or Logon Autostart Execution - Privileged cloud account manipulation	
ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise cloud tenant shows the following pattern: credentials, roles or authentication methods are added to an existing identity without a matching request. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-privileged test authentication method on a dedicated lab identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0254 T1547 Boot or Logon Autostart Execution - System service modified for repeat execution	
ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a server operating system shows the following pattern: a service image path, account or startup mode changes and points to an unusual location. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an

	approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a disposable lab service to invoke only a benign marker executable, then restore the original state. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0255 | T1547 Boot or Logon Autostart Execution - Web server component added

ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application server shows the following pattern: a new server-side component, plugin or script appears outside the release pipeline. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless test component to a non-production server through a documented exercise change. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0256 | T1547 Boot or Logon Autostart Execution - Execution flow hijack through search order

ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a desktop application shows the following pattern: a trusted application resolves a library or executable from an unexpected writable path. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab application and an approved harmless library to demonstrate the observable load path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0257 | T1547 Boot or Logon Autostart Execution - Dormant valid account reused

ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity environment shows the following pattern: an inactive but still valid account resumes access and establishes repeated sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any

	telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reactivate a dedicated test account for a short, approved window and then disable it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0258 T1547 Boot or Logon Autostart Execution - Scheduled cloud automation persistence	
ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a cloud subscription shows the following pattern: a new automation job or function is configured to run repeatedly using an unusual identity. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a non-privileged test job that writes a harmless log entry and remove the schedule. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0259 T1547 Boot or Logon Autostart Execution - Browser extension or add-in persistence	
ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a collaboration workstation shows the following pattern: an unapproved extension or add-in is installed and remains active across user sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign internally developed test extension in a disposable profile and remove it after capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0260 T1547 Boot or Logon Autostart Execution - Remote management configuration retained	
ATT&CK mapping	TA0003 Persistence -> T1547 Boot or Logon Autostart Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a third-party support platform shows the following pattern: a remote access configuration or account remains after the approved support period. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1547 because the core observable is registry run keys, startup folders, login items or boot mechanisms launch code automatically. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to configuration change with creator and target-path context across Registry; Sysmon; EDR; startup inventory; macOS/Linux audit. Preserve and enrich mechanism, old and new value, creator process, user, target file, signer and execution history. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved startup applications, drivers and user productivity tools.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited lab support configuration and confirm expiry and removal events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Boot or Logon Autostart Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

5.2 T1136 - Create Account (10 mappings: MAP-0261-MAP-0270)

Behavior focus: A local, domain, cloud or application account is created to retain access. Primary analytic: High-impact change with actor and authentication context. Core telemetry: AD audit; identity provider; local security logs; SaaS audit.

MAP-0261 T1136 Create Account - Autostart entry on a user workstation	
ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a managed endpoint shows the following pattern: a new startup location, logon item or registry value references a user-writable file. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a temporary autostart entry that launches only an inert test marker and remove it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0262 T1136 Create Account - New local account on a server	
ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a critical Windows server shows the following pattern: an account is created outside provisioning workflow and later receives an interactive or remote logon. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a disabled test account in the lab, verify telemetry, and delete it before ending the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0263 T1136 Create Account - Privileged cloud account manipulation	
ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise cloud tenant shows the following pattern: credentials, roles or authentication methods are added to an existing identity without a matching request. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-privileged test authentication method on a dedicated lab identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0264 T1136 Create Account - System service modified for repeat execution	
ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources

Scenario and rationale	During validation of an alert sequence, a server operating system shows the following pattern: a service image path, account or startup mode changes and points to an unusual location. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a disposable lab service to invoke only a benign marker executable, then restore the original state. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0265 | T1136 Create Account - Web server component added

ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application server shows the following pattern: a new server-side component, plugin or script appears outside the release pipeline. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless test component to a non-production server through a documented exercise change. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0266 | T1136 Create Account - Execution flow hijack through search order

ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a desktop application shows the following pattern: a trusted application resolves a library or executable from an unexpected writable path. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab application and an approved harmless library to demonstrate the observable load path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0267 | T1136 Create Account - Dormant valid account reused

ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity environment shows the following pattern: an inactive but still valid account resumes access and establishes repeated sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across AD audit; identity provider; local

	security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reactivate a dedicated test account for a short, approved window and then disable it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0268 | T1136 Create Account - Scheduled cloud automation persistence

ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a cloud subscription shows the following pattern: a new automation job or function is configured to run repeatedly using an unusual identity. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a non-privileged test job that writes a harmless log entry and remove the schedule. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0269 | T1136 Create Account - Browser extension or add-in persistence

ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a collaboration workstation shows the following pattern: an unapproved extension or add-in is installed and remains active across user sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign internally developed test extension in a disposable profile and remove it after capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0270 | T1136 Create Account - Remote management configuration retained

ATT&CK mapping	TA0003 Persistence -> T1136 Create Account Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a third-party support platform shows the following pattern: a remote access configuration or account remains after the approved support period. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1136 because the core observable is a local, domain, cloud or application account is created to retain access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across AD audit; identity provider; local security logs; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include new employees, service

	accounts and approved technical accounts.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited lab support configuration and confirm expiry and removal events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

5.3 T1098 - Account Manipulation (10 mappings: MAP-0271-MAP-0280)

Behavior focus: Credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. Primary analytic: High-impact change with actor and authentication context. Core telemetry: AD; Entra ID; IAM; PAM; SaaS audit.

MAP-0271 T1098 Account Manipulation - Autostart entry on a user workstation	
ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a managed endpoint shows the following pattern: a new startup location, logon item or registry value references a user-writable file. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a temporary autostart entry that launches only an inert test marker and remove it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0272 T1098 Account Manipulation - New local account on a server	
ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a critical Windows server shows the following pattern: an account is created outside provisioning workflow and later receives an interactive or remote logon. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a disabled test account in the lab, verify telemetry, and delete it before ending the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0273 T1098 Account Manipulation - Privileged cloud account manipulation	
ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise cloud tenant shows the following pattern: credentials, roles or authentication methods are added to an existing identity without a matching request. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, add and remove a non-privileged test authentication method on a dedicated lab identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0274 | T1098 Account Manipulation - System service modified for repeat execution

ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a server operating system shows the following pattern: a service image path, account or startup mode changes and points to an unusual location. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a disposable lab service to invoke only a benign marker executable, then restore the original state. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0275 | T1098 Account Manipulation - Web server component added

ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application server shows the following pattern: a new server-side component, plugin or script appears outside the release pipeline. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless test component to a non-production server through a documented exercise change. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0276 | T1098 Account Manipulation - Execution flow hijack through search order

ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a desktop application shows the following pattern: a trusted application resolves a library or executable from an unexpected writable path. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab application and an approved harmless library to demonstrate the observable load path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0277 | T1098 Account Manipulation - Dormant valid account reused

ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity environment shows the following pattern: an inactive but still valid account resumes access and establishes repeated sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reactivate a dedicated test account for a short, approved window and then disable it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0278 T1098 Account Manipulation - Scheduled cloud automation persistence	
ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a cloud subscription shows the following pattern: a new automation job or function is configured to run repeatedly using an unusual identity. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a non-privileged test job that writes a harmless log entry and remove the schedule. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0279 T1098 Account Manipulation - Browser extension or add-in persistence	
ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a collaboration workstation shows the following pattern: an unapproved extension or add-in is installed and remains active across user sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign internally developed test extension in a disposable profile and remove it after capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0280 T1098 Account Manipulation - Remote management configuration retained	
ATT&CK mapping	TA0003 Persistence -> T1098 Account Manipulation Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a third-party support platform shows the following pattern: a remote access configuration or account remains after the approved support period. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1098 because the core observable is credentials, group memberships, federation settings, MFA methods or account properties are changed to preserve access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Correlate raw and normalised events to high-impact change with actor and authentication context across AD; Entra ID; IAM; PAM; SaaS audit. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk resets, role changes and normal account maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited lab support configuration and confirm expiry and removal events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

5.4 T1543 - Create or Modify System Process (10 mappings: MAP-0281-MAP-0290)

Behavior focus: Services, daemons or launch agents are created or changed so attacker code starts reliably. Primary analytic: Service change with path, account and remote-origin context. Core telemetry: Windows System; Sysmon; EDR; auditd; configuration monitoring.

MAP-0281 T1543 Create or Modify System Process - Autostart entry on a user workstation	
ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a managed endpoint shows the following pattern: a new startup location, logon item or registry value references a user-writable file. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a temporary autostart entry that launches only an inert test marker and remove it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0282 T1543 Create or Modify System Process - New local account on a server	
ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a critical Windows server shows the following pattern: an account is created outside provisioning workflow and later receives an interactive or remote logon. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a disabled test account in the lab, verify telemetry, and delete it before ending the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0283 T1543 Create or Modify System Process - Privileged cloud account manipulation	
ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise cloud tenant shows the following pattern: credentials, roles or authentication methods are added to an existing identity without a matching request. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source

	and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-privileged test authentication method on a dedicated lab identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0284 T1543 Create or Modify System Process - System service modified for repeat execution	
ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a server operating system shows the following pattern: a service image path, account or startup mode changes and points to an unusual location. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a disposable lab service to invoke only a benign marker executable, then restore the original state. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0285 T1543 Create or Modify System Process - Web server component added	
ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application server shows the following pattern: a new server-side component, plugin or script appears outside the release pipeline. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless test component to a non-production server through a documented exercise change. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0286 T1543 Create or Modify System Process - Execution flow hijack through search order	
ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a desktop application shows the following pattern: a trusted application resolves a library or executable from an unexpected writable path. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service

	account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab application and an approved harmless library to demonstrate the observable load path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0287 | T1543 Create or Modify System Process - Dormant valid account reused

ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity environment shows the following pattern: an inactive but still valid account resumes access and establishes repeated sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reactivate a dedicated test account for a short, approved window and then disable it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0288 | T1543 Create or Modify System Process - Scheduled cloud automation persistence

ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a cloud subscription shows the following pattern: a new automation job or function is configured to run repeatedly using an unusual identity. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a non-privileged test job that writes a harmless log entry and remove the schedule. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0289 | T1543 Create or Modify System Process - Browser extension or add-in persistence

ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a collaboration workstation shows the following pattern: an unapproved extension or add-in is installed and remains active across user sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign internally developed test extension in a disposable profile and

	remove it after capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0290 T1543 Create or Modify System Process - Remote management configuration retained	
ATT&CK mapping	TA0003 Persistence -> T1543 Create or Modify System Process Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a third-party support platform shows the following pattern: a remote access configuration or account remains after the approved support period. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1543 because the core observable is services, daemons or launch agents are created or changed so attacker code starts reliably. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to service change with path, account and remote-origin context across Windows System; Sysmon; EDR; auditd; configuration monitoring. Preserve and enrich service name, binary path, account, start type, creator, remote source and subsequent execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, agent deployment and system maintenance.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a time-limited lab support configuration and confirm expiry and removal events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Create or Modify System Process without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

5.5 T1505 - Server Software Component (9 mappings: MAP-0291-MAP-0299)

Behavior focus: Web shells, plugins, modules or server components are added to maintain access through an application server. Primary analytic: Suspicious request followed by server-side consequence. Core telemetry: Web server; file integrity; EDR; application audit; WAF.

MAP-0291 T1505 Server Software Component - Autostart entry on a user workstation	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a managed endpoint shows the following pattern: a new startup location, logon item or registry value references a user-writable file. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a temporary autostart entry that launches only an inert test marker and remove it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0292 T1505 Server Software Component - New local account on a server	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a critical Windows server shows the following pattern: an account is created outside provisioning workflow and later receives an interactive or remote logon. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a disabled test account in the lab, verify telemetry, and delete it before ending the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software

	Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0293 T1505 Server Software Component - Privileged cloud account manipulation	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise cloud tenant shows the following pattern: credentials, roles or authentication methods are added to an existing identity without a matching request. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-privileged test authentication method on a dedicated lab identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0294 T1505 Server Software Component - System service modified for repeat execution	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a server operating system shows the following pattern: a service image path, account or startup mode changes and points to an unusual location. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a disposable lab service to invoke only a benign marker executable, then restore the original state. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0295 T1505 Server Software Component - Web server component added	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an internet-facing application server shows the following pattern: a new server-side component, plugin or script appears outside the release pipeline. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless test component to a non-production server through a documented exercise change. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0296 T1505 Server Software Component - Execution flow hijack through search order	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources

	more sources
Scenario and rationale	Following a change window, a desktop application shows the following pattern: a trusted application resolves a library or executable from an unexpected writable path. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab application and an approved harmless library to demonstrate the observable load path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0297 T1505 Server Software Component - Dormant valid account reused	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the identity environment shows the following pattern: an inactive but still valid account resumes access and establishes repeated sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reactivate a dedicated test account for a short, approved window and then disable it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0298 T1505 Server Software Component - Scheduled cloud automation persistence	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a cloud subscription shows the following pattern: a new automation job or function is configured to run repeatedly using an unusual identity. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a non-privileged test job that writes a harmless log entry and remove the schedule. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0299 T1505 Server Software Component - Browser extension or add-in persistence	
ATT&CK mapping	TA0003 Persistence -> T1505 Server Software Component Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a collaboration workstation shows the following pattern: an unapproved extension or add-in is installed and remains active across user sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1505 because the core observable is web shells, plugins, modules or server components are added to maintain access through an application server. The mapping describes behavior and evidence; it does not by itself

	prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where suspicious request followed by server-side consequence across Web server; file integrity; EDR; application audit; WAF. Preserve and enrich request, path, parameter, response, session, server process, file change and outbound connection. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, content updates and administrator extensions.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign internally developed test extension in a disposable profile and remove it after capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Server Software Component without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

5.6 T1574 - Hijack Execution Flow (9 mappings: MAP-0300-MAP-0308)

Behavior focus: Search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; Sysmon; image load; file integrity; registry.

MAP-0300 T1574 Hijack Execution Flow - Autostart entry on a user workstation	
ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a managed endpoint shows the following pattern: a new startup location, logon item or registry value references a user-writable file. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a temporary autostart entry that launches only an inert test marker and remove it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0301 T1574 Hijack Execution Flow - New local account on a server	
ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a critical Windows server shows the following pattern: an account is created outside provisioning workflow and later receives an interactive or remote logon. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a disabled test account in the lab, verify telemetry, and delete it before ending the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0302 T1574 Hijack Execution Flow - Privileged cloud account manipulation	
ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the enterprise cloud tenant shows the following pattern: credentials, roles or authentication methods are added to an existing identity without a matching request. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file

	integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-privileged test authentication method on a dedicated lab identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0303 | T1574 Hijack Execution Flow - System service modified for repeat execution

ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a server operating system shows the following pattern: a service image path, account or startup mode changes and points to an unusual location. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a disposable lab service to invoke only a benign marker executable, then restore the original state. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0304 | T1574 Hijack Execution Flow - Web server component added

ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an internet-facing application server shows the following pattern: a new server-side component, plugin or script appears outside the release pipeline. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless test component to a non-production server through a documented exercise change. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0305 | T1574 Hijack Execution Flow - Execution flow hijack through search order

ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a desktop application shows the following pattern: a trusted application resolves a library or executable from an unexpected writable path. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution,

	affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab application and an approved harmless library to demonstrate the observable load path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0306 | T1574 Hijack Execution Flow - Dormant valid account reused

ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, the identity environment shows the following pattern: an inactive but still valid account resumes access and establishes repeated sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reactivate a dedicated test account for a short, approved window and then disable it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0307 | T1574 Hijack Execution Flow - Scheduled cloud automation persistence

ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a cloud subscription shows the following pattern: a new automation job or function is configured to run repeatedly using an unusual identity. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a non-privileged test job that writes a harmless log entry and remove the schedule. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0308 | T1574 Hijack Execution Flow - Browser extension or add-in persistence

ATT&CK mapping	TA0003 Persistence -> T1574 Hijack Execution Flow Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a collaboration workstation shows the following pattern: an unapproved extension or add-in is installed and remains active across user sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1574 because the core observable is search-order, path, DLL, service or library-loading behavior is manipulated so legitimate execution loads malicious code. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; image load; file integrity; registry. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application compatibility shims and poorly packaged software.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign internally developed test extension in a disposable profile and remove it after capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Hijack Execution Flow without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity

	reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

5.7 T1078 - Valid Accounts (9 mappings: MAP-0309-MAP-0317)

Behavior focus: Stolen or retained credentials provide durable access without a separate implant. Primary analytic: Breadth or sequence correlation across authentication events. Core telemetry: Identity provider; AD; VPN; SaaS audit; UEBA.

MAP-0309 T1078 Valid Accounts - Autostart entry on a user workstation	
ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a managed endpoint shows the following pattern: a new startup location, logon item or registry value references a user-writable file. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a temporary autostart entry that launches only an inert test marker and remove it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0310 T1078 Valid Accounts - New local account on a server	
ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a critical Windows server shows the following pattern: an account is created outside provisioning workflow and later receives an interactive or remote logon. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a disabled test account in the lab, verify telemetry, and delete it before ending the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0311 T1078 Valid Accounts - Privileged cloud account manipulation	
ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the enterprise cloud tenant shows the following pattern: credentials, roles or authentication methods are added to an existing identity without a matching request. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-privileged test authentication method on a dedicated lab identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0312 T1078 Valid Accounts - System service modified for repeat execution	
ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a server operating system shows the following pattern: a

	service image path, account or startup mode changes and points to an unusual location. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a disposable lab service to invoke only a benign marker executable, then restore the original state. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0313 | T1078 Valid Accounts - Web server component added

ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an internet-facing application server shows the following pattern: a new server-side component, plugin or script appears outside the release pipeline. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless test component to a non-production server through a documented exercise change. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0314 | T1078 Valid Accounts - Execution flow hijack through search order

ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a desktop application shows the following pattern: a trusted application resolves a library or executable from an unexpected writable path. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab application and an approved harmless library to demonstrate the observable load path. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0315 | T1078 Valid Accounts - Dormant valid account reused

ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the identity environment shows the following pattern: an inactive but still valid account resumes access and establishes repeated sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service

	account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reactivate a dedicated test account for a short, approved window and then disable it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0316 T1078 Valid Accounts - Scheduled cloud automation persistence	
ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a cloud subscription shows the following pattern: a new automation job or function is configured to run repeatedly using an unusual identity. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a non-privileged test job that writes a harmless log entry and remove the schedule. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0317 T1078 Valid Accounts - Browser extension or add-in persistence	
ATT&CK mapping	TA0003 Persistence -> T1078 Valid Accounts Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a collaboration workstation shows the following pattern: an unapproved extension or add-in is installed and remains active across user sessions. A realistic enterprise example is that real incidents frequently retain access through account changes, scheduled execution, autostart locations, services, cloud automation or server-side components. This maps to T1078 because the core observable is stolen or retained credentials provide durable access without a separate implant. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across Identity provider; AD; VPN; SaaS audit; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal use, shared support accounts and service identities.. Identify the persistence object, creator, creation time, referenced file or identity, privilege level, first execution, affected systems, and whether the mechanism survives reboot, logoff or credential reset. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, install a benign internally developed test extension in a disposable profile and remove it after capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

6. TA0004 - Privilege Escalation

This chapter contains 58 practical mappings across 6 priority techniques. A standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

6.1 T1068 - Exploitation for Privilege Escalation (10 mappings: MAP-0318-MAP-0327)

Behavior focus: A local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. Primary analytic: Exposure plus exploit signal and post-exploitation consequence. Core telemetry: EDR; exploit protection; OS logs; vulnerability management.

MAP-0318 T1068 Exploitation for Privilege Escalation - Elevation after vulnerable service activity	
ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a server test segment shows the following pattern: a standard account is followed by privileged process activity without an approved elevation workflow. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided privilege simulation event or synthetic telemetry; do not exploit a live vulnerability. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0319 | T1068 Exploitation for Privilege Escalation - Access token use by an unusual process

ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a Windows endpoint shows the following pattern: a process obtains or uses a token associated with a more privileged identity than its normal context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved lab tool that duplicates a test token without accessing protected production resources. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0320 | T1068 Exploitation for Privilege Escalation - Domain or tenant policy changed

ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, Active Directory or the cloud tenant shows the following pattern: a policy grants broader privileges or weakens restrictions outside a controlled change. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a harmless lab policy affecting only test objects and restore it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0321 | T1068 Exploitation for Privilege Escalation - Consent or control bypass for elevation

ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an administrator workstation shows the following pattern: a process gains elevated rights through an unusual approval, helper or configuration path. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a built-in lab elevation prompt with a test account and capture only the

	resulting events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0322 | T1068 Exploitation for Privilege Escalation - Privileged valid account used unexpectedly

ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a critical management plane shows the following pattern: an administrative account accesses a new asset, service or time window without a matching task. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test admin identity on a non-production management endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0323 | T1068 Exploitation for Privilege Escalation - Process injection associated with higher privilege

ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an EDR-monitored endpoint shows the following pattern: one process manipulates another process running with greater rights and then performs privileged actions. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritize an alert when exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only a vendor-provided safe injection simulation or synthetic event stream. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0324 | T1068 Exploitation for Privilege Escalation - Cloud role assignment broadens access

ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a public cloud subscription shows the following pattern: a user or service principal receives a powerful role inconsistent with its previous duties. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, assign a narrow custom test role to a lab identity and remove it after telemetry verification. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0325 | T1068 Exploitation for Privilege Escalation - Misconfigured scheduled job executes as system

ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a user-controlled job or file is executed by a highly privileged scheduler context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a lab-only scheduled job that runs a harmless signed marker under an approved test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0326 T1068 Exploitation for Privilege Escalation - Service account privilege drift	
ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application platform shows the following pattern: a service account accumulates new group membership or permissions without application change evidence. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-sensitive lab group membership for a dedicated test service account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0327 T1068 Exploitation for Privilege Escalation - Container or workload identity elevation	
ATT&CK mapping	TA0004 Privilege Escalation -> T1068 Exploitation for Privilege Escalation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud-native test cluster shows the following pattern: a workload receives an elevated identity, capability or control-plane permission unexpectedly. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1068 because the core observable is a local vulnerability is exploited to move from a restricted context to administrator, root or system privileges. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that exposure plus exploit signal and post-exploitation consequence across EDR; exploit protection; OS logs; vulnerability management. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unusual but legitimate application faults.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox namespace and a non-destructive policy test with no access to production secrets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation for Privilege Escalation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

6.2 T1134 - Access Token Manipulation (10 mappings: MAP-0328-MAP-0337)

Behavior focus: Tokens are duplicated, impersonated or assigned to obtain another security context. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; process access; Windows Security; Sysmon.

MAP-0328 T1134 Access Token Manipulation - Elevation after vulnerable service activity	
ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a server test segment shows the following pattern: a standard account is followed by

	privileged process activity without an approved elevation workflow. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided privilege simulation event or synthetic telemetry; do not exploit a live vulnerability. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0329 T1134 Access Token Manipulation - Access token use by an unusual process	
ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a Windows endpoint shows the following pattern: a process obtains or uses a token associated with a more privileged identity than its normal context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved lab tool that duplicates a test token without accessing protected production resources. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0330 T1134 Access Token Manipulation - Domain or tenant policy changed	
ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, Active Directory or the cloud tenant shows the following pattern: a policy grants broader privileges or weakens restrictions outside a controlled change. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a harmless lab policy affecting only test objects and restore it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0331 T1134 Access Token Manipulation - Consent or control bypass for elevation	
ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an administrator workstation shows the following pattern: a process gains elevated rights through an unusual approval, helper or configuration path. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; process access; Windows

	Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a built-in lab elevation prompt with a test account and capture only the resulting events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0332 T1134 Access Token Manipulation - Privileged valid account used unexpectedly	
ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a critical management plane shows the following pattern: an administrative account accesses a new asset, service or time window without a matching task. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test admin identity on a non-production management endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0333 T1134 Access Token Manipulation - Process injection associated with higher privilege	
ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an EDR-monitored endpoint shows the following pattern: one process manipulates another process running with greater rights and then performs privileged actions. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only a vendor-provided safe injection simulation or synthetic event stream. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0334 T1134 Access Token Manipulation - Cloud role assignment broadens access	
ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a public cloud subscription shows the following pattern: a user or service principal receives a powerful role inconsistent with its previous duties. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify

	the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, assign a narrow custom test role to a lab identity and remove it after telemetry verification. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0335 | T1134 Access Token Manipulation - Misconfigured scheduled job executes as system

ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a user-controlled job or file is executed by a highly privileged scheduler context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a lab-only scheduled job that runs a harmless signed marker under an approved test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0336 | T1134 Access Token Manipulation - Service account privilege drift

ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application platform shows the following pattern: a service account accumulates new group membership or permissions without application change evidence. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-sensitive lab group membership for a dedicated test service account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0337 | T1134 Access Token Manipulation - Container or workload identity elevation

ATT&CK mapping	TA0004 Privilege Escalation -> T1134 Access Token Manipulation Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud-native test cluster shows the following pattern: a workload receives an elevated identity, capability or control-plane permission unexpectedly. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1134 because the core observable is tokens are duplicated, impersonated or assigned to obtain another security context. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; process access; Windows Security; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administrative tools, backup software and endpoint security products.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox namespace and a non-destructive policy test with no access to production secrets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Access Token Manipulation without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored.

	Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

6.3 T1484 - Domain or Tenant Policy Modification (10 mappings: MAP-0338-MAP-0347)

Behavior focus: Directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. Primary analytic: High-impact change with actor and authentication context. Core telemetry: AD; Entra ID; cloud audit; GPO change; PAM.

MAP-0338 T1484 Domain or Tenant Policy Modification - Elevation after vulnerable service activity	
ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a server test segment shows the following pattern: a standard account is followed by privileged process activity without an approved elevation workflow. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided privilege simulation event or synthetic telemetry; do not exploit a live vulnerability. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0339 T1484 Domain or Tenant Policy Modification - Access token use by an unusual process	
ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a Windows endpoint shows the following pattern: a process obtains or uses a token associated with a more privileged identity than its normal context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved lab tool that duplicates a test token without accessing protected production resources. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0340 T1484 Domain or Tenant Policy Modification - Domain or tenant policy changed	
ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, Active Directory or the cloud tenant shows the following pattern: a policy grants broader privileges or weakens restrictions outside a controlled change. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a harmless lab policy affecting only test objects and restore it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0341 T1484 Domain or Tenant Policy Modification - Consent or control bypass for elevation	
ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an administrator workstation shows the following pattern: a process gains elevated rights through an unusual approval, helper or configuration path. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a built-in lab elevation prompt with a test account and capture only the resulting events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0342 T1484 Domain or Tenant Policy Modification - Privileged valid account used unexpectedly	
ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a critical management plane shows the following pattern: an administrative account accesses a new asset, service or time window without a matching task. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test admin identity on a non-production management endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0343 T1484 Domain or Tenant Policy Modification - Process injection associated with higher privilege	
ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an EDR-monitored endpoint shows the following pattern: one process manipulates another process running with greater rights and then performs privileged actions. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only a vendor-provided safe injection simulation or synthetic event stream. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0344 T1484 Domain or Tenant Policy Modification - Cloud role assignment broadens access	
ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a public cloud subscription shows the following pattern: a user or service principal receives a powerful role inconsistent with its previous duties. A realistic enterprise example is that a standard user or low-privilege

	process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, assign a narrow custom test role to a lab identity and remove it after telemetry verification. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0345 | T1484 Domain or Tenant Policy Modification - Misconfigured scheduled job executes as system

ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a user-controlled job or file is executed by a highly privileged scheduler context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a lab-only scheduled job that runs a harmless signed marker under an approved test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0346 | T1484 Domain or Tenant Policy Modification - Service account privilege drift

ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application platform shows the following pattern: a service account accumulates new group membership or permissions without application change evidence. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-sensitive lab group membership for a dedicated test service account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0347 | T1484 Domain or Tenant Policy Modification - Container or workload identity elevation

ATT&CK mapping	TA0004 Privilege Escalation -> T1484 Domain or Tenant Policy Modification Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud-native test cluster shows the following pattern: a workload receives an elevated identity, capability or control-plane permission unexpectedly. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1484 because the core observable is directory, federation, conditional access or domain policy is changed to weaken controls or grant broader privilege. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that high-impact change with actor and authentication context across AD; Entra ID; cloud audit; GPO change; PAM. Preserve and enrich actor, target, role, old and new value, source, device, token, MFA and approval context. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or

	privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved policy deployment and emergency access changes. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox namespace and a non-destructive policy test with no access to production secrets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain or Tenant Policy Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

6.4 T1548 - Abuse Elevation Control Mechanism (10 mappings: MAP-0348-MAP-0357)

Behavior focus: Sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; Windows Security; sudo; auditd; application control.

MAP-0348 T1548 Abuse Elevation Control Mechanism - Elevation after vulnerable service activity	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a server test segment shows the following pattern: a standard account is followed by privileged process activity without an approved elevation workflow. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided privilege simulation event or synthetic telemetry; do not exploit a live vulnerability. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0349 T1548 Abuse Elevation Control Mechanism - Access token use by an unusual process	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a Windows endpoint shows the following pattern: a process obtains or uses a token associated with a more privileged identity than its normal context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved lab tool that duplicates a test token without accessing protected production resources. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0350 T1548 Abuse Elevation Control Mechanism - Domain or tenant policy changed	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, Active Directory or the cloud tenant shows the following pattern: a policy grants broader privileges or weakens restrictions outside a controlled change. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a harmless lab policy affecting only test objects and restore it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0351 T1548 Abuse Elevation Control Mechanism - Consent or control bypass for elevation	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an administrator workstation shows the following pattern: a process gains elevated rights through an unusual approval, helper or configuration path. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a built-in lab elevation prompt with a test account and capture only the resulting events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0352 T1548 Abuse Elevation Control Mechanism - Privileged valid account used unexpectedly	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a critical management plane shows the following pattern: an administrative account accesses a new asset, service or time window without a matching task. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test admin identity on a non-production management endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0353 T1548 Abuse Elevation Control Mechanism - Process injection associated with higher privilege	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an EDR-monitored endpoint shows the following pattern: one process manipulates another process running with greater rights and then performs privileged actions. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only a vendor-provided safe injection simulation or synthetic event stream. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps.

	Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

MAP-0354 T1548 Abuse Elevation Control Mechanism - Cloud role assignment broadens access	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a public cloud subscription shows the following pattern: a user or service principal receives a powerful role inconsistent with its previous duties. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, assign a narrow custom test role to a lab identity and remove it after telemetry verification. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0355 T1548 Abuse Elevation Control Mechanism - Misconfigured scheduled job executes as system	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a user-controlled job or file is executed by a highly privileged scheduler context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a lab-only scheduled job that runs a harmless signed marker under an approved test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0356 T1548 Abuse Elevation Control Mechanism - Service account privilege drift	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application platform shows the following pattern: a service account accumulates new group membership or permissions without application change evidence. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-sensitive lab group membership for a dedicated test service account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0357 T1548 Abuse Elevation Control Mechanism - Container or workload identity elevation	
ATT&CK mapping	TA0004 Privilege Escalation -> T1548 Abuse Elevation Control Mechanism Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud-native test cluster shows the following pattern: a workload receives an

	elevated identity, capability or control-plane permission unexpectedly. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1548 because the core observable is sudo, UAC bypass, setuid or similar mechanisms are abused to elevate execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Windows Security; sudo; auditd; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal administration and software installers.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox namespace and a non-destructive policy test with no access to production secrets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Abuse Elevation Control Mechanism without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

6.5 T1078 - Valid Accounts (9 mappings: MAP-0358-MAP-0366)

Behavior focus: An account that already has elevated privilege is stolen or misused. Primary analytic: Breadth or sequence correlation across authentication events. Core telemetry: Identity provider; PAM; AD; VPN; UEBA.

MAP-0358 T1078 Valid Accounts - Elevation after vulnerable service activity	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a server test segment shows the following pattern: a standard account is followed by privileged process activity without an approved elevation workflow. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritize an alert when breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided privilege simulation event or synthetic telemetry; do not exploit a live vulnerability. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0359 T1078 Valid Accounts - Access token use by an unusual process	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a Windows endpoint shows the following pattern: a process obtains or uses a token associated with a more privileged identity than its normal context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved lab tool that duplicates a test token without accessing protected production resources. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0360 T1078 Valid Accounts - Domain or tenant policy changed	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, Active Directory or the cloud tenant shows the following pattern: a policy grants broader privileges or weakens restrictions outside a controlled change. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or

	process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a harmless lab policy affecting only test objects and restore it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0361 T1078 Valid Accounts - Consent or control bypass for elevation	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an administrator workstation shows the following pattern: a process gains elevated rights through an unusual approval, helper or configuration path. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a built-in lab elevation prompt with a test account and capture only the resulting events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0362 T1078 Valid Accounts - Privileged valid account used unexpectedly	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a critical management plane shows the following pattern: an administrative account accesses a new asset, service or time window without a matching task. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test admin identity on a non-production management endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0363 T1078 Valid Accounts - Process injection associated with higher privilege	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an EDR-monitored endpoint shows the following pattern: one process manipulates another process running with greater rights and then performs privileged actions. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action,

	result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only a vendor-provided safe injection simulation or synthetic event stream. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0364 T1078 Valid Accounts - Cloud role assignment broadens access	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a public cloud subscription shows the following pattern: a user or service principal receives a powerful role inconsistent with its previous duties. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, assign a narrow custom test role to a lab identity and remove it after telemetry verification. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0365 T1078 Valid Accounts - Misconfigured scheduled job executes as system	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a server operating system shows the following pattern: a user-controlled job or file is executed by a highly privileged scheduler context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a lab-only scheduled job that runs a harmless signed marker under an approved test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0366 T1078 Valid Accounts - Service account privilege drift	
ATT&CK mapping	TA0004 Privilege Escalation -> T1078 Valid Accounts Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application platform shows the following pattern: a service account accumulates new group membership or permissions without application change evidence. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1078 because the core observable is an account that already has elevated privilege is stolen or misused. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to breadth or sequence correlation across authentication events across Identity provider; PAM; AD; VPN; UEBA. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate privileged administration and break-glass use.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, add and remove a non-sensitive lab group membership for a dedicated test service account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Valid Accounts without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

6.6 T1055 - Process Injection (9 mappings: MAP-0367-MAP-0375)

Behavior focus: Code is inserted into another process to inherit permissions, hide execution or access protected resources. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; process access; memory telemetry; Sysmon.

MAP-0367 T1055 Process Injection - Elevation after vulnerable service activity	
ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a server test segment shows the following pattern: a standard account is followed by privileged process activity without an approved elevation workflow. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided privilege simulation event or synthetic telemetry; do not exploit a live vulnerability. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0368 T1055 Process Injection - Access token use by an unusual process	
ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a Windows endpoint shows the following pattern: a process obtains or uses a token associated with a more privileged identity than its normal context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved lab tool that duplicates a test token without accessing protected production resources. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0369 T1055 Process Injection - Domain or tenant policy changed	
ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, Active Directory or the cloud tenant shows the following pattern: a policy grants broader privileges or weakens restrictions outside a controlled change. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a harmless lab policy affecting only test objects and restore it immediately. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized

	timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

MAP-0370 | T1055 Process Injection - Consent or control bypass for elevation

ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, an administrator workstation shows the following pattern: a process gains elevated rights through an unusual approval, helper or configuration path. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a built-in lab elevation prompt with a test account and capture only the resulting events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0371 | T1055 Process Injection - Privileged valid account used unexpectedly

ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a critical management plane shows the following pattern: an administrative account accesses a new asset, service or time window without a matching task. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test admin identity on a non-production management endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0372 | T1055 Process Injection - Process injection associated with higher privilege

ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an EDR-monitored endpoint shows the following pattern: one process manipulates another process running with greater rights and then performs privileged actions. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only a vendor-provided safe injection simulation or synthetic event stream. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0373 | T1055 Process Injection - Cloud role assignment broadens access

ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a public cloud subscription shows the following pattern: a user or service principal receives a powerful role inconsistent with its previous duties. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, assign a narrow custom test role to a lab identity and remove it after telemetry verification. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0374 | T1055 Process Injection - Misconfigured scheduled job executes as system

ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a server operating system shows the following pattern: a user-controlled job or file is executed by a highly privileged scheduler context. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create a lab-only scheduled job that runs a harmless signed marker under an approved test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0375 | T1055 Process Injection - Service account privilege drift

ATT&CK mapping	TA0004 Privilege Escalation -> T1055 Process Injection Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, an application platform shows the following pattern: a service account accumulates new group membership or permissions without application change evidence. A realistic enterprise example is that a standard user or low-privilege process may gain additional authority through policy changes, token use, vulnerable services, role assignment or process manipulation. This maps to T1055 because the core observable is code is inserted into another process to inherit permissions, hide execution or access protected resources. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that lineage, command intent and subsequent behavior across EDR; process access; memory telemetry; Sysmon. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security products, accessibility software and application instrumentation.. Compare the user and process privilege before and after the event, identify the mechanism that changed authority, review policy and token evidence, and scope every action performed with the elevated context. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, add and remove a non-sensitive lab group membership for a dedicated test service account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7. TA0005 - Defense Evasion

This chapter contains 85 practical mappings across 9 priority techniques. Attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

7.1 T1027 - Obfuscated Files or Information (10 mappings: MAP-0376-MAP-0385)

Behavior focus: Encoding, packing, encryption or string transformation hides executable content and command intent. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: AMSI; EDR; sandbox; script logs; file analysis.

MAP-0376 T1027 Obfuscated Files or Information - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0377 T1027 Obfuscated Files or Information - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0378 T1027 Obfuscated Files or Information - Masquerading as a trusted business file	
ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0379 T1027 Obfuscated Files or Information - Signed binary proxy pattern	
ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated

	by two or more sources
Scenario and rationale	During an analyst-led hunt, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0380 | T1027 Obfuscated Files or Information - Deobfuscation immediately before execution

ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0381 | T1027 Obfuscated Files or Information - Registry modification reduces visibility

ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed endpoint shows the following pattern: registry changes alter logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0382 | T1027 Obfuscated Files or Information - File permissions hide or protect artifacts

ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named

	threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0383 | T1027 Obfuscated Files or Information - Process manipulation to blend with trusted activity

ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0384 | T1027 Obfuscated Files or Information - Time-delayed execution avoids sandbox windows

ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0385 | T1027 Obfuscated Files or Information - Cloud audit setting weakened

ATT&CK mapping	TA0005 Defense Evasion -> T1027 Obfuscated Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the enterprise cloud tenant shows the following pattern: diagnostic, audit or retention configuration is reduced before other suspicious actions. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1027 because the core observable is encoding, packing, encryption or string transformation hides executable content and command intent. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across AMSI; EDR; sandbox; script logs; file analysis. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, compressed software, protectors and legitimate encoded administration.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change only a lab subscription diagnostic setting and restore it within the same exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Obfuscated Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.2 T1070 - Indicator Removal (10 mappings: MAP-0386-MAP-0395)

Behavior focus: Logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. Primary analytic: Explicit clearing or telemetry-health degradation. Core telemetry: Windows Security; EDR; auditd; cloud audit; file integrity.

MAP-0386 T1070 Indicator Removal - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0387 T1070 Indicator Removal - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0388 T1070 Indicator Removal - Masquerading as a trusted business file	
ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored

	completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0389 | T1070 Indicator Removal - Signed binary proxy pattern

ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0390 | T1070 Indicator Removal - Deobfuscation immediately before execution

ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0391 | T1070 Indicator Removal - Registry modification reduces visibility

ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed endpoint shows the following pattern: registry changes alter logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0392 T1070 Indicator Removal - File permissions hide or protect artifacts	
ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0393 T1070 Indicator Removal - Process manipulation to blend with trusted activity	
ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0394 T1070 Indicator Removal - Time-delayed execution avoids sandbox windows	
ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0395 T1070 Indicator Removal - Cloud audit setting weakened	
ATT&CK mapping	TA0005 Defense Evasion -> T1070 Indicator Removal Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the enterprise cloud tenant shows the following pattern: diagnostic, audit or retention configuration is reduced before other suspicious actions. A realistic enterprise example is that attackers commonly reduce

	visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1070 because the core observable is logs, files, histories, timestamps or cloud artifacts are cleared or altered to impede investigation. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when explicit clearing or telemetry-health degradation across Windows Security; EDR; auditd; cloud audit; file integrity. Preserve and enrich log clear event, policy change, service state, expected heartbeat, event-volume trend and maintenance record. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include privacy tools, maintenance scripts and log rotation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change only a lab subscription diagnostic setting and restore it within the same exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Indicator Removal without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.3 T1562 - Impair Defenses (10 mappings: MAP-0396-MAP-0405)

Behavior focus: Security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. Primary analytic: Critical configuration change with authorization context. Core telemetry: EDR; antivirus; Windows Security; cloud audit; configuration monitoring.

MAP-0396 T1562 Impair Defenses - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0397 T1562 Impair Defenses - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0398 T1562 Impair Defenses - Masquerading as a trusted business file	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named

	threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0399 T1562 Impair Defenses - Signed binary proxy pattern	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0400 T1562 Impair Defenses - Deobfuscation immediately before execution	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0401 T1562 Impair Defenses - Registry modification reduces visibility	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed endpoint shows the following pattern: registry changes alter logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0402 T1562 Impair Defenses - File permissions hide or protect artifacts	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0403 T1562 Impair Defenses - Process manipulation to blend with trusted activity	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0404 T1562 Impair Defenses - Time-delayed execution avoids sandbox windows	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network

	behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0405 T1562 Impair Defenses - Cloud audit setting weakened	
ATT&CK mapping	TA0005 Defense Evasion -> T1562 Impair Defenses Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the enterprise cloud tenant shows the following pattern: diagnostic, audit or retention configuration is reduced before other suspicious actions. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1562 because the core observable is security agents, logging, firewall, scanning or cloud controls are disabled, reconfigured or bypassed. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when critical configuration change with authorization context across EDR; antivirus; Windows Security; cloud audit; configuration monitoring. Preserve and enrich control name, old and new state, exclusion, actor, process, authorization and telemetry outcome. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, upgrades, exclusions and approved maintenance. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change only a lab subscription diagnostic setting and restore it within the same exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Impair Defenses without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.4 T1036 - Masquerading (10 mappings: MAP-0406-MAP-0415)

Behavior focus: Names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. Primary analytic: File origin, prevalence, path and execution sequence. Core telemetry: EDR; file telemetry; code signing; email; sandbox.

MAP-0406 T1036 Masquerading - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0407 T1036 Masquerading - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0408 T1036 Masquerading - Masquerading as a trusted business file	
ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0409 T1036 Masquerading - Signed binary proxy pattern	
ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0410 T1036 Masquerading - Deobfuscation immediately before execution	
ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0411 T1036 Masquerading - Registry modification reduces visibility	
ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed endpoint shows the following pattern: registry changes alter logging,

	security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0412 | T1036 Masquerading - File permissions hide or protect artifacts

ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0413 | T1036 Masquerading - Process manipulation to blend with trusted activity

ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0414 | T1036 Masquerading - Time-delayed execution avoids sandbox windows

ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or

	privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0415 T1036 Masquerading - Cloud audit setting weakened	
ATT&CK mapping	TA0005 Defense Evasion -> T1036 Masquerading Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the enterprise cloud tenant shows the following pattern: diagnostic, audit or retention configuration is reduced before other suspicious actions. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1036 because the core observable is names, paths, icons, extensions or metadata are changed to make malicious content appear trusted or ordinary. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when file origin, prevalence, path and execution sequence across EDR; file telemetry; code signing; email; sandbox. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include portable applications, renamed utilities and legacy software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change only a lab subscription diagnostic setting and restore it within the same exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Masquerading without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.5 T1218 - System Binary Proxy Execution (9 mappings: MAP-0416-MAP-0424)

Behavior focus: Trusted signed binaries execute, proxy or download attacker-controlled content. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; Sysmon; command line; network; application control.

MAP-0416 T1218 System Binary Proxy Execution - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0417 T1218 System Binary Proxy Execution - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0418 | T1218 System Binary Proxy Execution - Masquerading as a trusted business file

ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0419 | T1218 System Binary Proxy Execution - Signed binary proxy pattern

ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0420 | T1218 System Binary Proxy Execution - Deobfuscation immediately before execution

ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success

	requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

MAP-0421 T1218 System Binary Proxy Execution - Registry modification reduces visibility	
ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a managed endpoint shows the following pattern: registry changes alter logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0422 T1218 System Binary Proxy Execution - File permissions hide or protect artifacts	
ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0423 T1218 System Binary Proxy Execution - Process manipulation to blend with trusted activity	
ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0424 T1218 System Binary Proxy Execution - Time-delayed execution avoids sandbox windows	
ATT&CK mapping	TA0005 Defense Evasion -> T1218 System Binary Proxy Execution Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a malware-analysis or endpoint environment shows the following pattern: a newly introduced

	process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1218 because the core observable is trusted signed binaries execute, proxy or download attacker-controlled content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; Sysmon; command line; network; application control. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include installers, management scripts and vendor software.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Binary Proxy Execution without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.6 T1140 - Deobfuscate or Decode Files or Information (9 mappings: MAP-0425-MAP-0433)

Behavior focus: Content is decoded or unpacked on the host immediately before execution or use. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; AMSI; file telemetry; process command line.

MAP-0425 T1140 Deobfuscate or Decode Files or Information - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0426 T1140 Deobfuscate or Decode Files or Information - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0427 T1140 Deobfuscate or Decode Files or Information - Masquerading as a trusted business file	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a

	named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0428 T1140 Deobfuscate or Decode Files or Information - Signed binary proxy pattern	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0429 T1140 Deobfuscate or Decode Files or Information - Deobfuscation immediately before execution	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0430 T1140 Deobfuscate or Decode Files or Information - Registry modification reduces visibility	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a managed endpoint shows the following pattern: registry changes after logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0431 T1140 Deobfuscate or Decode Files or Information - File permissions hide or protect artifacts	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0432 T1140 Deobfuscate or Decode Files or Information - Process manipulation to blend with trusted activity	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0433 T1140 Deobfuscate or Decode Files or Information - Time-delayed execution avoids sandbox windows	
ATT&CK mapping	TA0005 Defense Evasion -> T1140 Deobfuscate or Decode Files or Information Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1140 because the core observable is content is decoded or unpacked on the host immediately before execution or use. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when lineage, command intent and subsequent behavior across EDR; AMSI; file telemetry; process command line. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, archives and legitimate data processing.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Deobfuscate or Decode Files or

Information without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.7 T1112 - Modify Registry (9 mappings: MAP-0434-MAP-0442)

Behavior focus: Registry keys are changed to alter execution, persistence, security settings or system behavior. Primary analytic: Security-relevant key change with creator process. Core telemetry: Registry auditing; Sysmon Event 13; EDR; configuration monitoring.

MAP-0434 T1112 Modify Registry - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0435 T1112 Modify Registry - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0436 T1112 Modify Registry - Masquerading as a trusted business file	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0437 T1112 Modify Registry - Signed binary proxy pattern	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0438 T1112 Modify Registry - Deobfuscation immediately before execution	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0439 T1112 Modify Registry - Registry modification reduces visibility	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a managed endpoint shows the following pattern: registry changes alter logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0440 T1112 Modify Registry - File permissions hide or protect artifacts	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly

	reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0441 T1112 Modify Registry - Process manipulation to blend with trusted activity	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0442 T1112 Modify Registry - Time-delayed execution avoids sandbox windows	
ATT&CK mapping	TA0005 Defense Evasion -> T1112 Modify Registry Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1112 because the core observable is registry keys are changed to alter execution, persistence, security settings or system behavior. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when security-relevant key change with creator process across Registry auditing; Sysmon Event 13; EDR; configuration monitoring. Preserve and enrich key, value, old and new data, creator process, user and referenced file. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software installation, policy deployment and user preferences.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Modify Registry without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.8 T1222 - File and Directory Permissions Modification (9 mappings: MAP-0443-MAP-0451)

Behavior focus: Permissions or ownership are changed to hide, protect or enable attacker-controlled files. Primary analytic: File origin, prevalence, path and execution sequence. Core telemetry: File audit; EDR; audit; integrity monitoring.

MAP-0443 T1222 File and Directory Permissions Modification - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or

	enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0444 T1222 File and Directory Permissions Modification - Audit evidence deletion attempt	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0445 T1222 File and Directory Permissions Modification - Masquerading as a trusted business file	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0446 T1222 File and Directory Permissions Modification - Signed binary proxy pattern	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source,

	target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0447 T1222 File and Directory Permissions Modification - Deobfuscation immediately before execution	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0448 T1222 File and Directory Permissions Modification - Registry modification reduces visibility	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a managed endpoint shows the following pattern: registry changes alter logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0449 T1222 File and Directory Permissions Modification - File permissions hide or protect artifacts	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored

	completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0450 T1222 File and Directory Permissions Modification - Process manipulation to blend with trusted activity	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0451 T1222 File and Directory Permissions Modification - Time-delayed execution avoids sandbox windows	
ATT&CK mapping	TA0005 Defense Evasion -> T1222 File and Directory Permissions Modification Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1222 because the core observable is permissions or ownership are changed to hide, protect or enable attacker-controlled files. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that file origin, prevalence, path and execution sequence across File audit; EDR; auditd; integrity monitoring. Preserve and enrich path, original name, extension, signer, hash, prevalence, source, permissions and execution. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include application deployment, shared-folder administration and service setup.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify File and Directory Permissions Modification without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

7.9 T1055 - Process Injection (9 mappings: MAP-0452-MAP-0460)

Behavior focus: Malicious code runs inside another process to conceal origin or evade controls. Primary analytic: Lineage, command intent and subsequent behavior. Core telemetry: EDR; memory protection; Sysmon; process access.

MAP-0452 T1055 Process Injection - Security control tampering on an endpoint	
ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a managed workstation shows the following pattern: security configuration, services or exclusions change shortly before suspicious activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, toggle only a benign test policy in an isolated endpoint and immediately restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0453 | T1055 Process Injection - Audit evidence deletion attempt

ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a Windows or Linux server shows the following pattern: logs, history or artifacts are cleared outside maintenance procedures. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, clear a dedicated lab application log containing only synthetic entries, not security logs. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0454 | T1055 Process Injection - Masquerading as a trusted business file

ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, email and endpoint telemetry shows the following pattern: a file name, icon, path or metadata imitates a legitimate document or system component. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an inert file with a deceptive test name in a lab folder and do not execute it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0455 | T1055 Process Injection - Signed binary proxy pattern

ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a Windows endpoint shows the following pattern: a trusted operating-system utility launches content or establishes network activity outside its normal role. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-approved safe test that produces the parent-child relationship without a payload. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0456 | T1055 Process Injection - Deobfuscation immediately before execution

ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a script-monitored endpoint shows the following pattern: encoded data is decoded in memory or on disk and followed by interpreter or process activity. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, decode a harmless text blob and write only an exercise marker. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0457 | T1055 Process Injection - Registry modification reduces visibility

ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a managed endpoint shows the following pattern: registry changes alter logging, security settings or execution behavior without a change ticket. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a non-security lab registry value designed for the exercise and restore it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0458 | T1055 Process Injection - File permissions hide or protect artifacts

ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a file server or endpoint shows the following pattern: permissions or attributes change to restrict access, conceal content or prevent scanning. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, change permissions on a synthetic lab file and return them to baseline. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0459 | T1055 Process Injection - Process manipulation to blend with trusted activity

ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an EDR test host shows the following pattern: execution occurs within or through an unexpected trusted process context. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Prioritise an alert when lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, rely on synthetic or vendor-provided safe process-manipulation telemetry. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0460 T1055 Process Injection - Time-delayed execution avoids sandbox windows	
ATT&CK mapping	TA0005 Defense Evasion -> T1055 Process Injection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a malware-analysis or endpoint environment shows the following pattern: a newly introduced process waits, checks timing or executes only after an unusual delay. A realistic enterprise example is that attackers commonly reduce visibility by altering security controls, clearing evidence, disguising files, abusing trusted utilities or changing permissions and logging. This maps to T1055 because the core observable is malicious code runs inside another process to conceal origin or evade controls. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to lineage, command intent and subsequent behavior across EDR; memory protection; Sysmon; process access. Preserve and enrich process and parent identifiers, image, command line, signer, hash, user, integrity and child activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security software and legitimate instrumentation.. Determine which control or evidence source was affected, who changed it, the duration of reduced visibility, suspicious activity during the blind period, and whether the configuration was restored completely. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a harmless lab script with a short approved delay and no network behavior. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Process Injection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8. TA0006 - Credential Access

This chapter contains 76 practical mappings across 8 priority techniques. Credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

8.1 T1003 - OS Credential Dumping (10 mappings: MAP-0461-MAP-0470)

Behavior focus: Memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. Primary analytic: Sensitive material access plus later credential use. Core telemetry: EDR; LSASS protection; Sysmon; Windows Security; file access.

MAP-0461 T1003 OS Credential Dumping - Credential material access on a workstation	
ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0462 T1003 OS Credential Dumping - Low-and-slow password spraying	
ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate lockout. A realistic enterprise example is that credential-related

	incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0463 | T1003 OS Credential Dumping - Unusual Kerberos ticket activity

ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0464 | T1003 OS Credential Dumping - Browser or application password store access

ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0465 | T1003 OS Credential Dumping - Input capture behavior near authentication

ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files,

	secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0466 | T1003 OS Credential Dumping - Web session cookie misuse

ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0467 | T1003 OS Credential Dumping - Application token accessed by a new process

ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0468 | T1003 OS Credential Dumping - Secrets found in unsecured files

ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing.. Protect evidence while identifying the targeted credential source, process and identity

	involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0469 T1003 OS Credential Dumping - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0470 T1003 OS Credential Dumping - Cloud metadata or managed identity token access	
ATT&CK mapping	TA0006 Credential Access -> T1003 OS Credential Dumping Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a public cloud workload shows the following pattern: a process or workload accesses identity metadata in a manner not expected for its role. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1003 because the core observable is memory, registry, directory databases or cached secrets are accessed to recover reusable credentials. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across EDR; LSASS protection; Sysmon; Windows Security; file access. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include endpoint security, forensic tools and approved credential testing. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only a sandbox metadata endpoint with a restricted test identity and no production permissions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify OS Credential Dumping without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8.2 T1110 - Brute Force (10 mappings: MAP-0471-MAP-0480)

Behavior focus: Password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. Primary analytic: Breadth or sequence correlation across authentication events. Core telemetry: Identity provider; AD; VPN; application authentication; WAF.

MAP-0471 T1110 Brute Force - Credential material access on a workstation	
ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0472 | T1110 Brute Force - Low-and-slow password spraying

ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate lockout. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0473 | T1110 Brute Force - Unusual Kerberos ticket activity

ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0474 | T1110 Brute Force - Browser or application password store access

ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0475 | T1110 Brute Force - Input capture behavior near authentication

ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
---------------------------	--

	sources
Scenario and rationale	While comparing activity with the 30-day baseline, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0476 T1110 Brute Force - Web session cookie misuse	
ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0477 T1110 Brute Force - Application token accessed by a new process	
ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0478 T1110 Brute Force - Secrets found in unsecured files	
ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Build a correlation that breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0479 T1110 Brute Force - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0480 T1110 Brute Force - Cloud metadata or managed identity token access	
ATT&CK mapping	TA0006 Credential Access -> T1110 Brute Force Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a public cloud workload shows the following pattern: a process or workload accesses identity metadata in a manner not expected for its role. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1110 because the core observable is password guessing, spraying, credential stuffing or cracking attempts target one or many accounts. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to breadth or sequence correlation across authentication events across Identity provider; AD; VPN; application authentication; WAF. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include user mistakes, stale applications and health checks.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only a sandbox metadata endpoint with a restricted test identity and no production permissions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Brute Force without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8.3 T1558 - Steal or Forge Kerberos Tickets (10 mappings: MAP-0481-MAP-0490)

Behavior focus: Kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. Primary analytic: Sensitive material access plus later credential use. Core telemetry: AD; domain controller; EDR; Kerberos events; UEBA.

MAP-0481 T1558 Steal or Forge Kerberos Tickets - Credential material access on a workstation	
ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the

	actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0482 | T1558 Steal or Forge Kerberos Tickets - Low-and-slow password spraying

ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate logout. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0483 | T1558 Steal or Forge Kerberos Tickets - Unusual Kerberos ticket activity

ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0484 | T1558 Steal or Forge Kerberos Tickets - Browser or application password store access

ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future

	changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0485 T1558 Steal or Forge Kerberos Tickets - Input capture behavior near authentication	
ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0486 T1558 Steal or Forge Kerberos Tickets - Web session cookie misuse	
ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0487 T1558 Steal or Forge Kerberos Tickets - Application token accessed by a new process	
ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0488 T1558 Steal or Forge Kerberos Tickets - Secrets found in unsecured files	
ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0489 T1558 Steal or Forge Kerberos Tickets - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0490 T1558 Steal or Forge Kerberos Tickets - Cloud metadata or managed identity token access	
ATT&CK mapping	TA0006 Credential Access -> T1558 Steal or Forge Kerberos Tickets Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a public cloud workload shows the following pattern: a process or workload accesses identity metadata in a manner not expected for its role. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1558 because the core observable is kerberos material is requested, extracted or forged for offline cracking or unauthorized authentication. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across AD; domain controller; EDR; Kerberos events; UEBA. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include service discovery, backup and legitimate high-volume service use.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only a sandbox metadata endpoint with a restricted test identity and no production permissions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal or Forge Kerberos Tickets without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8.4 T1555 - Credentials from Password Stores (10 mappings: MAP-0491-MAP-0500)

Behavior focus: Browsers, password managers, keychains and application stores are queried for saved secrets. Primary analytic: Sensitive material access plus later credential use. Core telemetry: EDR; process access; browser audit; file telemetry.

MAP-0491 T1555 Credentials from Password Stores - Credential material access on a workstation

ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0492 | T1555 Credentials from Password Stores - Low-and-slow password spraying

ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate lockout. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0493 | T1555 Credentials from Password Stores - Unusual Kerberos ticket activity

ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0494 | T1555 Credentials from Password Stores - Browser or application password store access

ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application

	stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0495 T1555 Credentials from Password Stores - Input capture behavior near authentication	
ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0496 T1555 Credentials from Password Stores - Web session cookie misuse	
ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0497 T1555 Credentials from Password Stores - Application token accessed by a new process	
ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later

	authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0498 T1555 Credentials from Password Stores - Secrets found in unsecured files	
ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0499 T1555 Credentials from Password Stores - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0500 T1555 Credentials from Password Stores - Cloud metadata or managed identity token access	
ATT&CK mapping	TA0006 Credential Access -> T1555 Credentials from Password Stores Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a public cloud workload shows the following pattern: a process or workload accesses identity metadata in a manner not expected for its role. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1555 because the core observable is browsers, password managers, keychains and application stores are queried for saved secrets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across EDR; process access; browser audit; file telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include password migration, backup, support and security products.. Protect evidence while identifying the targeted credential source, process and

	identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only a sandbox metadata endpoint with a restricted test identity and no production permissions. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Credentials from Password Stores without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8.5 T1056 - Input Capture (9 mappings: MAP-0501-MAP-0509)

Behavior focus: Keystrokes, forms, API hooks or credential prompts capture user authentication material. Primary analytic: Sensitive material access plus later credential use. Core telemetry: EDR; browser; application telemetry; memory protection.

MAP-0501 T1056 Input Capture - Credential material access on a workstation	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0502 T1056 Input Capture - Low-and-slow password spraying	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate logout. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0503 T1056 Input Capture - Unusual Kerberos ticket activity	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key

	rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0504 T1056 Input Capture - Browser or application password store access	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0505 T1056 Input Capture - Input capture behavior near authentication	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0506 T1056 Input Capture - Web session cookie misuse	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches

	production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0507 T1056 Input Capture - Application token accessed by a new process	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0508 T1056 Input Capture - Secrets found in unsecured files	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0509 T1056 Input Capture - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1056 Input Capture Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1056 because the core observable is keystrokes, forms, API hooks or credential prompts capture user authentication material. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across EDR; browser; application telemetry; memory protection. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility software, input methods and approved monitoring.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8.6 T1539 - Steal Web Session Cookie (9 mappings: MAP-0510-MAP-0518)

Behavior focus: Browser or application cookies are copied to reuse an authenticated session without the password. Primary analytic: Sensitive material access plus later credential use. Core telemetry: EDR; browser telemetry; file access; identity provider.

MAP-0510 T1539 Steal Web Session Cookie - Credential material access on a workstation	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0511 T1539 Steal Web Session Cookie - Low-and-slow password spraying	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate lockout. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0512 T1539 Steal Web Session Cookie - Unusual Kerberos ticket activity	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0513 T1539 Steal Web Session Cookie - Browser or application password store access	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources

Scenario and rationale	Following a user or application anomaly, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0514 T1539 Steal Web Session Cookie - Input capture behavior near authentication	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0515 T1539 Steal Web Session Cookie - Web session cookie misuse	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0516 T1539 Steal Web Session Cookie - Application token accessed by a new process	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a

	critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0517 T1539 Steal Web Session Cookie - Secrets found in unsecured files	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0518 T1539 Steal Web Session Cookie - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1539 Steal Web Session Cookie Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1539 because the core observable is browser or application cookies are copied to reuse an authenticated session without the password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining sensitive material access plus later credential use across EDR; browser telemetry; file access; identity provider. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include browser sync, profile migration and support tools.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Web Session Cookie without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8.7 T1528 - Steal Application Access Token (9 mappings: MAP-0519-MAP-0527)

Behavior focus: OAuth, API, cloud or service tokens are extracted and reused to access applications. Primary analytic: Sensitive material access plus later credential use. Core telemetry: Cloud audit; identity provider; secret store; workload telemetry.

MAP-0519 T1528 Steal Application Access Token - Credential material access on a workstation	
ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0520 T1528 Steal Application Access Token - Low-and-slow password spraying	
ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate logout. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0521 T1528 Steal Application Access Token - Unusual Kerberos ticket activity	
ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0522 T1528 Steal Application Access Token - Browser or application password store access	
ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production,

	uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0523 | T1528 Steal Application Access Token - Input capture behavior near authentication

ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0524 | T1528 Steal Application Access Token - Web session cookie misuse

ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0525 | T1528 Steal Application Access Token - Application token accessed by a new process

ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0526 | T1528 Steal Application Access Token - Secrets found in unsecured files

ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in

	files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0527 T1528 Steal Application Access Token - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1528 Steal Application Access Token Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1528 because the core observable is OAuth, API, cloud or service tokens are extracted and reused to access applications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive material access plus later credential use across Cloud audit; identity provider; secret store; workload telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automation, token refresh and application deployment. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Steal Application Access Token without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

8.8 T1552 - Unsecured Credentials (9 mappings: MAP-0528-MAP-0536)

Behavior focus: Secrets are discovered in files, scripts, registry, command history, repositories or environment variables. Primary analytic: Sensitive material access plus later credential use. Core telemetry: DLP; EDR; code repository; file audit; secret scanning.

MAP-0528 T1552 Unsecured Credentials - Credential material access on a workstation	
ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an EDR-monitored endpoint shows the following pattern: a process accesses credential-related memory, files or system interfaces outside approved security tooling. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor-provided credential-access simulation that returns only dummy test data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0529 T1552 Unsecured Credentials - Low-and-slow password spraying	
ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, the enterprise identity provider shows the following pattern: many accounts receive sparse failures from related infrastructure without immediate logout. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Apply rarity and temporal logic to sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, generate synthetic failures or use non-production accounts within agreed rate limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0530 | T1552 Unsecured Credentials - Unusual Kerberos ticket activity

ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, Active Directory shows the following pattern: ticket requests, encryption choices or service targeting differ from the account and host baseline. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use lab service accounts and normal ticket requests; do not forge or export real tickets. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0531 | T1552 Unsecured Credentials - Browser or application password store access

ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a user workstation shows the following pattern: a non-browser process accesses credential stores, profile databases or protected secrets. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a disposable browser profile populated only with fake test credentials. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0532 | T1552 Unsecured Credentials - Input capture behavior near authentication

ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an endpoint or web application shows the following pattern: keyboard, form or clipboard-related collection occurs around login activity. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and

	identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, simulate with a training form that captures only fixed dummy values and stores nothing sensitive. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0533 | T1552 Unsecured Credentials - Web session cookie misuse

ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a cloud application shows the following pattern: a session appears from a new device or location without a corresponding authentication event. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated test tenant and revoke the session immediately after generating the event. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0534 | T1552 Unsecured Credentials - Application token accessed by a new process

ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a cloud-integrated endpoint shows the following pattern: a token or credential artifact is read or used by an unusual process, application or host. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, issue a short-lived test token limited to a non-sensitive lab resource. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0535 | T1552 Unsecured Credentials - Secrets found in unsecured files

ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a development or file-sharing environment shows the following pattern: files, scripts or repositories contain credential-like strings and are accessed unexpectedly. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, seed unmistakably fake secrets in an isolated repository and monitor test access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches

	production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0536 T1552 Unsecured Credentials - Help-desk reset abuse pattern	
ATT&CK mapping	TA0006 Credential Access -> T1552 Unsecured Credentials Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, identity support operations shows the following pattern: a reset or authentication-method change is requested through an unusual channel and followed by new access. A realistic enterprise example is that credential-related incidents often involve password spraying, access to memory or stores, theft of sessions or tokens, or secrets left in files and repositories. This maps to T1552 because the core observable is secrets are discovered in files, scripts, registry, command history, repositories or environment variables. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to sensitive material access plus later credential use across DLP; EDR; code repository; file audit; secret scanning. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include configuration management and development activity.. Protect evidence while identifying the targeted credential source, process and identity involved, potential secrets exposed, subsequent authentication use, and the need for resets, token revocation or key rotation. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a tabletop or synthetic ticket exercise using a designated test identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Unsecured Credentials without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9. TA0007 - Discovery

This chapter contains 85 practical mappings across 9 priority techniques. After access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

9.1 T1087 - Account Discovery (10 mappings: MAP-0537-MAP-0546)

Behavior focus: Commands or directory queries enumerate local, domain, cloud or application accounts and groups. Primary analytic: Multi-category burst or sequence. Core telemetry: EDR; PowerShell; AD query; cloud audit; command line.

MAP-0537 T1087 Account Discovery - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0538 T1087 Account Discovery - Host and operating-system survey	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0539 T1087 Account Discovery - Network configuration enumeration	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0540 T1087 Account Discovery - Remote systems discovered from a new host	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0541 T1087 Account Discovery - Active network connections reviewed	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0542 T1087 Account Discovery - Security and software inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0543 T1087 Account Discovery - Domain trust relationships queried	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0544 T1087 Account Discovery - Privileged group membership discovery	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0545 T1087 Account Discovery - Collected data archived after discovery	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to

	T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0546 T1087 Account Discovery - Cloud resource inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1087 Account Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud subscription shows the following pattern: a new identity lists workloads, storage, keys or network resources beyond its normal use. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1087 because the core observable is commands or directory queries enumerate local, domain, cloud or application accounts and groups. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; PowerShell; AD query; cloud audit; command line. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, inventory, administration and application startup.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a read-only test identity in a sandbox subscription containing no production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Account Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.2 T1082 - System Information Discovery (10 mappings: MAP-0547-MAP-0556)

Behavior focus: Host name, operating system, hardware, patch level or domain context is collected. Primary analytic: Multi-category burst or sequence. Core telemetry: EDR; Sysmon; command line; PowerShell.

MAP-0547 T1082 System Information Discovery - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0548 T1082 System Information Discovery - Host and operating-system survey	
ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or

	successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0549 | T1082 System Information Discovery - Network configuration enumeration

ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0550 | T1082 System Information Discovery - Remote systems discovered from a new host

ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0551 | T1082 System Information Discovery - Active network connections reviewed

ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0552 | T1082 System Information Discovery - Security and software inventory discovery

ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0553 | T1082 System Information Discovery - Domain trust relationships queried

ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0554 | T1082 System Information Discovery - Privileged group membership discovery

ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic

	identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0555 T1082 System Information Discovery - Collected data archived after discovery	
ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0556 T1082 System Information Discovery - Cloud resource inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1082 System Information Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud subscription shows the following pattern: a new identity lists workloads, storage, keys or network resources beyond its normal use. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1082 because the core observable is host name, operating system, hardware, patch level or domain context is collected. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; Sysmon; command line; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting, inventory and software installers.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a read-only test identity in a sandbox subscription containing no production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Information Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.3 T1016 - System Network Configuration Discovery (10 mappings: MAP-0557-MAP-0566)

Behavior focus: Interfaces, routes, DNS, proxies, connections and network configuration are enumerated. Primary analytic: Multi-category burst or sequence. Core telemetry: EDR; command line; PowerShell; network telemetry.

MAP-0557 T1016 System Network Configuration Discovery - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches

	production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0558 T1016 System Network Configuration Discovery - Host and operating-system survey	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0559 T1016 System Network Configuration Discovery - Network configuration enumeration	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0560 T1016 System Network Configuration Discovery - Remote systems discovered from a new host	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0561 T1016 System Network Configuration Discovery - Active network connections reviewed	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the

	next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0562 T1016 System Network Configuration Discovery - Security and software inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0563 T1016 System Network Configuration Discovery - Domain trust relationships queried	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0564 T1016 System Network Configuration Discovery - Privileged group membership discovery	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0565 T1016 System Network Configuration Discovery - Collected data archived after discovery	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0566 T1016 System Network Configuration Discovery - Cloud resource inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1016 System Network Configuration Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud subscription shows the following pattern: a new identity lists workloads, storage, keys or network resources beyond its normal use. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1016 because the core observable is interfaces, routes, DNS, proxies, connections and network configuration are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; command line; PowerShell; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include network troubleshooting and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a read-only test identity in a sandbox subscription containing no production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Configuration Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.4 T1018 - Remote System Discovery (10 mappings: MAP-0567-MAP-0576)

Behavior focus: Hosts, servers, peers or cloud resources are enumerated to identify movement targets. Primary analytic: Multi-category burst or sequence. Core telemetry: EDR; AD; DNS; network flow; cloud audit.

MAP-0567 T1018 Remote System Discovery - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered.

	Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0568 | T1018 Remote System Discovery - Host and operating-system survey

ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0569 | T1018 Remote System Discovery - Network configuration enumeration

ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0570 | T1018 Remote System Discovery - Remote systems discovered from a new host

ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production,

	uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0571 | T1018 Remote System Discovery - Active network connections reviewed

ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0572 | T1018 Remote System Discovery - Security and software inventory discovery

ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0573 | T1018 Remote System Discovery - Domain trust relationships queried

ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0574 | T1018 Remote System Discovery - Privileged group membership discovery

ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
---------------------------	--

Scenario and rationale	Following a change window, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0575 T1018 Remote System Discovery - Collected data archived after discovery	
ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0576 T1018 Remote System Discovery - Cloud resource inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1018 Remote System Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a public cloud subscription shows the following pattern: a new identity lists workloads, storage, keys or network resources beyond its normal use. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1018 because the core observable is hosts, servers, peers or cloud resources are enumerated to identify movement targets. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; AD; DNS; network flow; cloud audit. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include inventory, monitoring and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a read-only test identity in a sandbox subscription containing no production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote System Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.5 T1049 - System Network Connections Discovery (9 mappings: MAP-0577-MAP-0585)

Behavior focus: Active connections, listening ports and network sessions are reviewed to understand communications. Primary analytic: Multi-category burst or sequence. Core telemetry: EDR; command line; network telemetry.

MAP-0577 T1049 System Network Connections Discovery - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an

	intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0578 | T1049 System Network Connections Discovery - Host and operating-system survey

ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0579 | T1049 System Network Connections Discovery - Network configuration enumeration

ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0580 | T1049 System Network Connections Discovery - Remote systems discovered from a new host

ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence

	when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0581 T1049 System Network Connections Discovery - Active network connections reviewed	
ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0582 T1049 System Network Connections Discovery - Security and software inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0583 T1049 System Network Connections Discovery - Domain trust relationships queried	
ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with

	administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0584 | T1049 System Network Connections Discovery - Privileged group membership discovery

ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0585 | T1049 System Network Connections Discovery - Collected data archived after discovery

ATT&CK mapping	TA0007 Discovery -> T1049 System Network Connections Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1049 because the core observable is active connections, listening ports and network sessions are reviewed to understand communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across EDR; command line; network telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include troubleshooting and performance monitoring.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify System Network Connections Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.6 T1518 - Software Discovery (9 mappings: MAP-0586-MAP-0594)

Behavior focus: Installed applications, packages, services and security products are enumerated. Primary analytic: Multi-category burst or sequence. Core telemetry: EDR; inventory; registry; package manager logs.

MAP-0586 | T1518 Software Discovery - Account enumeration after initial login

ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a user or application anomaly, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0587 | T1518 Software Discovery - Host and operating-system survey

ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After threat-intelligence enrichment, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0588 | T1518 Software Discovery - Network configuration enumeration

ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0589 | T1518 Software Discovery - Remote systems discovered from a new host

ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During an analyst-led hunt, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0590 | T1518 Software Discovery - Active network connections reviewed

ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While reviewing a high-value system, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0591 T1518 Software Discovery - Security and software inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a user or application anomaly, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0592 T1518 Software Discovery - Domain trust relationships queried	
ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After threat-intelligence enrichment, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0593 T1518 Software Discovery - Privileged group membership discovery	
ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise

	confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0594 T1518 Software Discovery - Collected data archived after discovery	
ATT&CK mapping	TA0007 Discovery -> T1518 Software Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During an analyst-led hunt, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1518 because the core observable is installed applications, packages, services and security products are enumerated. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that multi-category burst or sequence across EDR; inventory; registry; package manager logs. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include asset management, patching and support.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.7 T1482 - Domain Trust Discovery (9 mappings: MAP-0595-MAP-0603)

Behavior focus: Trust relationships, forests and domains are queried to identify movement paths. Primary analytic: Multi-category burst or sequence. Core telemetry: AD; PowerShell; EDR; directory query telemetry.

MAP-0595 T1482 Domain Trust Discovery - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0596 T1482 Domain Trust Discovery - Host and operating-system survey	
ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0597 T1482 Domain Trust Discovery - Network configuration enumeration	
ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0598 T1482 Domain Trust Discovery - Remote systems discovered from a new host	
ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0599 T1482 Domain Trust Discovery - Active network connections reviewed	
ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use

	synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

MAP-0600 | T1482 Domain Trust Discovery - Security and software inventory discovery

ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0601 | T1482 Domain Trust Discovery - Domain trust relationships queried

ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0602 | T1482 Domain Trust Discovery - Privileged group membership discovery

ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0603 | T1482 Domain Trust Discovery - Collected data archived after discovery

ATT&CK mapping	TA0007 Discovery -> T1482 Domain Trust Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1482 because the core observable is trust relationships, forests and domains are queried to identify movement paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when multi-category burst or sequence across AD; PowerShell; EDR; directory query telemetry. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include directory administration and architecture assessment.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Domain Trust Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.8 T1069 - Permission Groups Discovery (9 mappings: MAP-0604-MAP-0612)

Behavior focus: Privileged and functional groups are enumerated to identify useful accounts and access paths. Primary analytic: Multi-category burst or sequence. Core telemetry: AD; identity provider; EDR; PowerShell.

MAP-0604 T1069 Permission Groups Discovery - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While reviewing a high-value system, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0605 T1069 Permission Groups Discovery - Host and operating-system survey	
ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a user or application anomaly, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0606 T1069 Permission Groups Discovery - Network configuration enumeration	
ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity

Scenario and rationale	After threat-intelligence enrichment, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0607 T1069 Permission Groups Discovery - Remote systems discovered from a new host	
ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0608 T1069 Permission Groups Discovery - Active network connections reviewed	
ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During an analyst-led hunt, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0609 T1069 Permission Groups Discovery - Security and software inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While reviewing a high-value system, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence

	when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0610 | T1069 Permission Groups Discovery - Domain trust relationships queried

ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a user or application anomaly, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0611 | T1069 Permission Groups Discovery - Privileged group membership discovery

ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After threat-intelligence enrichment, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0612 | T1069 Permission Groups Discovery - Collected data archived after discovery

ATT&CK mapping	TA0007 Discovery -> T1069 Permission Groups Discovery Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During routine monitoring, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1069 because the core observable is privileged and functional groups are enumerated to identify useful accounts and access paths. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when multi-category burst or sequence across AD; identity provider; EDR; PowerShell. Preserve and enrich commands or API calls, process tree, categories enumerated, user, host and later movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help desk, access review and administration.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered.

	Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Permission Groups Discovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

9.9 T1560 - Archive Collected Data (9 mappings: MAP-0613-MAP-0621)

Behavior focus: Files are compressed, encrypted or packaged to simplify staging and transfer. Primary analytic: Volume or breadth anomaly followed by staging. Core telemetry: EDR; file telemetry; command line; DLP.

MAP-0613 T1560 Archive Collected Data - Account enumeration after initial login	
ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, a user or server endpoint shows the following pattern: a newly active account queries local or domain users, groups and privileges in rapid succession. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run documented read-only account queries with a test identity in the lab. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0614 T1560 Archive Collected Data - Host and operating-system survey	
ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, a managed endpoint shows the following pattern: system name, version, hardware and environment information is collected by an unusual process. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use harmless built-in information commands on a test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0615 T1560 Archive Collected Data - Network configuration enumeration	
ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, a server or workstation shows the following pattern: an unusual process gathers addresses, routes, adapters, DNS settings and proxies. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, collect configuration from a lab host using approved administrative commands. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0616 T1560 Archive Collected Data - Remote systems discovered from a new host	
ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, an internal network segment shows the following pattern: one endpoint queries or connects to many internal hosts without an inventory or management role. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a small allowlisted set of lab hosts from the security test workstation. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0617 T1560 Archive Collected Data - Active network connections reviewed	
ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	Following a change window, an endpoint shows the following pattern: a process enumerates current connections and listening services before other activity. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use normal operating-system status tools on an isolated test host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0618 T1560 Archive Collected Data - Security and software inventory discovery	
ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	After a new asset or identity appears, a corporate endpoint shows the following pattern: software, security agents or installed applications are enumerated by a process outside management tooling. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, run a benign inventory query in the lab and compare it with approved tooling. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0619 T1560 Archive Collected Data - Domain trust relationships queried	
---	--

ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During correlation of endpoint, identity and network evidence, Active Directory shows the following pattern: a user or host enumerates trust paths and domain relationships without an administrative task. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform read-only trust queries using a dedicated lab domain account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0620 | T1560 Archive Collected Data - Privileged group membership discovery

ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	During validation of an alert sequence, the identity environment shows the following pattern: multiple high-value groups and role assignments are queried soon after a new session. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query only lab groups populated with synthetic members. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0621 | T1560 Archive Collected Data - Collected data archived after discovery

ATT&CK mapping	TA0007 Discovery -> T1560 Archive Collected Data Severity: Medium to High Confidence: Medium; High with correlated follow-on activity
Scenario and rationale	While comparing activity with the 30-day baseline, an endpoint or server shows the following pattern: discovery output is gathered into a new archive in a temporary or staging directory. A realistic enterprise example is that after access, an intruder commonly inventories accounts, hosts, networks, software, groups and trust relationships to choose the next action. This maps to T1560 because the core observable is files are compressed, encrypted or packaged to simplify staging and transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across EDR; file telemetry; command line; DLP. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backups, software packaging and user archiving.. Reconstruct the enumeration sequence, identify the initiating process and account, compare it with administration baselines, and look for follow-on access to the systems, groups, software or data that were discovered. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, archive only synthetic text output from lab discovery commands and delete it after collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Archive Collected Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

10. TA0008 - Lateral Movement

This chapter contains 67 practical mappings across 7 priority techniques. A realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

10.1 T1021 - Remote Services (10 mappings: MAP-0622-MAP-0631)

Behavior focus: RDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. Primary analytic: Novel relationship followed by transfer or execution. Core telemetry: Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR.

MAP-0622 T1021 Remote Services - Remote service access from a user workstation	
ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, an internal server segment shows the following pattern: a workstation initiates administrative remote services to servers it does not normally manage. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect from a lab workstation to a lab server using a dedicated test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0623 T1021 Remote Services - Tool or file transferred between hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the internal network shows the following pattern: an executable, script or archive moves laterally and is followed by remote execution or authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy an inert marker file between two isolated lab hosts and verify both endpoint and network events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0624 T1021 Remote Services - Alternate authentication material used	
ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, the Windows domain shows the following pattern: access succeeds using authentication artifacts or patterns not consistent with a normal password logon. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic events or a vendor safe simulation; do not reuse or export real authentication material. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0625 T1021 Remote Services - Existing remote session unexpectedly controlled	
ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources

Scenario and rationale	After threat-intelligence enrichment, an administrator server shows the following pattern: a remote session changes ownership, source or activity without a new expected authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a supervised session handover only in the lab using test accounts. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0626 | T1021 Remote Services - Removable media propagation between isolated hosts

ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a controlled endpoint lab shows the following pattern: the same files or execution indicators appear after approved removable media moves between systems. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, move only inert marker files using dedicated test media between two disposable lab endpoints. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0627 | T1021 Remote Services - Software deployment system used outside workflow

ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, enterprise management tooling shows the following pattern: a deployment platform pushes content to unusual targets or under an unexpected operator account. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless text or inventory package to a lab device collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0628 | T1021 Remote Services - Remote service exploitation indicator

ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an internal test service shows the following pattern: abnormal requests, crashes or new processes occur on a remote service followed by access from the source host. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Create an analytic that novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic detection events or a non-destructive vendor test; do not exploit a production service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0629 T1021 Remote Services - Cloud-to-cloud administrative movement	
ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud management plane shows the following pattern: one compromised-looking identity pivots across subscriptions, projects or tenants through administrative APIs. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox account with read-only access across two test projects. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0630 T1021 Remote Services - Jump-host bypass	
ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a privileged access architecture shows the following pattern: an administrator identity reaches a protected server without using the required bastion or approved route. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attempt access only to a lab server from an alternate approved test path and immediately close the session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0631 T1021 Remote Services - Service account moves across application tiers	
ATT&CK mapping	TA0008 Lateral Movement -> T1021 Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a multi-tier application shows the following pattern: a service identity authenticates interactively or accesses systems outside its defined tier. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1021 because the core observable is rDP, SMB, WinRM, SSH, VNC or other services are used to authenticate and act on another system. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining novel relationship followed by transfer or execution across Windows logon; RDP; SMB; WinRM; SSH; firewall; EDR. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include administration, software support and automation.. Trace source and destination hosts, authentication type, account, remote

	service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated lab service identity and non-sensitive targets to generate scoped authentication events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

10.2 T1570 - Lateral Tool Transfer (10 mappings: MAP-0632-MAP-0641)

Behavior focus: Executables, scripts or archives are copied between hosts before remote execution. Primary analytic: Novel relationship followed by transfer or execution. Core telemetry: SMB; EDR; file telemetry; network flow.

MAP-0632 T1570 Lateral Tool Transfer - Remote service access from a user workstation	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, an internal server segment shows the following pattern: a workstation initiates administrative remote services to servers it does not normally manage. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect from a lab workstation to a lab server using a dedicated test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0633 T1570 Lateral Tool Transfer - Tool or file transferred between hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the internal network shows the following pattern: an executable, script or archive moves laterally and is followed by remote execution or authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy an inert marker file between two isolated lab hosts and verify both endpoint and network events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0634 T1570 Lateral Tool Transfer - Alternate authentication material used	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, the Windows domain shows the following pattern: access succeeds using authentication artifacts or patterns not consistent with a normal password logon. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritize an alert when novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use synthetic events or a vendor safe simulation; do not reuse or export real authentication material. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0635 T1570 Lateral Tool Transfer - Existing remote session unexpectedly controlled	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an administrator server shows the following pattern: a remote session changes ownership, source or activity without a new expected authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a supervised session handover only in the lab using test accounts. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0636 T1570 Lateral Tool Transfer - Removable media propagation between isolated hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a controlled endpoint lab shows the following pattern: the same files or execution indicators appear after approved removable media moves between systems. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, move only inert marker files using dedicated test media between two disposable lab endpoints. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0637 T1570 Lateral Tool Transfer - Software deployment system used outside workflow	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, enterprise management tooling shows the following pattern: a deployment platform pushes content to unusual targets or under an unexpected operator account. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless text or inventory package to a lab device collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0638 T1570 Lateral Tool Transfer - Remote service exploitation indicator	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an internal test service shows the following pattern: abnormal requests, crashes or new processes occur on a remote service followed by access from the source host. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic detection events or a non-destructive vendor test; do not exploit a production service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0639 T1570 Lateral Tool Transfer - Cloud-to-cloud administrative movement	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud management plane shows the following pattern: one compromised-looking identity pivots across subscriptions, projects or tenants through administrative APIs. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox account with read-only access across two test projects. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0640 T1570 Lateral Tool Transfer - Jump-host bypass	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a privileged access architecture shows the following pattern: an administrator identity reaches a protected server without using the required bastion or approved route. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attempt access only to a lab server from an alternate approved test path and immediately close the session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0641 T1570 Lateral Tool Transfer - Service account moves across application tiers	
ATT&CK mapping	TA0008 Lateral Movement -> T1570 Lateral Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a multi-tier application shows the following pattern: a service identity authenticates interactively or accesses systems outside its defined tier. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1570 because the core observable is executables, scripts or archives are copied between hosts before remote execution. The mapping describes behavior and evidence; it does not by itself prove a named

	threat actor or successful compromise.
Detection engineering	Detect the behavior by combining novel relationship followed by transfer or execution across SMB; EDR; file telemetry; network flow. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, patching and file sharing.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated lab service identity and non-sensitive targets to generate scoped authentication events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Lateral Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

10.3 T1550 - Use Alternate Authentication Material (10 mappings: MAP-0642-MAP-0651)

Behavior focus: Hashes, tickets, tokens or certificates are used instead of the cleartext password. Primary analytic: Breadth or sequence correlation across authentication events. Core telemetry: AD; Kerberos; NTLM; EDR; identity provider.

MAP-0642 T1550 Use Alternate Authentication Material - Remote service access from a user workstation	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, an internal server segment shows the following pattern: a workstation initiates administrative remote services to servers it does not normally manage. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect from a lab workstation to a lab server using a dedicated test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0643 T1550 Use Alternate Authentication Material - Tool or file transferred between hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the internal network shows the following pattern: an executable, script or archive moves laterally and is followed by remote execution or authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy an inert marker file between two isolated lab hosts and verify both endpoint and network events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0644 T1550 Use Alternate Authentication Material - Alternate authentication material used	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, the Windows domain shows the following pattern: access succeeds using authentication artifacts or patterns not consistent with a normal password logon. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Prioritise an alert when breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic events or a vendor safe simulation; do not reuse or export real authentication material. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0645 T1550 Use Alternate Authentication Material - Existing remote session unexpectedly controlled	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an administrator server shows the following pattern: a remote session changes ownership, source or activity without a new expected authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a supervised session handover only in the lab using test accounts. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0646 T1550 Use Alternate Authentication Material - Removable media propagation between isolated hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a controlled endpoint lab shows the following pattern: the same files or execution indicators appear after approved removable media moves between systems. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, move only inert marker files using dedicated test media between two disposable lab endpoints. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0647 T1550 Use Alternate Authentication Material - Software deployment system used outside workflow	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, enterprise management tooling shows the following pattern: a deployment platform pushes content to unusual targets or under an unexpected operator account. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless text or inventory package to a lab device collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0648 T1550 Use Alternate Authentication Material - Remote service exploitation indicator	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an internal test service shows the following pattern: abnormal requests, crashes or new processes occur on a remote service followed by access from the source host. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic detection events or a non-destructive vendor test; do not exploit a production service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0649 T1550 Use Alternate Authentication Material - Cloud-to-cloud administrative movement	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud management plane shows the following pattern: one compromised-looking identity pivots across subscriptions, projects or tenants through administrative APIs. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox account with read-only access across two test projects. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0650 T1550 Use Alternate Authentication Material - Jump-host bypass	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a privileged access architecture shows the following pattern: an administrator identity reaches a protected server without using the required bastion or approved route. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, attempt access only to a lab server from an alternate approved test path and immediately close the session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0651 T1550 Use Alternate Authentication Material - Service account moves across application tiers	
ATT&CK mapping	TA0008 Lateral Movement -> T1550 Use Alternate Authentication Material Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a multi-tier application shows the following pattern: a service identity authenticates interactively or accesses systems outside its defined tier. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1550 because the core observable is hashes, tickets, tokens or certificates are used instead of the cleartext password. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining breadth or sequence correlation across authentication events across AD; Kerberos; NTLM; EDR; identity provider. Preserve and enrich source, account, device, result, method, application, session and later success. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include sSO, service authentication and certificate-based administration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated lab service identity and non-sensitive targets to generate scoped authentication events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Use Alternate Authentication Material without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

10.4 T1563 - Remote Service Session Hijacking (10 mappings: MAP-0652-MAP-0661)

Behavior focus: An existing RDP, SSH or other session is taken over to inherit access. Primary analytic: Novel relationship followed by transfer or execution. Core telemetry: RDP; SSH; PAM; EDR; session audit.

MAP-0652 T1563 Remote Service Session Hijacking - Remote service access from a user workstation	
ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, an internal server segment shows the following pattern: a workstation initiates administrative remote services to servers it does not normally manage. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect from a lab workstation to a lab server using a dedicated test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0653 T1563 Remote Service Session Hijacking - Tool or file transferred between hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the internal network shows the following pattern: an executable, script or archive moves laterally and is followed by remote execution or authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, copy an inert marker file between two isolated lab hosts and verify both endpoint and network events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0654 T1563 Remote Service Session Hijacking - Alternate authentication material used	
ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, the Windows domain shows the following pattern: access succeeds using authentication artifacts or patterns not consistent with a normal password logon. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic events or a vendor safe simulation; do not reuse or export real authentication material. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0655 T1563 Remote Service Session Hijacking - Existing remote session unexpectedly controlled	
ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an administrator server shows the following pattern: a remote session changes ownership, source or activity without a new expected authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a supervised session handover only in the lab using test accounts. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0656 T1563 Remote Service Session Hijacking - Removable media propagation between isolated hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a controlled endpoint lab shows the following pattern: the same files or execution indicators appear after approved removable media moves between systems. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, move only inert marker files using dedicated test media between two disposable lab endpoints. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0657 T1563 Remote Service Session Hijacking - Software deployment system used outside workflow	
---	--

ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, enterprise management tooling shows the following pattern: a deployment platform pushes content to unusual targets or under an unexpected operator account. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless text or inventory package to a lab device collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0658 | T1563 Remote Service Session Hijacking - Remote service exploitation indicator

ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an internal test service shows the following pattern: abnormal requests, crashes or new processes occur on a remote service followed by access from the source host. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic detection events or a non-destructive vendor test; do not exploit a production service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0659 | T1563 Remote Service Session Hijacking - Cloud-to-cloud administrative movement

ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud management plane shows the following pattern: one compromised-looking identity pivots across subscriptions, projects or tenants through administrative APIs. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritize an alert when novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox account with read-only access across two test projects. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0660 | T1563 Remote Service Session Hijacking - Jump-host bypass

ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a privileged access architecture shows the following pattern: an administrator identity reaches a protected server without using the required bastion or approved route. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by

	itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attempt access only to a lab server from an alternate approved test path and immediately close the session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0661 T1563 Remote Service Session Hijacking - Service account moves across application tiers	
ATT&CK mapping	TA0008 Lateral Movement -> T1563 Remote Service Session Hijacking Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a multi-tier application shows the following pattern: a service identity authenticates interactively or accesses systems outside its defined tier. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1563 because the core observable is an existing RDP, SSH or other session is taken over to inherit access. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining novel relationship followed by transfer or execution across RDP; SSH; PAM; EDR; session audit. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include help-desk shadowing and approved collaboration.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a dedicated lab service identity and non-sensitive targets to generate scoped authentication events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Service Session Hijacking without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

10.5 T1091 - Replication Through Removable Media (9 mappings: MAP-0662-MAP-0670)

Behavior focus: Content spreads between disconnected or segmented systems through removable devices. Primary analytic: Device insertion followed by copy or execution. Core telemetry: Device control; EDR; file telemetry.

MAP-0662 T1091 Replication Through Removable Media - Remote service access from a user workstation	
ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, an internal server segment shows the following pattern: a workstation initiates administrative remote services to servers it does not normally manage. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect from a lab workstation to a lab server using a dedicated test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0663 T1091 Replication Through Removable Media - Tool or file transferred between hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the internal network shows the following pattern: an executable, script or archive moves laterally and is followed by remote execution or authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Create an analytic that device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy an inert marker file between two isolated lab hosts and verify both endpoint and network events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0664 | T1091 Replication Through Removable Media - Alternate authentication material used

ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, the Windows domain shows the following pattern: access succeeds using authentication artifacts or patterns not consistent with a normal password logon. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic events or a vendor safe simulation; do not reuse or export real authentication material. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0665 | T1091 Replication Through Removable Media - Existing remote session unexpectedly controlled

ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an administrator server shows the following pattern: a remote session changes ownership, source or activity without a new expected authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a supervised session handover only in the lab using test accounts. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0666 | T1091 Replication Through Removable Media - Removable media propagation between isolated hosts

ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a controlled endpoint lab shows the following pattern: the same files or execution indicators appear after approved removable media moves between systems. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket,

	source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, move only inert marker files using dedicated test media between two disposable lab endpoints. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0667 T1091 Replication Through Removable Media - Software deployment system used outside workflow	
ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, enterprise management tooling shows the following pattern: a deployment platform pushes content to unusual targets or under an unexpected operator account. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless text or inventory package to a lab device collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0668 T1091 Replication Through Removable Media - Remote service exploitation indicator	
ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an internal test service shows the following pattern: abnormal requests, crashes or new processes occur on a remote service followed by access from the source host. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic detection events or a non-destructive vendor test; do not exploit a production service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0669 T1091 Replication Through Removable Media - Cloud-to-cloud administrative movement	
ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a cloud management plane shows the following pattern: one compromised-looking identity pivots across subscriptions, projects or tenants through administrative APIs. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritize an alert when device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox account with read-only access across two test projects. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps.

	Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0670 T1091 Replication Through Removable Media - Jump-host bypass	
ATT&CK mapping	TA0008 Lateral Movement -> T1091 Replication Through Removable Media Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a privileged access architecture shows the following pattern: an administrator identity reaches a protected server without using the required bastion or approved route. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1091 because the core observable is content spreads between disconnected or segmented systems through removable devices. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to device insertion followed by copy or execution across Device control; EDR; file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved offline transfer and system recovery.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attempt access only to a lab server from an alternate approved test path and immediately close the session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Replication Through Removable Media without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

10.6 T1072 - Software Deployment Tools (9 mappings: MAP-0671-MAP-0679)

Behavior focus: Enterprise management, remote support or deployment systems are abused to execute across many endpoints. Primary analytic: Novel relationship followed by transfer or execution. Core telemetry: Management console; EDR; software distribution; PAM.

MAP-0671 T1072 Software Deployment Tools - Remote service access from a user workstation	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, an internal server segment shows the following pattern: a workstation initiates administrative remote services to servers it does not normally manage. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect from a lab workstation to a lab server using a dedicated test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0672 T1072 Software Deployment Tools - Tool or file transferred between hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the internal network shows the following pattern: an executable, script or archive moves laterally and is followed by remote execution or authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy an inert marker file between two isolated lab hosts and verify both endpoint and network events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0673 T1072 Software Deployment Tools - Alternate authentication material used	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the Windows domain shows the following pattern: access succeeds using authentication artifacts or patterns not consistent with a normal password login. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic events or a vendor safe simulation; do not reuse or export real authentication material. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0674 T1072 Software Deployment Tools - Existing remote session unexpectedly controlled	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an administrator server shows the following pattern: a remote session changes ownership, source or activity without a new expected authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a supervised session handover only in the lab using test accounts. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0675 T1072 Software Deployment Tools - Removable media propagation between isolated hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a controlled endpoint lab shows the following pattern: the same files or execution indicators appear after approved removable media moves between systems. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, move only inert marker files using dedicated test media between two disposable lab endpoints. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0676 T1072 Software Deployment Tools - Software deployment system used outside workflow	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, enterprise management tooling shows the following pattern: a deployment platform pushes content to unusual targets or under an unexpected operator account. A realistic enterprise example is that a realistic case

	involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless text or inventory package to a lab device collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0677 T1072 Software Deployment Tools - Remote service exploitation indicator	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, an internal test service shows the following pattern: abnormal requests, crashes or new processes occur on a remote service followed by access from the source host. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic detection events or a non-destructive vendor test; do not exploit a production service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0678 T1072 Software Deployment Tools - Cloud-to-cloud administrative movement	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a cloud management plane shows the following pattern: one compromised-looking identity pivots across subscriptions, projects or tenants through administrative APIs. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox account with read-only access across two test projects. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0679 T1072 Software Deployment Tools - Jump-host bypass	
ATT&CK mapping	TA0008 Lateral Movement -> T1072 Software Deployment Tools Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a privileged access architecture shows the following pattern: an administrator identity reaches a protected server without using the required bastion or approved route. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1072 because the core observable is enterprise management, remote support or deployment systems are abused to execute across many endpoints. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where novel relationship followed by transfer or execution across Management console; EDR; software distribution; PAM. Preserve and enrich source, destination, user, logon type, protocol, session, file transfer and remote process. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor,

	source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal patching, inventory and remote support. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attempt access only to a lab server from an alternate approved test path and immediately close the session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Software Deployment Tools without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

10.7 T1210 - Exploitation of Remote Services (9 mappings: MAP-0680-MAP-0688)

Behavior focus: A vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. Primary analytic: Exposure plus exploit signal and post-exploitation consequence. Core telemetry: IDS/IPS; EDR; vulnerability management; firewall; service logs.

MAP-0680 T1210 Exploitation of Remote Services - Remote service access from a user workstation	
ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, an internal server segment shows the following pattern: a workstation initiates administrative remote services to servers it does not normally manage. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect from a lab workstation to a lab server using a dedicated test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0681 T1210 Exploitation of Remote Services - Tool or file transferred between hosts	
ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, the internal network shows the following pattern: an executable, script or archive moves laterally and is followed by remote execution or authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy an inert marker file between two isolated lab hosts and verify both endpoint and network events. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0682 T1210 Exploitation of Remote Services - Alternate authentication material used	
ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the Windows domain shows the following pattern: access succeeds using authentication artifacts or patterns not consistent with a normal password logon. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket,

	source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic events or a vendor safe simulation; do not reuse or export real authentication material. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0683 | T1210 Exploitation of Remote Services - Existing remote session unexpectedly controlled

ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an administrator server shows the following pattern: a remote session changes ownership, source or activity without a new expected authentication. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, perform a supervised session handover only in the lab using test accounts. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0684 | T1210 Exploitation of Remote Services - Removable media propagation between isolated hosts

ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a controlled endpoint lab shows the following pattern: the same files or execution indicators appear after approved removable media moves between systems. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, move only inert marker files using dedicated test media between two disposable lab endpoints. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0685 | T1210 Exploitation of Remote Services - Software deployment system used outside workflow

ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, enterprise management tooling shows the following pattern: a deployment platform pushes content to unusual targets or under an unexpected operator account. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, deploy a harmless text or inventory package to a lab device collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production,

	uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0686 | T1210 Exploitation of Remote Services - Remote service exploitation indicator

ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, an internal test service shows the following pattern: abnormal requests, crashes or new processes occur on a remote service followed by access from the source host. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic detection events or a non-destructive vendor test; do not exploit a production service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0687 | T1210 Exploitation of Remote Services - Cloud-to-cloud administrative movement

ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a cloud management plane shows the following pattern: one compromised-looking identity pivots across subscriptions, projects or tenants through administrative APIs. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a sandbox account with read-only access across two test projects. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0688 | T1210 Exploitation of Remote Services - Jump-host bypass

ATT&CK mapping	TA0008 Lateral Movement -> T1210 Exploitation of Remote Services Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a privileged access architecture shows the following pattern: an administrator identity reaches a protected server without using the required bastion or approved route. A realistic enterprise example is that a realistic case involves one compromised account or endpoint reaching another host through remote services, deployment tools, transferred artifacts or trusted administrative paths. This maps to T1210 because the core observable is a vulnerability in SMB, RDP, database or other remote service is exploited to reach another host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining exposure plus exploit signal and post-exploitation consequence across IDS/IPS; EDR; vulnerability management; firewall; service logs. Preserve and enrich asset exposure, request or fault, child process, memory evidence, privilege change and network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include security testing and unstable services.. Trace source and destination hosts, authentication type, account, remote service, transferred artifacts and follow-on commands; determine whether the movement crossed trust zones or reached privileged systems. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, attempt access only to a lab server from an alternate approved test path and immediately close the session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exploitation of Remote Services without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11. TA0009 - Collection

This chapter contains 76 practical mappings across 8 priority techniques. Before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

11.1 T1005 - Data from Local System (10 mappings: MAP-0689-MAP-0698)

Behavior focus: Documents, databases, browser data or application files are accessed from the compromised host. Primary analytic: Volume or breadth anomaly followed by staging. Core telemetry: DLP; file audit; EDR; application logs.

MAP-0689 T1005 Data from Local System - Local document collection	
ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0690 T1005 Data from Local System - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0691 T1005 Data from Local System - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0692 T1005 Data from Local System - Clipboard content captured	
ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0693 T1005 Data from Local System - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0694 T1005 Data from Local System - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0695 T1005 Data from Local System - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application

	files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0696 | T1005 Data from Local System - Form or input data collected

ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0697 | T1005 Data from Local System - Database query volume expands

ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0698 | T1005 Data from Local System - Cloud storage object collection

ATT&CK mapping	TA0009 Collection -> T1005 Data from Local System Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a sandbox cloud tenant shows the following pattern: a user or application lists and downloads many objects across containers or projects. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1005 because the core observable is documents, databases, browser data or application files are accessed from the compromised host. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across DLP; file audit; EDR; application logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service

	account, expected destination and normal time window. Likely benign explanations include normal user access, search indexing and backup.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic objects in a dedicated test bucket and a read-only exercise identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Local System without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11.2 T1039 - Data from Network Shared Drive (10 mappings: MAP-0699-MAP-0708)

Behavior focus: Shared folders and mapped drives are searched or copied for information of value. Primary analytic: Volume or breadth anomaly followed by staging. Core telemetry: SMB; file server audit; DLP; EDR.

MAP-0699 T1039 Data from Network Shared Drive - Local document collection	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0700 T1039 Data from Network Shared Drive - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0701 T1039 Data from Network Shared Drive - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0702 T1039 Data from Network Shared Drive - Clipboard content captured	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0703 T1039 Data from Network Shared Drive - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0704 T1039 Data from Network Shared Drive - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0705 T1039 Data from Network Shared Drive - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources

Scenario and rationale	Following a change window, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0706 T1039 Data from Network Shared Drive - Form or input data collected	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0707 T1039 Data from Network Shared Drive - Database query volume expands	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0708 T1039 Data from Network Shared Drive - Cloud storage object collection	
ATT&CK mapping	TA0009 Collection -> T1039 Data from Network Shared Drive Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a sandbox cloud tenant shows the following pattern: a user or application lists and downloads many objects across containers or projects. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1039 because the core observable is shared folders and mapped drives are searched or copied for information of value. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across SMB; file server audit; DLP; EDR. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is

	followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include departmental work, backup and migration.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic objects in a dedicated test bucket and a read-only exercise identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data from Network Shared Drive without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11.3 T1114 - Email Collection (10 mappings: MAP-0709-MAP-0718)

Behavior focus: Mailboxes, local mail stores or email APIs are searched, exported or forwarded. Primary analytic: Volume or breadth anomaly followed by staging. Core telemetry: M365 audit; Exchange; email DLP; identity provider.

MAP-0709 T1114 Email Collection - Local document collection	
ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0710 T1114 Email Collection - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0711 T1114 Email Collection - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0712 T1114 Email Collection - Clipboard content captured	
ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0713 T1114 Email Collection - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0714 T1114 Email Collection - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0715 T1114 Email Collection - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are

	searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0716 | T1114 Email Collection - Form or input data collected

ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0717 | T1114 Email Collection - Database query volume expands

ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0718 | T1114 Email Collection - Cloud storage object collection

ATT&CK mapping	TA0009 Collection -> T1114 Email Collection Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a sandbox cloud tenant shows the following pattern: a user or application lists and downloads many objects across containers or projects. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1114 because the core observable is mailboxes, local mail stores or email APIs are searched, exported or forwarded. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across M365 audit; Exchange; email DLP; identity provider. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include eDiscovery, legal hold, migration and user rules.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation

	explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic objects in a dedicated test bucket and a read-only exercise identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Email Collection without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11.4 T1115 - Clipboard Data (10 mappings: MAP-0719-MAP-0728)

Behavior focus: Clipboard content is read to capture copied credentials, text or data. Primary analytic: Volume or breadth anomaly followed by staging.
Core telemetry: EDR; DLP; application telemetry.

MAP-0719 T1115 Clipboard Data - Local document collection	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0720 T1115 Clipboard Data - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0721 T1115 Clipboard Data - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0722 T1115 Clipboard Data - Clipboard content captured

ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0723 T1115 Clipboard Data - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0724 T1115 Clipboard Data - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0725 T1115 Clipboard Data - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0726 T1115 Clipboard Data - Form or input data collected	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0727 T1115 Clipboard Data - Database query volume expands	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0728 T1115 Clipboard Data - Cloud storage object collection	
ATT&CK mapping	TA0009 Collection -> T1115 Clipboard Data Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a sandbox cloud tenant shows the following pattern: a user or application lists and downloads many objects across containers or projects. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1115 because the core observable is clipboard content is read to capture copied credentials, text or data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across EDR; DLP; application telemetry. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include clipboard managers, accessibility and remote support.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic objects in a dedicated test bucket and a read-only exercise identity. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Clipboard Data without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11.5 T1113 - Screen Capture (9 mappings: MAP-0729-MAP-0737)

Behavior focus: Screenshots are taken to collect visible information or monitor user activity. Primary analytic: Volume or breadth anomaly followed by staging. Core telemetry: EDR; process telemetry; API monitoring.

MAP-0729 T1113 Screen Capture - Local document collection	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0730 T1113 Screen Capture - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0731 T1113 Screen Capture - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0732 T1113 Screen Capture - Clipboard content captured	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0733 T1113 Screen Capture - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0734 T1113 Screen Capture - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0735 T1113 Screen Capture - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and

	synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	--

MAP-0736 T1113 Screen Capture - Form or input data collected	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0737 T1113 Screen Capture - Database query volume expands	
ATT&CK mapping	TA0009 Collection -> T1113 Screen Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1113 because the core observable is screenshots are taken to collect visible information or monitor user activity. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across EDR; process telemetry; API monitoring. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include collaboration tools, support and user-initiated screenshots. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Screen Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11.6 T1123 - Audio Capture (9 mappings: MAP-0738-MAP-0746)

Behavior focus: Microphone input is recorded to collect conversations or environmental information. Primary analytic: Volume or breadth anomaly followed by staging. Core telemetry: EDR; privacy control; device access logs.

MAP-0738 T1123 Audio Capture - Local document collection	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0739 T1123 Audio Capture - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources

Scenario and rationale	During routine monitoring, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0740 T1123 Audio Capture - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0741 T1123 Audio Capture - Clipboard content captured	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0742 T1123 Audio Capture - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source

	ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0743 T1123 Audio Capture - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0744 T1123 Audio Capture - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0745 T1123 Audio Capture - Form or input data collected	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0746 T1123 Audio Capture - Database query volume expands	
ATT&CK mapping	TA0009 Collection -> T1123 Audio Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1123 because the core observable is microphone input is recorded to collect conversations or environmental information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to volume or breadth anomaly followed by staging across EDR; privacy control; device access logs. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include conferencing, transcription and accessibility.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Audio Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11.7 T1074 - Data Staged (9 mappings: MAP-0747-MAP-0755)

Behavior focus: Collected material is consolidated in a local, network or cloud staging location. Primary analytic: Volume or breadth anomaly followed by staging. Core telemetry: File audit; DLP; EDR; cloud storage audit.

MAP-0747 T1074 Data Staged - Local document collection	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0748 T1074 Data Staged - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0749 T1074 Data Staged - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named

	threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0750 T1074 Data Staged - Clipboard content captured	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0751 T1074 Data Staged - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0752 T1074 Data Staged - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0753 T1074 Data Staged - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0754 T1074 Data Staged - Form or input data collected	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0755 T1074 Data Staged - Database query volume expands	
ATT&CK mapping	TA0009 Collection -> T1074 Data Staged Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1074 because the core observable is collected material is consolidated in a local, network or cloud staging location. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that volume or breadth anomaly followed by staging across File audit; DLP; EDR; cloud storage audit. Preserve and enrich data source, sensitivity, volume, breadth, user, process, staging location and archive. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup, exports, software builds and analytics workflows.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Staged without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

11.8 T1056 - Input Capture (9 mappings: MAP-0756-MAP-0764)

Behavior focus: Forms, keystrokes or application input are captured as a source of information. Primary analytic: Sensitive material access plus later credential use. Core telemetry: EDR; browser; application telemetry.

MAP-0756 T1056 Input Capture - Local document collection

ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a corporate endpoint shows the following pattern: a process or account reads many documents from user folders without a matching business workflow. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, populate a lab profile with synthetic documents and perform a controlled read-only collection. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0757 T1056 Input Capture - Network share harvesting	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file-server environment shows the following pattern: a host enumerates and reads files across multiple shares at an unusual rate or scope. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a lab share containing dummy files and a test account with limited read access. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0758 T1056 Input Capture - Mailbox content collection	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, Microsoft 365 or another mail platform shows the following pattern: a user, application or protocol reads unusual mailbox volumes or folders outside its baseline. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a test mailbox filled with synthetic messages and revoke access after the exercise. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0759 T1056 Input Capture - Clipboard content captured	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a user workstation shows the following pattern: an unexpected process accesses clipboard content around authentication or sensitive application use. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time,

	action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, place only a fixed dummy string in the clipboard of an isolated lab endpoint. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0760 T1056 Input Capture - Repeated screen capture	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an endpoint shows the following pattern: a process captures screens repeatedly or around high-value application windows. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign screenshot utility on a lab desktop containing only synthetic information. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0761 T1056 Input Capture - Audio capture permission and activity	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a collaboration endpoint shows the following pattern: a non-collaboration process accesses the microphone or records audio outside an approved meeting. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, record a short synthetic tone in a lab with no people or conversations present. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0762 T1056 Input Capture - Data staged in a temporary location	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a server or workstation shows the following pattern: files from multiple sources are copied into a new staging directory before compression or transfer. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy dummy files into a designated lab staging folder and delete them after evidence capture. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0763 T1056 Input Capture - Form or input data collected	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a test web application or endpoint shows the following pattern: input values are captured by an unexpected process, script or application component. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use only pre-defined fake values in a training form with no real user data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0764 T1056 Input Capture - Database query volume expands	
ATT&CK mapping	TA0009 Collection -> T1056 Input Capture Severity: High Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a business database shows the following pattern: an account reads a broader set of tables or records than its normal role requires. A realistic enterprise example is that before data leaves the environment, it is often read from endpoints, shares, mailboxes, databases or cloud storage and staged or archived for efficient handling. This maps to T1056 because the core observable is forms, keystrokes or application input are captured as a source of information. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that sensitive material access plus later credential use across EDR; browser; application telemetry. Preserve and enrich requester process, target process or store, access rights, files, secrets, user and later authentication. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include accessibility, input tools and approved testing.. Identify the data source, selection logic, volume, staging path, process and account, then check whether the collected material was compressed, transferred, deleted or accessed by another host. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, query a sandbox database containing only generated records with a test account. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Input Capture without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12. TA0011 - Command and Control

This chapter contains 76 practical mappings across 8 priority techniques. Many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

12.1 T1071 - Application Layer Protocol (10 mappings: MAP-0765-MAP-0774)

Behavior focus: HTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: Proxy; DNS; firewall; NDR; EDR; TLS metadata.

MAP-0765 T1071 Application Layer Protocol - Periodic HTTPS beacon-like traffic	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is HTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0766 T1071 Application Layer Protocol - Unusual non-application protocol traffic	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is HTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0767 T1071 Application Layer Protocol - Tool transfer from an external host	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is HTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0768 T1071 Application Layer Protocol - Encrypted channel to a rare destination	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is HTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0769 T1071 Application Layer Protocol - Protocol tunneling indicator	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-

	access software or tool transfer. This maps to T1071 because the core observable is hTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0770 T1071 Application Layer Protocol - External proxy chain	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is hTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0771 T1071 Application Layer Protocol - Unapproved remote access software session	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is hTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0772 T1071 Application Layer Protocol - Web service used as a control channel	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is hTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0773 T1071 Application Layer Protocol - Domain fronting or destination mismatch pattern	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is HTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0774 T1071 Application Layer Protocol - Dead-drop resolver pattern	
ATT&CK mapping	TA0011 Command and Control -> T1071 Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, web and DNS telemetry shows the following pattern: an endpoint periodically retrieves small configuration-like content from a public page or service. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1071 because the core observable is HTTP, HTTPS, DNS, mail or other common protocols carry tasking and results. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Proxy; DNS; firewall; NDR; EDR; TLS metadata. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software updates, telemetry and cloud applications.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless static configuration marker on an internal exercise page. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12.2 T1095 - Non-Application Layer Protocol (10 mappings: MAP-0775-MAP-0784)

Behavior focus: Raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: Firewall; NDR; NetFlow; EDR.

MAP-0775 T1095 Non-Application Layer Protocol - Periodic HTTPS beacon-like traffic	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record

	any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0776 T1095 Non-Application Layer Protocol - Unusual non-application protocol traffic	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0777 T1095 Non-Application Layer Protocol - Tool transfer from an external host	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0778 T1095 Non-Application Layer Protocol - Encrypted channel to a rare destination	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0779 T1095 Non-Application Layer Protocol - Protocol tunneling indicator	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0780 T1095 Non-Application Layer Protocol - External proxy chain	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0781 T1095 Non-Application Layer Protocol - Unapproved remote access software session	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0782 T1095 Non-Application Layer Protocol - Web service used as a control channel	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0783 T1095 Non-Application Layer Protocol - Domain fronting or destination mismatch pattern	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0784 T1095 Non-Application Layer Protocol - Dead-drop resolver pattern	
ATT&CK mapping	TA0011 Command and Control -> T1095 Non-Application Layer Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, web and DNS telemetry shows the following pattern: an endpoint periodically retrieves small configuration-like content from a public page or service. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1095 because the core observable is raw TCP, UDP or uncommon protocol traffic carries C2 outside normal application semantics. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Firewall; NDR; NetFlow; EDR. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include custom business protocols and infrastructure monitoring.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless static configuration marker on an internal exercise page. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Non-Application Layer Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12.3 T1105 - Ingress Tool Transfer (10 mappings: MAP-0785-MAP-0794)

Behavior focus: Additional payloads, scripts or tools are downloaded to the compromised environment. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: Proxy; firewall; EDR; DNS; file telemetry.

MAP-0785 T1105 Ingress Tool Transfer - Periodic HTTPS beacon-like traffic	
ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source,

	target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0786 | T1105 Ingress Tool Transfer - Unusual non-application protocol traffic

ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0787 | T1105 Ingress Tool Transfer - Tool transfer from an external host

ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0788 | T1105 Ingress Tool Transfer - Encrypted channel to a rare destination

ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or

	future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0789 T1105 Ingress Tool Transfer - Protocol tunneling indicator	
ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0790 T1105 Ingress Tool Transfer - External proxy chain	
ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0791 T1105 Ingress Tool Transfer - Unapproved remote access software session	
ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0792 T1105 Ingress Tool Transfer - Web service used as a control channel	
ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0793 T1105 Ingress Tool Transfer - Domain fronting or destination mismatch pattern	
ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0794 T1105 Ingress Tool Transfer - Dead-drop resolver pattern	
ATT&CK mapping	TA0011 Command and Control -> T1105 Ingress Tool Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, web and DNS telemetry shows the following pattern: an endpoint periodically retrieves small configuration-like content from a public page or service. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1105 because the core observable is additional payloads, scripts or tools are downloaded to the compromised environment. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Proxy; firewall; EDR; DNS; file telemetry. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include software distribution, package managers and user downloads.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, host a harmless static configuration marker on an internal exercise page. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Ingress Tool Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12.4 T1573 - Encrypted Channel (10 mappings: MAP-0795-MAP-0804)

Behavior focus: Encryption or custom encoding conceals command traffic and transferred content. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: TLS metadata; proxy; NDR; EDR; certificate intelligence.

MAP-0795 T1573 Encrypted Channel - Periodic HTTPS beacon-like traffic

ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0796 | T1573 Encrypted Channel - Unusual non-application protocol traffic

ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0797 | T1573 Encrypted Channel - Tool transfer from an external host

ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0798 | T1573 Encrypted Channel - Encrypted channel to a rare destination

ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding

	conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0799 T1573 Encrypted Channel - Protocol tunneling indicator	
ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0800 T1573 Encrypted Channel - External proxy chain	
ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0801 T1573 Encrypted Channel - Unapproved remote access software session	
ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should

	state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0802 | T1573 Encrypted Channel - Web service used as a control channel

ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0803 | T1573 Encrypted Channel - Domain fronting or destination mismatch pattern

ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0804 | T1573 Encrypted Channel - Dead-drop resolver pattern

ATT&CK mapping	TA0011 Command and Control -> T1573 Encrypted Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, web and DNS telemetry shows the following pattern: an endpoint periodically retrieves small configuration-like content from a public page or service. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1573 because the core observable is encryption or custom encoding conceals command traffic and transferred content. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across TLS metadata; proxy; NDR; EDR; certificate intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include ordinary HTTPS, VPN and encrypted enterprise services.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future

	changes.
Safe validation	In an isolated or non-production environment, host a harmless static configuration marker on an internal exercise page. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Encrypted Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12.5 T1572 - Protocol Tunneling (9 mappings: MAP-0805-MAP-0813)

Behavior focus: One protocol is encapsulated inside another to bypass routing, filtering or inspection. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: DNS; proxy; firewall; NDR; network flow.

MAP-0805 T1572 Protocol Tunneling - Periodic HTTPS beacon-like traffic	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include VPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0806 T1572 Protocol Tunneling - Unusual non-application protocol traffic	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include VPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0807 T1572 Protocol Tunneling - Tool transfer from an external host	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include VPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling

	without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0808 T1572 Protocol Tunneling - Encrypted channel to a rare destination	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0809 T1572 Protocol Tunneling - Protocol tunneling indicator	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0810 T1572 Protocol Tunneling - External proxy chain	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0811 T1572 Protocol Tunneling - Unapproved remote access software session	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is

	that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0812 T1572 Protocol Tunneling - Web service used as a control channel	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0813 T1572 Protocol Tunneling - Domain fronting or destination mismatch pattern	
ATT&CK mapping	TA0011 Command and Control -> T1572 Protocol Tunneling Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1572 because the core observable is one protocol is encapsulated inside another to bypass routing, filtering or inspection. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across DNS; proxy; firewall; NDR; network flow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include vPN, remote support and legitimate tunneling.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Protocol Tunneling without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12.6 T1090 - Proxy (9 mappings: MAP-0814-MAP-0822)

Behavior focus: External, internal or multi-hop proxies obscure the true source or destination of communications. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: Proxy; firewall; VPN; NDR; threat intelligence.

MAP-0814 T1090 Proxy - Periodic HTTPS beacon-like traffic	
ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Detect the behavior by combining new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0815 | T1090 Proxy - Unusual non-application protocol traffic

ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0816 | T1090 Proxy - Tool transfer from an external host

ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0817 | T1090 Proxy - Encrypted channel to a rare destination

ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service

	account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0818 | T1090 Proxy - Protocol tunneling indicator

ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0819 | T1090 Proxy - External proxy chain

ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0820 | T1090 Proxy - Unapproved remote access software session

ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized

	timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0821 T1090 Proxy - Web service used as a control channel	
ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0822 T1090 Proxy - Domain fronting or destination mismatch pattern	
ATT&CK mapping	TA0011 Command and Control -> T1090 Proxy Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1090 because the core observable is external, internal or multi-hop proxies obscure the true source or destination of communications. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when new-or-rare plus periodicity or sequence correlation across Proxy; firewall; VPN; NDR; threat intelligence. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include corporate proxies, privacy services and remote workforce tools.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Proxy without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12.7 T1219 - Remote Access Software (9 mappings: MAP-0823-MAP-0831)

Behavior focus: Commercial remote management or support tools provide interactive control and file transfer. Primary analytic: Unapproved capability plus service, connection or transfer. Core telemetry: EDR; software inventory; proxy; firewall; identity.

MAP-0823 T1219 Remote Access Software - Periodic HTTPS beacon-like traffic	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0824 T1219 Remote Access Software - Unusual non-application protocol traffic	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0825 T1219 Remote Access Software - Tool transfer from an external host	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0826 T1219 Remote Access Software - Encrypted channel to a rare destination	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0827 T1219 Remote Access Software - Protocol tunneling indicator	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-

	access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0828 T1219 Remote Access Software - External proxy chain	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0829 T1219 Remote Access Software - Unapproved remote access software session	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0830 T1219 Remote Access Software - Web service used as a control channel	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0831 T1219 Remote Access Software - Domain fronting or destination mismatch pattern	
ATT&CK mapping	TA0011 Command and Control -> T1219 Remote Access Software Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1219 because the core observable is commercial remote management or support tools provide interactive control and file transfer. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that unapproved capability plus service, connection or transfer across EDR; software inventory; proxy; firewall; identity. Preserve and enrich product, path, signer, installation source, user, service, destination and approval status. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved help-desk, vendor support and remote work.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Remote Access Software without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

12.8 T1102 - Web Service (9 mappings: MAP-0832-MAP-0840)

Behavior focus: Public cloud, messaging, code or collaboration services are used as a C2 channel. Primary analytic: Control-plane or data-plane sequence with identity risk. Core telemetry: Proxy; CASB; SaaS audit; DNS; EDR.

MAP-0832 T1102 Web Service - Periodic HTTPS beacon-like traffic	
ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, the enterprise web proxy shows the following pattern: an endpoint contacts a rare domain at regular intervals with similar byte patterns and little user interaction. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an internal web server to generate a short, clearly tagged periodic heartbeat from a lab host. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0833 T1102 Web Service - Unusual non-application protocol traffic	
ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, the network perimeter shows the following pattern: a host uses an uncommon protocol or port pattern to communicate externally outside its asset role. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure.

	Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send harmless tagged packets between lab systems on an approved test segment. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0834 | T1102 Web Service - Tool transfer from an external host

ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, endpoint and proxy telemetry shows the following pattern: a newly contacted domain or IP delivers an executable, script or archive followed by process activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, download an inert text marker renamed as a test artifact from an internal exercise server. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0835 | T1102 Web Service - Encrypted channel to a rare destination

ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, firewall and TLS telemetry shows the following pattern: a process establishes repeated encrypted sessions to a new destination with unusual certificate or timing features. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, connect a lab process to an internal TLS test service using a short-lived certificate. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0836 | T1102 Web Service - Protocol tunneling indicator

ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, DNS, proxy or network telemetry shows the following pattern: request size, frequency or encoding suggests that one protocol is carrying data for another purpose. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a benign vendor simulation or synthetic logs; do not construct an operational tunnel. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0837 T1102 Web Service - External proxy chain	
ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, web and firewall telemetry shows the following pattern: traffic from an endpoint is relayed through newly observed proxy infrastructure inconsistent with corporate configuration. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, route a lab browser through an approved internal test proxy and remove the configuration afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0838 T1102 Web Service - Unapproved remote access software session	
ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, endpoint and network monitoring shows the following pattern: remote-control software starts, persists or communicates from an asset without an active support ticket. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use an approved remote support product on a lab endpoint with a designated test session. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0839 T1102 Web Service - Web service used as a control channel	
ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, cloud and proxy telemetry shows the following pattern: a process communicates with a legitimate web service in a repetitive automated pattern unrelated to user activity. A realistic enterprise example is that many incidents show repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, post fixed non-sensitive test messages to an internally controlled webhook service. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0840 T1102 Web Service - Domain fronting or destination mismatch pattern	
ATT&CK mapping	TA0011 Command and Control -> T1102 Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, TLS and proxy telemetry shows the following pattern: visible domain indicators do not align with the destination, certificate or application behavior. A realistic enterprise example is that many incidents show

	repeated outbound communication, encrypted or proxied channels, legitimate web-service abuse, remote-access software or tool transfer. This maps to T1102 because the core observable is public cloud, messaging, code or collaboration services are used as a C2 channel. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to control-plane or data-plane sequence with identity risk across Proxy; CASB; SaaS audit; DNS; EDR. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include normal collaboration, development and automation.. Resolve the process-to-destination relationship, interval and byte pattern, DNS and TLS context, first-seen history, related downloads or commands, and whether the destination is shared legitimate infrastructure. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use synthetic proxy records representing the mismatch rather than reproducing fronting externally. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

13. TA0010 - Exfiltration

This chapter contains 67 practical mappings across 7 priority techniques. A practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

13.1 T1041 - Exfiltration Over C2 Channel (10 mappings: MAP-0841-MAP-0850)

Behavior focus: Collected data leaves through the same channel used for command and control. Primary analytic: Sensitive access and staging followed by unusual transfer. Core telemetry: Proxy; firewall; NDR; DLP; EDR.

MAP-0841 T1041 Exfiltration Over C2 Channel - Outbound transfer over an established channel	
ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, proxy and endpoint telemetry shows the following pattern: a process sends an unusual volume of data through a channel already associated with suspicious activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, transfer generated dummy files to an internal exercise receiver with strict size limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0842 T1041 Exfiltration Over C2 Channel - Upload to a web storage service	
ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, cloud access and proxy logs shows the following pattern: an account uploads archives or sensitive-looking filenames to a newly used web service. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, upload synthetic files to an approved internal or sandbox storage service and then delete them. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0843 T1041 Exfiltration Over C2 Channel - Alternative protocol transfer	
ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources

	more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, network monitoring shows the following pattern: large or repeated outbound transfers use a protocol not expected for the source asset. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send bounded dummy data between lab hosts using an approved test protocol. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0844 T1041 Exfiltration Over C2 Channel - Physical media data movement	
ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a controlled endpoint shows the following pattern: files are copied to removable media outside an approved export process. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy only synthetic files to designated test media and securely erase it afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0845 T1041 Exfiltration Over C2 Channel - Automated recurring upload	
ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a server or cloud workload shows the following pattern: data is packaged and transferred repeatedly without an interactive user or approved integration. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a lab job that sends a tiny generated file to an internal receiver and then remove the job. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0846 T1041 Exfiltration Over C2 Channel - Transfer between cloud accounts	
ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a sandbox cloud environment shows the following pattern: objects move from the enterprise tenant to a new external or personal account. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Use a sequence-based rule that sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy synthetic objects between two controlled test accounts with no production trust. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0847 | T1041 Exfiltration Over C2 Channel - Scheduled bulk transfer window

ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a file or application server shows the following pattern: large transfers recur at a fixed time that does not match backup or business schedules. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a small internal lab transfer and label all events with the exercise identifier. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0848 | T1041 Exfiltration Over C2 Channel - Email-based outbound data movement

ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, corporate email and DLP monitoring shows the following pattern: a user or application sends unusual attachments or message volumes to a new external recipient. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send synthetic documents only to an approved test mailbox controlled by the security team. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0849 | T1041 Exfiltration Over C2 Channel - Repository or code-hosting upload

ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, developer network and SaaS audit logs shows the following pattern: a host pushes a new archive or repository containing data patterns outside development activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record

	any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, push generated dummy files to a private sandbox repository and delete it after testing. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0850 T1041 Exfiltration Over C2 Channel - Encrypted archive leaves the network	
ATT&CK mapping	TA0010 Exfiltration -> T1041 Exfiltration Over C2 Channel Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint, DLP and proxy telemetry shows the following pattern: a newly created archive with high entropy is uploaded shortly after broad file access. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1041 because the core observable is collected data leaves through the same channel used for command and control. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive access and staging followed by unusual transfer across Proxy; firewall; NDR; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate application upload and telemetry.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an encrypted archive containing only random test data and upload it to an internal receiver. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over C2 Channel without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

13.2 T1567 - Exfiltration Over Web Service (10 mappings: MAP-0851-MAP-0860)

Behavior focus: Cloud storage, code repositories, file transfer or paste services receive stolen data. Primary analytic: Control-plane or data-plane sequence with identity risk. Core telemetry: CASB; proxy; DLP; cloud audit; DNS.

MAP-0851 T1567 Exfiltration Over Web Service - Outbound transfer over an established channel	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, proxy and endpoint telemetry shows the following pattern: a process sends an unusual volume of data through a channel already associated with suspicious activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, transfer generated dummy files to an internal exercise receiver with strict size limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0852 T1567 Exfiltration Over Web Service - Upload to a web storage service	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, cloud access and proxy logs shows the following pattern: an account uploads archives or sensitive-looking filenames to a newly used web service. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, upload synthetic files to an approved internal or sandbox storage service and then delete them. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0853 T1567 Exfiltration Over Web Service - Alternative protocol transfer	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, network monitoring shows the following pattern: large or repeated outbound transfers use a protocol not expected for the source asset. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send bounded dummy data between lab hosts using an approved test protocol. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0854 T1567 Exfiltration Over Web Service - Physical media data movement	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a controlled endpoint shows the following pattern: files are copied to removable media outside an approved export process. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy only synthetic files to designated test media and securely erase it afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0855 T1567 Exfiltration Over Web Service - Automated recurring upload	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a server or cloud workload shows the following pattern: data is packaged and transferred repeatedly without an interactive user or approved integration. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a lab job that sends a tiny generated file to an internal receiver and then remove the job. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0856 T1567 Exfiltration Over Web Service - Transfer between cloud accounts	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a sandbox cloud environment shows the following pattern: objects move from the enterprise tenant to a new external or personal account. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy synthetic objects between two controlled test accounts with no production trust. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0857 T1567 Exfiltration Over Web Service - Scheduled bulk transfer window	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a file or application server shows the following pattern: large transfers recur at a fixed time that does not match backup or business schedules. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a small internal lab transfer and label all events with the exercise identifier. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0858 T1567 Exfiltration Over Web Service - Email-based outbound data movement	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, corporate email and DLP monitoring shows the following pattern: a user or application sends unusual attachments or message volumes to a new external recipient. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send synthetic documents only to an approved test mailbox controlled by the security team. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0859 T1567 Exfiltration Over Web Service - Repository or code-hosting upload	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, developer network and SaaS audit logs shows the following pattern: a host pushes a new archive or repository containing data patterns outside development activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium

	moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, push generated dummy files to a private sandbox repository and delete it after testing. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0860 T1567 Exfiltration Over Web Service - Encrypted archive leaves the network	
ATT&CK mapping	TA0010 Exfiltration -> T1567 Exfiltration Over Web Service Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint, DLP and proxy telemetry shows the following pattern: a newly created archive with high entropy is uploaded shortly after broad file access. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1567 because the core observable is cloud storage, code repositories, file transfer or paste services receive stolen data. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to control-plane or data-plane sequence with identity risk across CASB; proxy; DLP; cloud audit; DNS. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include authorized cloud collaboration and software development.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an encrypted archive containing only random test data and upload it to an internal receiver. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Web Service without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

13.3 T1048 - Exfiltration Over Alternative Protocol (10 mappings: MAP-0861-MAP-0870)

Behavior focus: DNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. Primary analytic: New-or-rare plus periodicity or sequence correlation. Core telemetry: Firewall; DNS; NDR; proxy; NetFlow.

MAP-0861 T1048 Exfiltration Over Alternative Protocol - Outbound transfer over an established channel	
ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, proxy and endpoint telemetry shows the following pattern: a process sends an unusual volume of data through a channel already associated with suspicious activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is dNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, transfer generated dummy files to an internal exercise receiver with strict size limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0862 T1048 Exfiltration Over Alternative Protocol - Upload to a web storage service	
ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, cloud access and proxy logs shows the following pattern: an account uploads archives or sensitive-looking filenames to a newly used web service. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is dNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a

	named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, upload synthetic files to an approved internal or sandbox storage service and then delete them. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0863 T1048 Exfiltration Over Alternative Protocol - Alternative protocol transfer	
ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, network monitoring shows the following pattern: large or repeated outbound transfers use a protocol not expected for the source asset. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is dNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send bounded dummy data between lab hosts using an approved test protocol. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0864 T1048 Exfiltration Over Alternative Protocol - Physical media data movement	
ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a controlled endpoint shows the following pattern: files are copied to removable media outside an approved export process. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is dNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy only synthetic files to designated test media and securely erase it afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0865 T1048 Exfiltration Over Alternative Protocol - Automated recurring upload	
ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a server or cloud workload shows the following pattern: data is packaged and transferred repeatedly without an interactive user or approved integration. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is dNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target,

	time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a lab job that sends a tiny generated file to an internal receiver and then remove the job. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0866 | T1048 Exfiltration Over Alternative Protocol - Transfer between cloud accounts

ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a sandbox cloud environment shows the following pattern: objects move from the enterprise tenant to a new external or personal account. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is DNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy synthetic objects between two controlled test accounts with no production trust. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0867 | T1048 Exfiltration Over Alternative Protocol - Scheduled bulk transfer window

ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a file or application server shows the following pattern: large transfers recur at a fixed time that does not match backup or business schedules. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is DNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a small internal lab transfer and label all events with the exercise identifier. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0868 | T1048 Exfiltration Over Alternative Protocol - Email-based outbound data movement

ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, corporate email and DLP monitoring shows the following pattern: a user or application sends unusual attachments or message volumes to a new external recipient. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is DNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or

	process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send synthetic documents only to an approved test mailbox controlled by the security team. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0869 T1048 Exfiltration Over Alternative Protocol - Repository or code-hosting upload	
ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, developer network and SaaS audit logs shows the following pattern: a host pushes a new archive or repository containing data patterns outside development activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is dNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, push generated dummy files to a private sandbox repository and delete it after testing. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0870 T1048 Exfiltration Over Alternative Protocol - Encrypted archive leaves the network	
ATT&CK mapping	TA0010 Exfiltration -> T1048 Exfiltration Over Alternative Protocol Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint, DLP and proxy telemetry shows the following pattern: a newly created archive with high entropy is uploaded shortly after broad file access. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1048 because the core observable is dNS, FTP, mail, custom protocols or unexpected ports transfer data outside normal channels. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to new-or-rare plus periodicity or sequence correlation across Firewall; DNS; NDR; proxy; NetFlow. Preserve and enrich source and destination, port, protocol, bytes, DNS, certificate, process, first seen and interval. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legacy applications, monitoring and vendor integrations.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an encrypted archive containing only random test data and upload it to an internal receiver. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Alternative Protocol without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

13.4 T1052 - Exfiltration Over Physical Medium (10 mappings: MAP-0871-MAP-0880)

Behavior focus: Data is copied to removable media or another physically transported device. Primary analytic: Device insertion followed by copy or execution. Core telemetry: Device control; DLP; endpoint file telemetry.

MAP-0871 T1052 Exfiltration Over Physical Medium - Outbound transfer over an established channel	
ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, proxy and endpoint telemetry shows the following pattern: a process sends an unusual volume of data through a channel already associated with suspicious activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted.

	Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, transfer generated dummy files to an internal exercise receiver with strict size limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0872 | T1052 Exfiltration Over Physical Medium - Upload to a web storage service

ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, cloud access and proxy logs shows the following pattern: an account uploads archives or sensitive-looking filenames to a newly used web service. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, upload synthetic files to an approved internal or sandbox storage service and then delete them. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0873 | T1052 Exfiltration Over Physical Medium - Alternative protocol transfer

ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, network monitoring shows the following pattern: large or repeated outbound transfers use a protocol not expected for the source asset. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send bounded dummy data between lab hosts using an approved test protocol. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0874 | T1052 Exfiltration Over Physical Medium - Physical media data movement

ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a controlled endpoint shows the following pattern: files are copied to removable media outside an approved export process. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy only synthetic files to designated test media and securely erase it afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity

	reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0875 | T1052 Exfiltration Over Physical Medium - Automated recurring upload

ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a server or cloud workload shows the following pattern: data is packaged and transferred repeatedly without an interactive user or approved integration. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a lab job that sends a tiny generated file to an internal receiver and then remove the job. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0876 | T1052 Exfiltration Over Physical Medium - Transfer between cloud accounts

ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a sandbox cloud environment shows the following pattern: objects move from the enterprise tenant to a new external or personal account. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy synthetic objects between two controlled test accounts with no production trust. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0877 | T1052 Exfiltration Over Physical Medium - Scheduled bulk transfer window

ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a file or application server shows the following pattern: large transfers recur at a fixed time that does not match backup or business schedules. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a small internal lab transfer and label all events with the exercise identifier. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0878 | T1052 Exfiltration Over Physical Medium - Email-based outbound data movement

ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
---------------------------	---

Scenario and rationale	During correlation of endpoint, identity and network evidence, corporate email and DLP monitoring shows the following pattern: a user or application sends unusual attachments or message volumes to a new external recipient. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send synthetic documents only to an approved test mailbox controlled by the security team. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0879 T1052 Exfiltration Over Physical Medium - Repository or code-hosting upload	
ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, developer network and SaaS audit logs shows the following pattern: a host pushes a new archive or repository containing data patterns outside development activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, push generated dummy files to a private sandbox repository and delete it after testing. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0880 T1052 Exfiltration Over Physical Medium - Encrypted archive leaves the network	
ATT&CK mapping	TA0010 Exfiltration -> T1052 Exfiltration Over Physical Medium Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, endpoint, DLP and proxy telemetry shows the following pattern: a newly created archive with high entropy is uploaded shortly after broad file access. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1052 because the core observable is data is copied to removable media or another physically transported device. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to device insertion followed by copy or execution across Device control; DLP; endpoint file telemetry. Preserve and enrich device identity, policy, host, user, files copied, execution and later network activity. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved media use, backup and offline transfer.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, create an encrypted archive containing only random test data and upload it to an internal receiver. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Exfiltration Over Physical Medium without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

13.5 T1020 - Automated Exfiltration (9 mappings: MAP-0881-MAP-0889)

Behavior focus: Scripts or tools repeatedly collect and transfer data without manual interaction. Primary analytic: Sensitive access and staging followed by unusual transfer. Core telemetry: EDR; scheduler; DLP; proxy; firewall.

MAP-0881 T1020 Automated Exfiltration - Outbound transfer over an established channel	
ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, proxy and endpoint telemetry shows the following pattern: a process sends an unusual volume of data through a channel already associated with suspicious activity. A realistic enterprise example is that a practical case

	may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, transfer generated dummy files to an internal exercise receiver with strict size limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0882 | T1020 Automated Exfiltration - Upload to a web storage service

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, cloud access and proxy logs shows the following pattern: an account uploads archives or sensitive-looking filenames to a newly used web service. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, upload synthetic files to an approved internal or sandbox storage service and then delete them. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0883 | T1020 Automated Exfiltration - Alternative protocol transfer

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, network monitoring shows the following pattern: large or repeated outbound transfers use a protocol not expected for the source asset. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send bounded dummy data between lab hosts using an approved test protocol. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0884 | T1020 Automated Exfiltration - Physical media data movement

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a controlled endpoint shows the following pattern: files are copied to removable media outside an approved export process. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud

	account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy only synthetic files to designated test media and securely erase it afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0885 | T1020 Automated Exfiltration - Automated recurring upload

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a server or cloud workload shows the following pattern: data is packaged and transferred repeatedly without an interactive user or approved integration. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a lab job that sends a tiny generated file to an internal receiver and then remove the job. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0886 | T1020 Automated Exfiltration - Transfer between cloud accounts

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a sandbox cloud environment shows the following pattern: objects move from the enterprise tenant to a new external or personal account. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy synthetic objects between two controlled test accounts with no production trust. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0887 | T1020 Automated Exfiltration - Scheduled bulk transfer window

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a file or application server shows the following pattern: large transfers recur at a fixed time that does not match backup or business schedules. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user

	or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a small internal lab transfer and label all events with the exercise identifier. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0888 | T1020 Automated Exfiltration - Email-based outbound data movement

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, corporate email and DLP monitoring shows the following pattern: a user or application sends unusual attachments or message volumes to a new external recipient. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send synthetic documents only to an approved test mailbox controlled by the security team. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0889 | T1020 Automated Exfiltration - Repository or code-hosting upload

ATT&CK mapping	TA0010 Exfiltration -> T1020 Automated Exfiltration Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, developer network and SaaS audit logs shows the following pattern: a host pushes a new archive or repository containing data patterns outside development activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1020 because the core observable is scripts or tools repeatedly collect and transfer data without manual interaction. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive access and staging followed by unusual transfer across EDR; scheduler; DLP; proxy; firewall. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include automated backup, synchronization and reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, push generated dummy files to a private sandbox repository and delete it after testing. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Automated Exfiltration without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

13.6 T1537 - Transfer Data to Cloud Account (9 mappings: MAP-0890-MAP-0898)

Behavior focus: Data is moved from an enterprise-controlled tenant or account to an external cloud account. Primary analytic: Control-plane or data-plane sequence with identity risk. Core telemetry: Cloud audit; CASB; DLP; identity provider.

MAP-0890 | T1537 Transfer Data to Cloud Account - Outbound transfer over an established channel

ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, proxy and endpoint telemetry shows the following pattern: a process sends an unusual volume of data through a channel already associated with suspicious activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, transfer generated dummy files to an internal exercise receiver with strict size limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	---

MAP-0891 T1537 Transfer Data to Cloud Account - Upload to a web storage service	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, cloud access and proxy logs shows the following pattern: an account uploads archives or sensitive-looking filenames to a newly used web service. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, upload synthetic files to an approved internal or sandbox storage service and then delete them. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0892 T1537 Transfer Data to Cloud Account - Alternative protocol transfer	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, network monitoring shows the following pattern: large or repeated outbound transfers use a protocol not expected for the source asset. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send bounded dummy data between lab hosts using an approved test protocol. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0893 T1537 Transfer Data to Cloud Account - Physical media data movement	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a controlled endpoint shows the following pattern: files are copied to removable media outside an approved export process. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy only synthetic files to designated test media and securely erase it afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0894 T1537 Transfer Data to Cloud Account - Automated recurring upload	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a server or cloud workload shows the following pattern: data is packaged and transferred repeatedly without an interactive user or approved integration. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a lab job that sends a tiny generated file to an internal receiver and then remove the job. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0895 T1537 Transfer Data to Cloud Account - Transfer between cloud accounts	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a sandbox cloud environment shows the following pattern: objects move from the enterprise tenant to a new external or personal account. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy synthetic objects between two controlled test accounts with no production trust. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0896 T1537 Transfer Data to Cloud Account - Scheduled bulk transfer window	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a file or application server shows the following pattern: large transfers recur at a fixed time that does not match backup or business schedules. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a small internal lab transfer and label all events with the exercise identifier. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0897 T1537 Transfer Data to Cloud Account - Email-based outbound data movement	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, corporate email and DLP monitoring shows the following pattern: a user or application sends unusual attachments or message volumes to a new external recipient. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by

	itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send synthetic documents only to an approved test mailbox controlled by the security team. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0898 T1537 Transfer Data to Cloud Account - Repository or code-hosting upload	
ATT&CK mapping	TA0010 Exfiltration -> T1537 Transfer Data to Cloud Account Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, developer network and SaaS audit logs shows the following pattern: a host pushes a new archive or repository containing data patterns outside development activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1537 because the core observable is data is moved from an enterprise-controlled tenant or account to an external cloud account. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining control-plane or data-plane sequence with identity risk across Cloud audit; CASB; DLP; identity provider. Preserve and enrich tenant, actor, application, token, source device, target resource, old and new state and data movement. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include partner collaboration and tenant migration.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, push generated dummy files to a private sandbox repository and delete it after testing. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Transfer Data to Cloud Account without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

13.7 T1029 - Scheduled Transfer (9 mappings: MAP-0899-MAP-0907)

Behavior focus: Data transfer occurs at defined times or intervals to blend with routine traffic. Primary analytic: Sensitive access and staging followed by unusual transfer. Core telemetry: Scheduler; proxy; firewall; DLP; EDR.

MAP-0899 T1029 Scheduled Transfer - Outbound transfer over an established channel	
ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, proxy and endpoint telemetry shows the following pattern: a process sends an unusual volume of data through a channel already associated with suspicious activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, transfer generated dummy files to an internal exercise receiver with strict size limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0900 T1029 Scheduled Transfer - Upload to a web storage service	
ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, cloud access and proxy logs shows the following pattern: an account uploads archives or sensitive-looking filenames to a newly used web service. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.

Detection engineering	Build a correlation that sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, upload synthetic files to an approved internal or sandbox storage service and then delete them. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0901 | T1029 Scheduled Transfer - Alternative protocol transfer

ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, network monitoring shows the following pattern: large or repeated outbound transfers use a protocol not expected for the source asset. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send bounded dummy data between lab hosts using an approved test protocol. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0902 | T1029 Scheduled Transfer - Physical media data movement

ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a controlled endpoint shows the following pattern: files are copied to removable media outside an approved export process. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy only synthetic files to designated test media and securely erase it afterward. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0903 | T1029 Scheduled Transfer - Automated recurring upload

ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a server or cloud workload shows the following pattern: data is packaged and transferred repeatedly without an interactive user or approved integration. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service

	account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a lab job that sends a tiny generated file to an internal receiver and then remove the job. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0904 | T1029 Scheduled Transfer - Transfer between cloud accounts

ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a sandbox cloud environment shows the following pattern: objects move from the enterprise tenant to a new external or personal account. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, copy synthetic objects between two controlled test accounts with no production trust. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0905 | T1029 Scheduled Transfer - Scheduled bulk transfer window

ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a file or application server shows the following pattern: large transfers recur at a fixed time that does not match backup or business schedules. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, schedule a small internal lab transfer and label all events with the exercise identifier. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0906 | T1029 Scheduled Transfer - Email-based outbound data movement

ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, corporate email and DLP monitoring shows the following pattern: a user or application sends unusual attachments or message volumes to a new external recipient. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, send synthetic documents only to an approved test mailbox controlled by the

	security team. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0907 T1029 Scheduled Transfer - Repository or code-hosting upload	
ATT&CK mapping	TA0010 Exfiltration -> T1029 Scheduled Transfer Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, developer network and SaaS audit logs shows the following pattern: a host pushes a new archive or repository containing data patterns outside development activity. A realistic enterprise example is that a practical case may involve an archive, automated job, cloud account, web service, alternative protocol or physical medium moving data outside its approved boundary. This maps to T1029 because the core observable is data transfer occurs at defined times or intervals to blend with routine traffic. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to sensitive access and staging followed by unusual transfer across Scheduler; proxy; firewall; DLP; EDR. Preserve and enrich data source and sensitivity, archive or staging, destination, cloud account, protocol, volume and session. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include batch integration, backups and scheduled reporting.. Measure the transferred data, identify source files and destination ownership, verify the user or process, review DLP and application audit evidence, and determine whether the transfer was completed, blocked or only attempted. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, push generated dummy files to a private sandbox repository and delete it after testing. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Scheduled Transfer without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

14. TA0040 - Impact

This chapter contains 93 practical mappings across 10 priority techniques. Operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. The records emphasise observable behavior, evidence quality, narrow tuning and safe validation.

14.1 T1486 - Data Encrypted for Impact (10 mappings: MAP-0908-MAP-0917)

Behavior focus: Files, databases or storage are encrypted to deny availability, often at high speed and broad scope. Primary analytic: Emergency threshold and destructive precursor. Core telemetry: EDR; file integrity; storage; backup; Windows events.

MAP-0908 T1486 Data Encrypted for Impact - Rapid file encryption pattern	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint lab shows the following pattern: many files are rewritten, renamed or become unreadable within a short period by one process or account. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor ransomware simulator or rename synthetic lab files; never encrypt production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0909 T1486 Data Encrypted for Impact - Recovery mechanism interference	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a backup test environment shows the following pattern: backup jobs, snapshots or recovery settings are disabled or deleted before other destructive activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption,

	backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, pause and restore only a disposable lab backup job under change control. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0910 T1486 Data Encrypted for Impact - Destructive file deletion	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox server shows the following pattern: large numbers of files or records are deleted by an unusual process or privileged identity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, delete only generated test files from a disposable lab directory and restore from the test backup. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0911 T1486 Data Encrypted for Impact - Critical service stopped	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application test server shows the following pattern: a required service is stopped or disabled outside maintenance and business transactions fail. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, stop a non-critical lab service for a brief approved interval and restart it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0912 T1486 Data Encrypted for Impact - Website content altered	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a non-production web application shows the following pattern: public-facing content or configuration changes outside the release pipeline. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a clearly labelled test page in staging and restore it through the normal deployment process. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if

	activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
MAP-0913 T1486 Data Encrypted for Impact - Network resource exhaustion	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an isolated performance test segment shows the following pattern: traffic volume or connection behavior overwhelms a service and degrades availability. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a bounded vendor load test against a purpose-built lab service with automatic stop limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0914 T1486 Data Encrypted for Impact - Endpoint resource exhaustion	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a disposable virtual machine shows the following pattern: a process consumes CPU, memory, handles or disk in a way that prevents normal operation. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled performance test with conservative limits and automatic termination. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0915 T1486 Data Encrypted for Impact - Business data manipulated	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox database or application shows the following pattern: records are changed in bulk or outside the approved transaction workflow. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, alter generated test records in a sandbox and compare audit logs before restoring the dataset. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0916 T1486 Data Encrypted for Impact - User access deliberately removed	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a test identity tenant shows the following pattern: accounts, credentials or roles are

	disabled or revoked in a pattern that disrupts access. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, disable and re-enable only dedicated test identities with no production dependency. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0917 T1486 Data Encrypted for Impact - Unexpected shutdown or reboot	
ATT&CK mapping	TA0040 Impact -> T1486 Data Encrypted for Impact Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a lab server or endpoint shows the following pattern: systems restart or shut down outside maintenance shortly after suspicious administrative activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1486 because the core observable is files, databases or storage are encrypted to deny availability, often at high speed and broad scope. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that emergency threshold and destructive precursor across EDR; file integrity; storage; backup; Windows events. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include legitimate encryption, backup and large file operations.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reboot a disposable lab virtual machine within a documented exercise window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Encrypted for Impact without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

14.2 T1490 - Inhibit System Recovery (10 mappings: MAP-0918-MAP-0927)

Behavior focus: Backups, snapshots, recovery services or restore configurations are deleted or disabled. Primary analytic: Emergency threshold and destructive precursor. Core telemetry: Backup audit; EDR; Windows System; cloud audit.

MAP-0918 T1490 Inhibit System Recovery - Rapid file encryption pattern	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint lab shows the following pattern: many files are rewritten, renamed or become unreadable within a short period by one process or account. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor ransomware simulator or rename synthetic lab files; never encrypt production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0919 T1490 Inhibit System Recovery - Recovery mechanism interference	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a backup test environment shows the following pattern: backup jobs, snapshots or recovery settings are disabled or deleted before other destructive activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore

	configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, pause and restore only a disposable lab backup job under change control. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0920 T1490 Inhibit System Recovery - Destructive file deletion	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox server shows the following pattern: large numbers of files or records are deleted by an unusual process or privileged identity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, delete only generated test files from a disposable lab directory and restore from the test backup. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0921 T1490 Inhibit System Recovery - Critical service stopped	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application test server shows the following pattern: a required service is stopped or disabled outside maintenance and business transactions fail. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, stop a non-critical lab service for a brief approved interval and restart it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0922 T1490 Inhibit System Recovery - Website content altered	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a non-production web application shows the following pattern: public-facing content or configuration changes outside the release pipeline. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target,

	time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a clearly labelled test page in staging and restore it through the normal deployment process. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0923 T1490 Inhibit System Recovery - Network resource exhaustion	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an isolated performance test segment shows the following pattern: traffic volume or connection behavior overwhelms a service and degrades availability. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a bounded vendor load test against a purpose-built lab service with automatic stop limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0924 T1490 Inhibit System Recovery - Endpoint resource exhaustion	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a disposable virtual machine shows the following pattern: a process consumes CPU, memory, handles or disk in a way that prevents normal operation. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled performance test with conservative limits and automatic termination. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0925 T1490 Inhibit System Recovery - Business data manipulated	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox database or application shows the following pattern: records are changed in bulk or outside the approved transaction workflow. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future

	changes.
Safe validation	In an isolated or non-production environment, alter generated test records in a sandbox and compare audit logs before restoring the dataset. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0926 T1490 Inhibit System Recovery - User access deliberately removed	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a test identity tenant shows the following pattern: accounts, credentials or roles are disabled or revoked in a pattern that disrupts access. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, disable and re-enable only dedicated test identities with no production dependency. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0927 T1490 Inhibit System Recovery - Unexpected shutdown or reboot	
ATT&CK mapping	TA0040 Impact -> T1490 Inhibit System Recovery Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a lab server or endpoint shows the following pattern: systems restart or shut down outside maintenance shortly after suspicious administrative activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1490 because the core observable is backups, snapshots, recovery services or restore configurations are deleted or disabled. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that emergency threshold and destructive precursor across Backup audit; EDR; Windows System; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include backup maintenance, retention cleanup and disaster-recovery tests.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reboot a disposable lab virtual machine within a documented exercise window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Inhibit System Recovery without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

14.3 T1485 - Data Destruction (10 mappings: MAP-0928-MAP-0937)

Behavior focus: Files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. Primary analytic: Emergency threshold and destructive precursor. Core telemetry: EDR; file audit; database audit; storage; cloud audit.

MAP-0928 T1485 Data Destruction - Rapid file encryption pattern	
ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint lab shows the following pattern: many files are rewritten, renamed or become unreadable within a short period by one process or account. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor ransomware simulator or rename synthetic lab files; never

	encrypt production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0929 | T1485 Data Destruction - Recovery mechanism interference

ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a backup test environment shows the following pattern: backup jobs, snapshots or recovery settings are disabled or deleted before other destructive activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, pause and restore only a disposable lab backup job under change control. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0930 | T1485 Data Destruction - Destructive file deletion

ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox server shows the following pattern: large numbers of files or records are deleted by an unusual process or privileged identity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, delete only generated test files from a disposable lab directory and restore from the test backup. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0931 | T1485 Data Destruction - Critical service stopped

ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application test server shows the following pattern: a required service is stopped or disabled outside maintenance and business transactions fail. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, stop a non-critical lab service for a brief approved interval and restart it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0932 | T1485 Data Destruction - Website content altered

ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a non-production web application shows the following pattern: public-facing content or configuration changes outside the release pipeline. A realistic enterprise example is that operational incidents may

	encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a clearly labelled test page in staging and restore it through the normal deployment process. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0933 | T1485 Data Destruction - Network resource exhaustion

ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an isolated performance test segment shows the following pattern: traffic volume or connection behavior overwhelms a service and degrades availability. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a bounded vendor load test against a purpose-built lab service with automatic stop limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0934 | T1485 Data Destruction - Endpoint resource exhaustion

ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a disposable virtual machine shows the following pattern: a process consumes CPU, memory, handles or disk in a way that prevents normal operation. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled performance test with conservative limits and automatic termination. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0935 | T1485 Data Destruction - Business data manipulated

ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox database or application shows the following pattern: records are changed in bulk or outside the approved transaction workflow. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.

Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, alter generated test records in a sandbox and compare audit logs before restoring the dataset. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0936 T1485 Data Destruction - User access deliberately removed	
ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a test identity tenant shows the following pattern: accounts, credentials or roles are disabled or revoked in a pattern that disrupts access. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, disable and re-enable only dedicated test identities with no production dependency. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0937 T1485 Data Destruction - Unexpected shutdown or reboot	
ATT&CK mapping	TA0040 Impact -> T1485 Data Destruction Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a lab server or endpoint shows the following pattern: systems restart or shut down outside maintenance shortly after suspicious administrative activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1485 because the core observable is files, databases, disks or cloud objects are deleted or overwritten to cause irreversible loss. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that emergency threshold and destructive precursor across EDR; file audit; database audit; storage; cloud audit. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved decommissioning, data lifecycle and test cleanup.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, reboot a disposable lab virtual machine within a documented exercise window. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Data Destruction without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

14.4 T1489 - Service Stop (9 mappings: MAP-0938-MAP-0946)

Behavior focus: Critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. Primary analytic: Emergency threshold and destructive precursor. Core telemetry: Windows System; service manager; EDR; application monitoring.

MAP-0938 T1489 Service Stop - Rapid file encryption pattern	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, a file server or endpoint lab shows the following pattern: many files are rewritten, renamed or become unreadable within a short period by one process or account. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.

Safe validation	In an isolated or non-production environment, use a vendor ransomware simulator or rename synthetic lab files; never encrypt production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
------------------------	--

MAP-0939 T1489 Service Stop - Recovery mechanism interference	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a backup test environment shows the following pattern: backup jobs, snapshots or recovery settings are disabled or deleted before other destructive activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, pause and restore only a disposable lab backup job under change control. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0940 T1489 Service Stop - Destructive file deletion	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox server shows the following pattern: large numbers of files or records are deleted by an unusual process or privileged identity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, delete only generated test files from a disposable lab directory and restore from the test backup. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0941 T1489 Service Stop - Critical service stopped	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, an application test server shows the following pattern: a required service is stopped or disabled outside maintenance and business transactions fail. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, stop a non-critical lab service for a brief approved interval and restart it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0942 T1489 Service Stop - Website content altered	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a user or application anomaly, a non-production web application shows the following pattern: public-facing content or configuration changes outside the release pipeline. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force

	systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Create an analytic that emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Review recurring benign cases and constrain by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a clearly labelled test page in staging and restore it through the normal deployment process. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0943 T1489 Service Stop - Network resource exhaustion	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After threat-intelligence enrichment, an isolated performance test segment shows the following pattern: traffic volume or connection behavior overwhelms a service and degrades availability. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Prioritise an alert when emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Baseline authorised tools, identities and windows, then exclude asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a bounded vendor load test against a purpose-built lab service with automatic stop limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0944 T1489 Service Stop - Endpoint resource exhaustion	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During routine monitoring, a disposable virtual machine shows the following pattern: a process consumes CPU, memory, handles or disk in a way that prevents normal operation. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Apply rarity and temporal logic to emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Use change and asset context to separate asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled performance test with conservative limits and automatic termination. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0945 T1489 Service Stop - Business data manipulated	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During an analyst-led hunt, a sandbox database or application shows the following pattern: records are changed in bulk or outside the approved transaction workflow. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Detect the behavior by combining emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Apply scoped suppression only for asset role, approved scanner or tool identity, change ticket, source ownership, service

	account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, alter generated test records in a sandbox and compare audit logs before restoring the dataset. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0946 T1489 Service Stop - User access deliberately removed	
ATT&CK mapping	TA0040 Impact -> T1489 Service Stop Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While reviewing a high-value system, a test identity tenant shows the following pattern: accounts, credentials or roles are disabled or revoked in a pattern that disrupts access. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1489 because the core observable is critical services, agents, databases or applications are stopped to disrupt operations or facilitate damage. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use entity-aware correlation to emergency threshold and destructive precursor across Windows System; service manager; EDR; application monitoring. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Tune narrowly by asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include maintenance, patching and troubleshooting.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, disable and re-enable only dedicated test identities with no production dependency. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Service Stop without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

14.5 T1491 - Defacement (9 mappings: MAP-0947-MAP-0955)

Behavior focus: Websites, portals or public content are modified to damage trust or communicate a message. Primary analytic: Emergency threshold and destructive precursor. Core telemetry: Web integrity; CMS audit; WAF; source control.

MAP-0947 T1491 Defacement - Rapid file encryption pattern	
ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, a file server or endpoint lab shows the following pattern: many files are rewritten, renamed or become unreadable within a short period by one process or account. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a vendor ransomware simulator or rename synthetic lab files; never encrypt production data. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0948 T1491 Defacement - Recovery mechanism interference	
ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a backup test environment shows the following pattern: backup jobs, snapshots or recovery settings are disabled or deleted before other destructive activity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, pause and restore only a disposable lab backup job under change control. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps.

	Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.
--	---

MAP-0949 T1491 Defacement - Destructive file deletion	
ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a sandbox server shows the following pattern: large numbers of files or records are deleted by an unusual process or privileged identity. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, delete only generated test files from a disposable lab directory and restore from the test backup. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0950 T1491 Defacement - Critical service stopped	
ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, an application test server shows the following pattern: a required service is stopped or disabled outside maintenance and business transactions fail. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, stop a non-critical lab service for a brief approved interval and restart it. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0951 T1491 Defacement - Website content altered	
ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During correlation of endpoint, identity and network evidence, a non-production web application shows the following pattern: public-facing content or configuration changes outside the release pipeline. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Generate a detection when emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Reduce benign volume through asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, modify a clearly labelled test page in staging and restore it through the normal deployment process. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0952 T1491 Defacement - Network resource exhaustion	
ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	During validation of an alert sequence, an isolated performance test segment shows the following pattern: traffic volume or connection behavior overwhelms a service and degrades availability. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself

	prove a named threat actor or successful compromise.
Detection engineering	Build a correlation that emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Attach business context and tune using asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a bounded vendor load test against a purpose-built lab service with automatic stop limits. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0953 | T1491 Defacement - Endpoint resource exhaustion

ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	While comparing activity with the 30-day baseline, a disposable virtual machine shows the following pattern: a process consumes CPU, memory, handles or disk in a way that prevents normal operation. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Model normal activity and flag cases where emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Avoid broad allowlisting; instead use asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, use a controlled performance test with conservative limits and automatic termination. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0954 | T1491 Defacement - Business data manipulated

ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	Following a change window, a sandbox database or application shows the following pattern: records are changed in bulk or outside the approved transaction workflow. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Correlate raw and normalised events to emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Require additional evidence for asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any telemetry limitation explicitly and avoid a broad allowlist that would suppress unrelated entities or future changes.
Safe validation	In an isolated or non-production environment, alter generated test records in a sandbox and compare audit logs before restoring the dataset. Use synthetic identities and data, reserved test infrastructure, a documented change ticket and synchronized timestamps. Success requires the intended evidence to arrive, the analytic to identify Defacement without overstating impact, an analyst to reconstruct the event, and all test objects to be removed or restored. Stop if activity reaches production, uses a real secret, weakens a live control, transfers sensitive data or cannot be reversed.

MAP-0955 | T1491 Defacement - User access deliberately removed

ATT&CK mapping	TA0040 Impact -> T1491 Defacement Severity: Critical Confidence: High when corroborated by two or more sources
Scenario and rationale	After a new asset or identity appears, a test identity tenant shows the following pattern: accounts, credentials or roles are disabled or revoked in a pattern that disrupts access. A realistic enterprise example is that operational incidents may encrypt, delete or manipulate data, stop services, disrupt networks, remove account access, alter public content or force systems offline. This maps to T1491 because the core observable is websites, portals or public content are modified to damage trust or communicate a message. The mapping describes behavior and evidence; it does not by itself prove a named threat actor or successful compromise.
Detection engineering	Use a sequence-based rule that emergency threshold and destructive precursor across Web integrity; CMS audit; WAF; source control. Preserve and enrich initiating process, account, affected files or services, rate, recovery state, spread and containment result. Raise confidence when the activity is new for the entity, occurs outside an approved workflow, affects a critical asset or privileged identity, or is followed by another ATT&CK-aligned behavior. The alert should state the actor, source, target, time, action, result and the strongest supporting raw events.
Investigation and tuning	Preserve coverage while excluding asset role, approved scanner or tool identity, change ticket, source ownership, service account, expected destination and normal time window. Likely benign explanations include approved content publication and emergency updates.. Prioritise safety and service restoration, identify the initiating identity and process, preserve affected-system evidence, determine scope and business effect, and verify that recovery does not reintroduce the cause. Record any